

STUDY PACK

Privacy, the AI Act and the Assessments

Practical Privacy · Practical AI Act Advice · six assessment
tools · the GDPR readiness model

31

REFERENCE TOPICS

337

ASSESSMENT QUESTIONS

71

READINESS ACTIVITIES

69

SELF-TEST QUESTIONS

Printed for study. Everything here is reference material and none of it is legal advice.

How to use this pack

This is the whole body of material in one printable document: the two written references in full, every question the six assessment tools ask with the scoring model behind each one, and the complete readiness model. It is organised so it can be read straight through once and then used for retrieval practice afterwards, which is the part that actually makes it stick.

The one thing that matters most

Reading this pack three times will feel productive and will teach you much less than reading it once and then testing yourself on it three times. Recognition is not recall: a paragraph you have just read feels known, and that feeling disappears the moment someone asks you the question cold. Every part ends with a self-test whose answers are printed on a later page for exactly this reason. Use them as the primary activity, not as a nice-to-have at the end.

Two habits do most of the work. First, before reading a section, read only its heading and try to list what you think it will say: even a wrong guess prepares the memory to hold the right answer. Second, after reading a section, close the pack and say the decision rule out loud in one sentence. If you cannot, you have not finished with that section.

What is in each part

- **Part 1, Practical Privacy.** Eighteen situations that recur inside every organisation: surveillance, offboarding, mailbox access, meetings, remote work, surveys, talent data, rights requests, sensitive data, consent, secondary use, external requests, AI and analytics, regulators, digital products, breach response, records management, marketing. Each carries a key takeaways box which is the version to revise from.
- **Part 2, Practical AI Act Advice.** Thirteen sections covering scope, prohibitions, high-risk classification, provider and deployer obligations, GPAI, conformity, governance and enforcement, then four practitioner sections on building a program, assessing risk, vetting vendors, literacy, and copyright. Same takeaway boxes.
- **Part 3, the Assessment Suite.** Six tools. Each one opens with a cheat sheet covering what it is for, its shape, what it returns, how the scoring works and where people get it wrong, followed by the full question bank step by step. Read the cheat sheet first: the questions only make sense once you know what the scoring does with the answers.
- **Part 4, the GDPR Readiness Model.** The method, the four statuses, the 13 scope questions, all 71 activities with both evidence questions and their Article mapping, and the reverse Article index.
- **Appendices.** The long option lists that were too big to sit inline, and a fifteen-minute review card: the whole pack compressed to the facts worth knowing cold.

A four-week plan

Roughly forty minutes a day, five days a week. The review column is the part people skip and the part that produces the result: it is deliberately short, and it always covers material from earlier weeks rather than the material you just read.

WEEK	NEW MATERIAL	REVIEW, 10 MINUTES	END OF WEEK
1	Part 1, topics 1 to 18. Four topics a day: read, then say the decision rule aloud.	Yesterday's takeaway boxes, from the heading only.	Part 1 self-test, closed book. Mark honestly.
2	Part 2, sections 1 to 13. Three a day. The dates, the penalty tiers and the ten prohibitions want writing out by hand.	Part 1 takeaway boxes, four a day, plus any Part 1 self-test question you got wrong.	Part 2 self-test, closed book.
3	Part 3. One tool a day: cheat sheet first, then skim the question bank, then reconstruct the scoring model on paper without looking.	Part 2 takeaways, three a day.	Part 3 self-test. Then work one real case through the Privacy Assessment end to end.
4	Part 4. The method and statuses on day one, then three or four activity categories a day.	Part 3 cheat sheets, one a day, from memory.	Part 4 self-test, then the review card in Appendix B against the clock.

After the four weeks

Space the reviews out rather than stopping. Revisit the review card after one week, then after a month, then after three. Each successful recall at a longer gap buys a longer gap after it, and the whole card takes a quarter of an hour. Anything you fail twice at that spacing is worth copying onto a single sheet of its own: a list of your own failures is a better revision aid than any summary written by someone else, including this one.

The material also rewards use over revision. The fastest way to hold the six tools in memory is to run a real process through the Privacy Assessment, a real vendor through the Third-Party Security Assessment, and a real or invented incident through the ENISA formula. Ten minutes of that beats an hour of rereading.

A note on printing

The pack is set for A4 with page numbers, running headers and a linked table of contents. Self-test answers always begin on a fresh page, so you can fold the answer pages back while you work. If you are printing double-sided, the part openers are deliberately short pages: that is intentional, so each part starts cleanly.

Contents

Part 1. Practical Privacy	6
1. Video Surveillance, Photography & Location Tracking	7
2. Offboarding: Protecting Data When Someone Leaves	9
3. Accessing Another Person's Mailbox	10
4. Meetings: Recording, Transcripts & AI Notetaking	12
5. Remote & Hybrid Work: Privacy Risks Outside the Office	14
6. Surveys, Polls, Quizzes & Competitions.....	16
7. Privacy Through the Talent Lifecycle	18
8. Handling Requests to Exercise Privacy Rights	20
9. Sensitive (Special-Category) Personal Data & Biometrics	22
10. Consent: When It's the Right Tool (and When It Isn't)	24
11. Secondary Use: Reusing Data for a New Purpose	26
12. Responding to External Requests for Data	28
13. AI, Analytics & Automated Decision-Making (Emerging Area)	30
14. Engaging with Data Protection Regulators	32
15. Website & Digital Product Privacy Compliance	34
16. Data Breach Response & Incident Reporting	36
17. Records Management, Retention & Secure Sharing	38
18. Marketing & Direct Communications Compliance	41
Part 1 self-test	43
Part 2. Practical AI Act Advice.....	46
1. Scope, Territorial Reach & Key Definitions	47
2. Prohibited AI Practices	49
3. High-Risk AI Systems: What Counts	51
4. Obligations for AI Providers	53
5. Obligations for AI Deployers.....	55
6. General-Purpose AI Models (GPAI)	57
7. Compliance & Conformity Assessment.....	59
8. Governance & Enforcement.....	61
9. Building an Enterprise AI Governance Program: 10 Foundations.....	64
10. Assessing AI Risk: Questions Worth Asking.....	66
11. Vetting AI Vendors: A Procurement Due-Diligence Framework	68
12. Building AI Literacy Across an Organization.....	69
13. Copyright & Generative AI	71
Part 2 self-test	75
Part 3. The Assessment Suite	79
Privacy Assessment.....	80
Full DPIA.....	87
Legitimate Interest Test.....	94
AI Risk Assessment	98
Incident & Breach Severity.....	101
Third-Party Security Assessment.....	110
Part 3 self-test	120
Part 4. The GDPR Readiness Model	123
The method	124
The 71 activities.....	126
Article index.....	134

Part 4 self-test	136
Appendix. Reference lists	138
Appendix A. Long option lists	139
Appendix B. Fifteen-minute review card	140
Appendix C. Sources	142

PART 1

Practical Privacy

Eighteen situations that recur inside every organisation,
and the decision rule for each.

Privacy programs live or die on the small, everyday decisions people make - whether to record a meeting, how long to keep a spreadsheet, who gets access to a shared mailbox. This reference distills practitioner-tested guidance on the situations that come up again and again inside a modern organization: surveillance and monitoring, offboarding, meetings, remote work, surveys, talent data, individual rights requests, sensitive data, consent, secondary use, external and regulatory requests, digital products, breach response, records management, and marketing.

None of this is legal advice, and none of it describes any single company's internal program - it is a genericized synthesis of practices that recur across privacy programs, intended as a practical starting point you can adapt to your own organization's tools, policies and legal environment. Wherever it says "your organization," substitute your own employer's approved systems, escalation paths and legal counsel.

SOURCES [1] [5] [16] [17] [18] [19]

1. Video Surveillance, Photography & Location Tracking

Why it matters: Cameras, photos, GPS trackers, and workplace monitoring tools all capture personal information, often about people who never agreed to be filmed or tracked. Because these methods are inherently intrusive, they are only justified when there's a clear, lawful business need paired with real transparency and safeguards - not just because the technology is available.

Key actions

- Treat any recording or tracking technology as a personal-data activity from day one - complete a privacy impact assessment before deployment.
- Understand and comply with local privacy and labor law before installing cameras, trackers, or monitoring software.
- Define narrowly what data is collected and why; get sign-off from your privacy and security functions where relevant.
- Notify people through signage, onboarding materials, or direct communication - a camera or tracker that nobody knows about is a red flag.
- Signage should name the controller, the purpose, the retention period, and how to exercise rights or get more information.
- Build in opt-out functionality wherever legally required, and apply firm retention and deletion schedules.
- For photos and event footage: explain the purpose and where images will be used, get general consent for group shots and explicit consent for anyone singled out as a focal subject, store only on approved platforms, and delete once the purpose is served.
- For location/GPS tracking: limit scope to work activity, disable tracking outside working hours where possible, and delete location data promptly.

Never

- Install hidden cameras without an exceptional, documented approval.
- Point cameras at bathrooms, locker rooms, private spaces, public streets, neighboring properties, or individual workstations.
- Share footage externally without privacy review, copy it to personal devices, or use facial recognition without a completed assessment and formal sign-off.
- Enable location tracking secretly, use it as a backdoor for disciplinary monitoring without a proper legal basis, or turn it on by default without purpose and notice.
- Reuse photos or video for a purpose different from what people were told, or edit media in misleading ways.

Worked example - delivery fleet GPS A logistics team wants to add GPS tracking to delivery vehicles for route optimization and driver safety. Good practice: tracking is scoped to working hours and disabled outside them, data is retained only as long as needed for operational purposes, and drivers are told clearly what's tracked and why. A companion event app that offers optional location sharing makes it strictly opt-in, user-controlled, and deletes the data once the event ends.

KEY TAKEAWAYS

- The trigger is the technology, not the intent: any camera, tracker or monitoring tool is a personal-data activity from day one and needs an assessment before it is switched on.
- Transparency is the test a regulator applies first. Signage has four elements: controller, purpose, retention, how to exercise rights.
- Scope beats consent here. Narrow the collection (working hours only, no workstations, no public streets) rather than trying to paper over a wide scope with notices.
- Photography splits two ways: general consent for group shots, explicit consent for anyone who is the focal subject.
- Facial recognition and hidden cameras are the two bright lines: neither without a completed assessment and formal, documented sign-off.

2. Offboarding: Protecting Data When Someone Leaves

Why it matters: The moment someone leaves an organization is a high-risk moment for data - for the departing person's own privacy, and for the company's information. Good offboarding protects both: personal content gets removed from company equipment, business records stay findable in the right place, and access closes cleanly.

Key actions

- Before your last day, delete personal photos, downloads, saved passwords, browser history, personal accounts, and any other personal files stored on company equipment - this protects your own privacy.
- Move business information into approved shared systems (document management, team collaboration, cloud storage) before access is removed, and complete handover with your manager and colleagues.
- Return laptops, phones, tablets, badges, and any role-specific equipment - this enables device sanitization and access closure.
- Leave business records where they are. Only personal content should be deleted; work records must remain available for legal, retention, and operational purposes. If you're unsure whether something is personal or business-related, ask your manager or IT.
- Once a device is returned and processed, expect a mandatory secure wipe - local data is then unrecoverable, while cloud-based information stays subject to normal retention and access rules.

Never

- Copy company files to personal devices or personal cloud services, or forward work emails to a personal account.
- Retain company documents after employment ends, or attempt to access company systems after termination.
- Store business documents only locally during your notice period unless the role specifically requires it.

If you're unsure: ask your manager, IT support, or your organization's privacy team before you delete or move anything.

KEY TAKEAWAYS

- Offboarding protects two different parties at once: the leaver's personal privacy, and the organisation's records.
- The rule is asymmetric: delete personal content, leave business records. Those pull in opposite directions, which is why people get it wrong.
- Move business information into approved shared systems before access closes, not after. After is too late.
- The classic failure is exfiltration framed as convenience: forwarding to personal email, copying to a personal drive, keeping documents 'for reference'.
- If you cannot tell whether something is personal or business, ask before you act on it.

3. Accessing Another Person's Mailbox

Why it matters: Reading someone else's mailbox is an exceptional measure, not a routine convenience. It should only happen when it's strictly necessary, no less-intrusive option exists, and proper governance is in place - because mailbox content is personal information and often contains far more than the business need requires.

When access may be appropriate

- An employee is on extended or unexpected leave and business-critical information is trapped in their inbox.
- Someone is unresponsive in a way that threatens business continuity.
- A legal or regulatory investigation requires it.
- An employee has departed without properly handing over information.

Every one of these situations still has to satisfy purpose limitation, fairness, and proportionality.

Key principles

- **Least privilege:** access only the minimum content needed - broad, unrestricted mailbox reviews are prohibited.
- **Authorized and logged:** access should go through identity and access management controls, with a formal request, documented approval, periodic review, and immediate removal once no longer needed.
- **Logging and monitoring:** every access should be logged (user, timestamp, IP address, read/update activity), and those logs must themselves be protected from tampering.
- **Privileged access is temporary:** any elevated access must be justified, time-boxed, and removed the moment it's no longer required - avoid permanent elevation.
- **Documentation:** keep records of the request, business justification, approvals, who accessed the mailbox, when, and what was reviewed or copied.
- Treat everything retrieved as sensitive company information: store only in approved systems, minimize duplication, and apply retention rules.
- People should normally be told their mailbox was accessed, unless notification would compromise an investigation, legal process, or create regulatory issues.

Never

- Request or share someone's password, use shared or generic accounts, or otherwise circumvent privileged-access controls.
- Copy an entire mailbox without approval, or retain retrieved information beyond the business purpose.
- Treat mailbox access as routine - every instance needs its own justification and approval chain (people manager, HR, privacy/legal review, IT/security).

Worked example - urgent customer handoff An account manager becomes unexpectedly unavailable and a customer needs urgent information sitting in their inbox. Good practice: document the justification, get privacy sign-off, restrict access to the specific relevant emails, grant temporary time-bound delegated access rather than full mailbox access, and keep a complete access record.

Worked example - misconduct investigation An employee is placed on leave and evidence may exist in their mailbox. Good practice: legal and HR are engaged, privacy reviews the scope, access is granted only to authorized investigators, irrelevant personal communic-

ations are excluded, every approval and access event is logged, and access is removed the moment the investigation concludes.

KEY TAKEAWAYS

- Mailbox access is exceptional, never routine. Every instance needs its own justification and its own approval chain.
- Four situations can justify it: extended or unexpected leave, unresponsiveness threatening continuity, a legal or regulatory investigation, a departure without handover. Each still has to satisfy purpose limitation, fairness and proportionality.
- The five governance controls are least privilege, formal authorisation, logging, time-boxed elevation, and documentation.
- Prefer temporary, delegated access to the specific messages over full mailbox access. Scope is the control that does the most work.
- Tell the person afterwards, unless notification would compromise an investigation or legal process.

4. Meetings: Recording, Transcripts & AI Notetaking

Why it matters: A single meeting can generate recordings, transcripts, captions, attendance reports, chat logs, polls, and AI-generated summaries and action items - any of which may contain personal information, confidential business content, or legal advice. Whoever organizes the meeting is responsible for how all of that gets handled through its lifecycle.

Key actions

- Ask, before enabling recording, transcription, or an AI notetaker: is this actually necessary? Would notes achieve the same goal? Who needs access to the output, and what risk does creating it introduce?
- Match the tool to the meeting: routine training, town halls, and workshops are usually fine to record; HR matters, investigations, and legal-advice discussions generally should not be, or need explicit privacy/legal/HR sign-off first.
- As the organizer, control the recording and sharing settings, review who has access, review retention, and review AI-generated outputs before they're relied upon.
- For sensitive meetings, prefer a standalone meeting invite over a channel-based one - channel meetings tend to inherit broader team permissions than the discussion warrants, so a standalone invite with a defined attendee list reduces exposure.
- Apply short, defined retention windows to recordings, transcripts, chat files, and AI-generated prompts and summaries rather than letting them accumulate indefinitely.
- Before the meeting, tell participants if recording, transcription, or AI summarization is enabled, why, who will see the output, and how long it will be kept.
- Set up the meeting deliberately: use a waiting room where appropriate, restrict who can present, review bypass settings, and keep external and internal discussions separate.

During the meeting

- Share a single window or application rather than your whole screen, and pause sharing before opening email or messages.
- Avoid displaying or reading aloud personal information that isn't necessary for the discussion.
- Treat chat messages, polls, whiteboards, transcripts, and AI outputs as records, not throwaway ephemera.
- Verify unexpected attendees before continuing sensitive discussion.

Always / Never for AI-generated outputs

- Always review AI-generated summaries and action items before treating them as accurate, validate decisions and actions, remove unnecessary personal data, and correct errors.
- Never assume an AI summary is complete, treat it as an official record without review, share it externally without approval, or paste meeting content into an unapproved AI tool. Only approved AI tools should touch company information.

For high-risk meetings (employee relations, grievances, investigations, incident response, health matters, legal advice, commercial negotiations): consider notes instead of a recording and minutes instead of a transcript, use a standalone meeting rather than a channel meeting, and enable a lobby/waiting room with restricted bypass.

KEY TAKEAWAYS

- One meeting can produce recordings, transcripts, captions, attendance reports, chat logs, polls and AI summaries. The organiser owns all of it.
- Ask the necessity question before enabling anything: would notes achieve the same goal?
- Match the tool to the meeting. Training and town halls are usually fine to record; HR matters, investigations and legal advice generally are not, or need sign-off first.
- For sensitive meetings, use a standalone invite rather than a channel meeting: channel meetings inherit permissions the discussion does not warrant.
- AI output is a draft. Review summaries and action items before they are relied on, and never paste meeting content into an unapproved tool.

5. Remote & Hybrid Work: Privacy Risks Outside the Office

Why it matters: Working from home, a café, or on the road moves personal data and sensitive business information into less controlled environments. The obligations don't change just because the location did - three lenses still apply: privacy principles (fairness, purpose limitation, minimization), security controls (device management, access, monitoring), and records hygiene (approved storage, retention, timely deletion).

Remote-working checklist

- Connect through trusted networks and an approved VPN.
- Use a company-managed device with encryption, anti-malware, and current updates enabled.
- Lock your device whenever you step away.
- Share links rather than files where possible, and restrict access to people with a genuine business need.
- Store information in approved systems of record, and clean up duplicate local copies.

Major risk areas and controls

RISK AREA	TYPICAL RISK	CORE CONTROLS
Networks	Public Wi-Fi or insecure home networks	Use an approved VPN and encrypted connections; avoid unknown VPNs or proxies
Devices	Loss, theft, or unpatched endpoints	Managed devices only, encryption and anti-malware on, prompt updates, never share accounts, report loss immediately
Information sharing	Uncontrolled sharing, duplicate copies	Follow classification rules, share links not files, avoid personal email/cloud storage/consumer messaging apps
Meetings & screen sharing	Unintended disclosure	Verify attendees, share application windows not full screens, disable pop-up notifications, record only with a legitimate reason
Physical environment	Screen and document visibility	Use privacy screens, angle displays away from others, secure paper documents, keep devices under your control
Printing & disposal	Paper bypasses retention controls	Avoid printing where possible, file information in approved systems, destroy paper securely, respect legal holds
Test/development data	Live personal data used outside production	Use anonymized or masked data, delete promptly after testing

Working while mobile: use trusted connectivity or a secure hotspot plus VPN, confirm recipients actually need what you're sharing, share restricted links rather than attachments, apply the right classification label, avoid unnecessary downloads, and upload anything temporary to an approved system before deleting the local copy.

Never

- Create personal workarounds when a requirement seems inconvenient - escalate and ask for a compliant solution instead. Formal exceptions need written justification, compensating controls, and appropriate governance approval.
- Keep information "just in case," or delete information subject to a legal or tax hold.
- Use personal email as a shortcut - it bypasses identity, access, and logging controls entirely.

Worked examples

- *Café deadline*: use a hotspot plus VPN, share a restricted link rather than a file, save the final version to an approved system, and delete the local copy.
- *Home printout of an HR document*: print only if necessary, keep it secured, upload it to an approved system, and shred it after use.
- *Lost laptop*: report immediately, begin containment, and expect a privacy risk assessment.
- *Screen-share slip*: share application windows only, verify who's actually in the meeting, and only record when there's a real need.

Report immediately: lost or stolen devices, misdirected emails, suspicious logins, malware, or any unauthorized access - through your organization's incident-reporting channel or confidential reporting route.

KEY TAKEAWAYS

- Location changes the environment, not the obligation. Three lenses still apply: privacy principles, security controls, records hygiene.
- The seven risk areas are networks, devices, information sharing, meetings and screen sharing, physical environment, printing and disposal, and test data.
- Share links, not files, and restrict to people with a genuine business need.
- Personal email is the single worst shortcut: it bypasses identity, access and logging controls in one move.
- Never build a personal workaround. Escalate and ask for a compliant path; formal exceptions need written justification, compensating controls and governance approval.

6. Surveys, Polls, Quizzes & Competitions

Why it matters: Surveys, quizzes, and competitions feel informal, but they routinely collect names, contact details, opinions, and sometimes sensitive information - and the same privacy, security, and retention requirements apply whether the audience is internal employees or the public.

Key actions

- Use only approved, vetted platforms and vendors - never a random consumer quiz app.
- Be transparent: tell participants why the activity is running, whether identities are collected, where data is stored, how long it's kept, who can access it, and whether participation is voluntary.
- Collect only what's genuinely needed - skip sensitive or unnecessary questions.
- Store responses securely and restrict access; avoid local storage, personal devices, or unapproved systems.
- Use the data only for the purpose participants were told, unless you get fresh notice/approval for anything new.
- Delete responses when the retention period ends, and make sure any vendor involved does the same.

Never

- Use consumer-grade quiz or survey tools for anything work-related.
- Repurpose survey or quiz results for monitoring or performance management without telling people first.
- Try to re-identify participants in an "anonymous" survey.
- Collect sensitive categories of information (health, religion, politics, other protected characteristics) in a pulse-check or feedback tool.

Customer competitions and promotions carry more risk. Always: use approved vendors, publish a clear privacy statement covering purpose, data collected, retention, deletion, and any transfers; get consent where required; explain the rules and how winners are notified; delete entries on schedule; and keep marketing use of entrant data separate from - and dependent on - a distinct, freely given consent. Never: use unapproved vendors, collect more than necessary, use entrant data for profiling or marketing without consent, or share it with partners without approval. Larger promotional activities may need a formal privacy impact assessment - build that into the planning timeline.

Worked example - anonymous employee survey No names, IDs, or IP addresses collected; responses reported only in aggregate; purpose, storage location, access list, and retention period all explained up front; participation voluntary. This works because there's nothing to re-identify, and every transparency box is checked.

Worked example - mandatory training quiz Completion is mandatory and results are tied to an employee ID - but that's disclosed clearly, storage is limited to the learning platform, access is restricted to compliance/learning teams, a retention period is defined, and results are explicitly not used for performance management. Identity is necessary here, so the focus shifts to purpose limitation and access control rather than anonymity.

KEY TAKEAWAYS

- Informality is the risk. A quiz feels casual; the data it collects is not, and the same platform, retention and transparency rules apply.
- Anonymous means unlinkable. If you can re-identify, it is not anonymous, and trying to re-identify is itself a breach of what you told people.
- Identity is sometimes necessary (a mandatory training quiz). When it is, the controls shift from anonymity to purpose limitation and access control.
- Never collect special categories in a pulse-check or feedback tool.
- Customer competitions carry more risk than internal surveys: approved vendor, published privacy statement, separate marketing consent, deletion on schedule, and a possible formal assessment in the planning timeline.

7. Privacy Through the Talent Lifecycle

Why it matters: From attracting candidates through onboarding, performance management, and eventual offboarding, people-data touches every stage of the employment relationship - and each stage carries its own minimization, access, and retention expectations.

Recruitment & candidates

- Do: collect only what's needed to assess suitability, tell candidates when background checks are part of the process, use approved vendors and processes, store CVs and interview notes only in approved HR systems, and keep interview questions tied to skills and role requirements.
- Don't: download CVs into personal folders, ask irrelevant questions about age, family, or health, search social media without a formally approved check, or use personal email/messaging apps for recruitment activity.

Onboarding

- Do: collect only what employment administration requires, store identity documents in approved systems, and restrict access to authorized administrators and HR.
- Don't: store passports, licenses, or bank details locally, or forward onboarding documents outside the organization.

Performance management

- Do: keep feedback factual and role-related, store reviews and development plans only in the approved HR system, and restrict access to authorized participants.
- Don't: include personal assumptions, keep screenshots or duplicate copies, or share performance information outside the authorized process.

Learning & development, talent reviews, succession planning

- Do: use approved learning platforms, follow meeting-recording guidance for recorded sessions, keep talent-review discussions confidential, and stick to factual information in approved templates.
- Don't: export talent data into personal spreadsheets, discuss readiness or potential informally, or move talent information across borders without approval.

Employee relations & sensitive cases

- Do: store information securely, restrict access to authorized personnel, follow the approved case-management process, and involve HR, legal, or privacy for complex matters.
- Don't: record meetings without justification and notice, share case details outside the authorized group, or keep local copies after the case closes.

Digital collaboration

- Do: use approved systems for storing and sharing people data, and think carefully about AI-generated meeting summaries before relying on them.
- Don't: upload employee information into external or unapproved AI tools, or reuse employee data for a new purpose without checking first.

Offboarding

- Do: remove access promptly, retain only what law or policy requires, and transfer employee documentation to HR.
- Don't: keep personal copies of employee files, access a former employee's information without authorization, or disclose it unless legally required.

KEY TAKEAWAYS

- People-data has a lifecycle of its own: recruitment, onboarding, performance, learning and talent, employee relations, collaboration, offboarding. Each stage has its own minimisation, access and retention expectation.
- The recurring failure across every stage is the same: data leaving the approved system into a personal folder, spreadsheet or mailbox.
- Recruitment questions stay tied to skills and role requirements. No age, family or health questions; no informal social-media checks.
- Performance records stay factual and role-related, in the approved HR system, visible only to authorised participants.
- Employee data must not go into external or unapproved AI tools, and must not be reused for a new purpose without a check.

8. Handling Requests to Exercise Privacy Rights

Why it matters: Anyone - an employee, former employee, candidate, customer, or supplier - can ask to access, correct, delete, or restrict their personal data, object to how it's used, or withdraw consent. These formal rights requests come with strict legal deadlines, so getting them to the right team fast matters more than trying to handle them yourself.

How to recognize one - it doesn't need legal language. Treat these as rights requests and escalate immediately:

- "Can I have a copy of my data?"
- "Delete my information."
- "Correct my information."
- "Stop using my information."
- "Who have you shared my information with?"
- "I withdraw my consent."
- "Please stop contacting me."

Usually NOT a rights request: updating a customer's account contact details, requesting a payslip, or changing a supplier's billing email - these are routine operational asks, even though they involve personal information.

What you should do

- Escalate immediately to your organization's privacy team through the approved channel.
- Do not investigate it yourself, verify identity independently, release information, or respond substantively - even a well-intentioned reply can undermine the formal process. If in doubt, escalate anyway.

What the privacy team typically does: verifies identity, confirms scope and request type, identifies affected systems, coordinates data collection, reviews information before release, tracks the legal deadline, and communicates with the requester. You may be asked to help locate or clarify data relevant to the request.

Typical statutory response windows (these vary by law and country - confirm current requirements locally):

- EU/GDPR-style regimes: one month, extendable by up to two additional months for complex cases, with the requester told about any extension within the first month.
- Australia: around 30 calendar days, with reasonable identity verification and possible access fees.
- New Zealand: 20 working days (about four weeks) under the Privacy Act 2020, extendable in limited cases with written notice inside that period; private sector agencies may charge a reasonable fee, public sector agencies may not.

Recent case law worth knowing: the Court of Justice held in *Brillen Rottler* (C-526/24, 2026) that even a first access request can be refused as abusive where the organization can show it was made for a purpose unrelated to data protection, so document the reasons whenever a refusal is considered; and in *EDPS v SRB* (C-413/23 P, September 2025) that pseudonymized data stays personal data in the hands of the organization that can still identify people, even if the recipient cannot, and that the duty to tell people who will receive their data is judged at the point of collection. The EDPB's one-stop-shop case digests on the right of access, objection and erasure collect how authorities have decided the recurring situations.

Roles typically involved: the requester (submits the request, provides ID, clarifies scope); HR (logs internal requests, supports ID verification, gathers HR-held information); the privacy team (end-to-end coordination, ID verification, tracking, final response); legal (exemptions, redaction, complex cases); and a security/e-discovery function (search and secure extraction of records).

Common scenarios: a former employee requesting access to their HR file, a candidate asking for erasure, an employee asking for a correction, a data-portability export, or someone objecting to marketing. Each follows a version of the same pattern - verify identity, confirm scope and retention obligations, take the appropriate action, and record the outcome.

KEY TAKEAWAYS

- A rights request does not have to use legal language. 'Delete my information' and 'stop contacting me' both count.
- Speed is the whole point: statutory clocks start on receipt, so route it to the privacy team immediately instead of handling it yourself.
- Routine operational asks are not rights requests: updating account contact details, requesting a payslip, changing a billing email.
- Do not verify identity, investigate, or respond substantively on your own. A well-meant reply can undermine the formal process.
- Typical windows: one month under GDPR-style regimes (extendable by two more for complex cases, with notice inside the first month); around 30 calendar days in Australia; 20 working days in New Zealand. Confirm locally.

9. Sensitive (Special-Category) Personal Data & Biometrics

Why it matters: Some categories of personal data create outsized harm if mishandled - racial or ethnic origin, political opinions, religious or philosophical beliefs, trade union membership, genetic data, biometric data processed to uniquely identify a person, health information, and sex life or sexual orientation. Most privacy laws single these out for extra protection, and organizations should never collect them casually.

When it may be collected or used - one of these has to genuinely apply:

1. There's a clear legal obligation (health and safety requirements, regulated workplace processes, specific reporting duties).
2. The individual has given explicit, informed, documented consent, understanding exactly what's collected, why, how it's used, and who sees it.
3. The purpose is necessary, defined, and proportionate - if the task can be done without this level of detail, don't collect it.

If none of these apply, don't collect or use it. Talk to your privacy team first.

Valid scenarios: an employee shares medical information to request a workplace accommodation; a visitor provides biometric data for secure-site access where local law permits it and privacy has approved it; health information is collected to manage a workplace incident where required.

Not valid: asking candidates about health or family plans; keeping informal notes about someone's background or beliefs; storing medical certificates in personal email or local files; rolling out a biometric or health-data tool without an assessment.

Always

- Loop in your privacy team before collecting or using sensitive data, and explain clearly why it's needed.
- Use only secure, approved systems, limit access as much as possible, and delete the information as soon as it's no longer needed.

Never

- Collect sensitive data without a valid purpose, store it in spreadsheets or personal email, forward it to people who don't need it, or use unapproved tools that capture biometric or health data.

Biometrics deserve their own scrutiny. Biometric data means information about physical or behavioral features used to identify or classify someone - facial images and facial recognition, fingerprints, voice patterns, keystroke patterns, gait analysis. A project likely involves biometrics if it scans a face, voice, or behavior, compares physical features against a stored record, or uses those features to make decisions about identity, access, attendance, or classification.

Some jurisdictions (New Zealand is a useful example) have dedicated biometrics codes and rules layered on top of general privacy law - for instance, requirements around necessity and proportionality, clear safeguards, advance transparency, restrictions on emotion-detection or inferring ethnicity/gender, extra care for children's data, and specific notification duties when biometric data is collected indirectly (from a source other than the individual). The specifics vary by jurisdiction, but the pattern is consistent: pause, assess, and get privacy sign-off before any biometric processing begins.

Before any biometric processing:

1. Stop and assess - pause the project until privacy confirms which rules apply.
2. Complete a formal privacy impact assessment - this is not optional for biometrics.
3. Be ready to show why biometrics are necessary and why nothing less intrusive would work, how people will be told, what safeguards apply, and how bias and accuracy risks are managed.
4. Don't sign a vendor contract or activate a system before privacy review is complete.

Never, without privacy review: trial or test a biometric tool, upload images or recordings of employees, contractors, or customers into an AI or cloud-based biometric system, use tools that infer emotion or other sensitive characteristics, or roll out facial recognition for attendance or access.

KEY TAKEAWAYS

- Special categories are racial or ethnic origin, political opinions, religious or philosophical beliefs, trade union membership, genetic data, biometric data processed to uniquely identify a person, health, and sex life or sexual orientation.
- One of three gates has to genuinely apply: a clear legal obligation, explicit informed documented consent, or a necessary, defined and proportionate purpose. If none applies, do not collect it.
- Biometric data means physical or behavioural features used to identify or classify: faces, fingerprints, voice, keystrokes, gait.
- A project involves biometrics if it scans a face, voice or behaviour, compares features to a stored record, or uses features to decide about identity, access, attendance or classification.
- Biometrics are never assessment-optional: stop, complete a formal assessment, show why nothing less intrusive works, and do not sign a vendor contract before privacy review completes.

10. Consent: When It's the Right Tool (and When It Isn't)

Why it matters: Consent is the most misunderstood legal basis in privacy. It's often reached for by default, but it only works when people have a real, free choice - and many everyday business activities (payroll, security checks, performance management, access control) don't offer that choice, so consent is the wrong tool for them.

When consent is not the right basis: for anything people can't realistically refuse without a negative work consequence - payroll, IT security, safety checks, performance management, access control, or mandatory compliance activities. These rely on other lawful bases (contract, legal obligation, legitimate business need) paired with clear notice, not a tick-box.

Valid consent must be:

1. **Informed** - the person understands what's collected, why, for how long, and who it's shared with.
2. **Voluntary** - given freely, with no pressure or penalty for refusing.
3. **Specific and current** - tied to a clearly defined purpose, and not assumed to survive a change in context.
4. **Given by someone with capacity** - able to understand and communicate the decision (with extra care for minors, vulnerable individuals, or language/comprehension barriers).

Before adding a consent checkbox, ask: Is this actually optional? Can people say no without any negative impact? Is there a better basis (contract, legal obligation, safety, legitimate need)? Will people actually understand what they're agreeing to? Can withdrawal be tracked and honored? If the answer to any of these is no, consent probably isn't the right choice.

Do

- Use express consent (a signature, a verbal recording, a ticked box) for sensitive data or higher-risk activities.
- Keep each purpose separate - never bundle unrelated processing into one all-or-nothing request.
- Make withdrawal as easy as giving consent in the first place, and honor it promptly.
- Keep records of consent and withdrawal in line with your retention rules.

Don't

- Rely on silence, pre-ticked boxes, or inaction as consent.
- Use implied consent for sensitive data or high-risk uses - where there's any doubt, use express consent instead.
- Assume old consent still applies once the purpose, scope, or context has materially changed.
- Treat a privacy notice as consent - a notice informs; consent grants permission. They are not interchangeable.

Where consent works well: optional event photography, opt-in newsletters, voluntary wellbeing programs, and using someone's story or quote with their permission - situations where saying no genuinely carries no downside.

Marketing-specific note: consent (not implied browsing behavior) should back any optional communications, profiling, or non-essential cookie tracking; operational messages like safety notices or delivery confirmations generally rely on a different basis.

Further reading: EDPB Guidelines 03/2022 on deceptive design patterns in social media interfaces catalog the patterns that invalidate consent (overloading, skipping, stirring, obstructing, fickle, left in the dark) with examples; they are the reference authorities use when they judge whether a choice was really free.

KEY TAKEAWAYS

- Consent only works where refusal is genuinely free of consequence. Payroll, security, safety checks, performance management and access control do not meet that test.
- Valid consent has four properties: informed, voluntary, specific and current, and given by someone with capacity.
- A privacy notice is not consent. A notice informs; consent grants permission.
- Never rely on silence, pre-ticked boxes or inaction, and never bundle unrelated purposes into one request.
- Withdrawal must be as easy as giving it, and honoured promptly. If you cannot track withdrawal, you cannot use consent.

11. Secondary Use: Reusing Data for a New Purpose

Why it matters: Data collected for one purpose can't just be reused for another because it happens to be available. Every proposed new use needs its own check for lawfulness, transparency, and proportionality - reusing CCTV footage for an unrelated investigation, or repurposing delivery data for marketing analysis, are both examples of "secondary use" that need fresh scrutiny.

Core principles

1. **Confirm the original purpose first.** If a proposed new use doesn't clearly fit what people were originally told, treat it as secondary use - even a small shift in purpose counts.
2. **Don't assume existing consent or notices cover a new purpose.** A new use may need an updated notice, new consent, a new legal basis, a fresh privacy assessment, or added safeguards.
3. **Be transparent when purpose, processing, or audience changes** - update privacy notices, system descriptions, or communications as needed.
4. **Never let a secondary use cause harm, create bias or discrimination, or happen just because the data exists.**
5. **Document the decision:** business justification, compatibility assessment, legal basis, consent status, privacy-review outcome, and final approval.

Escalate immediately when: the purpose differs materially, sensitive or children's data is involved, an automated decision could affect someone, a new vendor or third party is involved, data will cross borders, anonymization isn't possible, or data is being requested for a use that hasn't been assessed.

Common scenarios

- *Marketing/advertising:* using purchase history for targeted campaigns - assess compatibility, get consent where required, prefer pseudonymized data, and maintain suppression lists; never target sensitive categories or market to people who've opted out.
- *Analytics & AI:* training a model on internal data - prefer anonymized or pseudonymized datasets, complete a privacy assessment, test for bias, and maintain governance; never train on identifiable data without approval.
- *Product development:* using customer insights for new products - use aggregated or anonymized data, assess compatibility, update notices, and limit retention; never combine datasets in a way that could re-identify people without assessment.
- *New vendor processing:* bringing on a new analytics vendor - engage privacy, confirm the legal basis, put a data processing agreement in place, complete security due diligence, and confirm safeguards for any cross-border transfer.

KEY TAKEAWAYS

- Availability is not a justification. Data collected for one purpose cannot be reused for another just because it is there.
- Confirm the original purpose first. If the new use does not clearly fit what people were told, it is secondary use, even if the shift is small.
- A new purpose may need a new notice, new consent, a new lawful basis, a fresh assessment, or added safeguards. Do not assume the old ones stretch.
- Seven escalation triggers: material purpose change, sensitive or children's data, an automated decision affecting someone, a new vendor, a cross-border move, anonymisation not possible, or an unassessed use.
- Document the decision: business justification, compatibility assessment, lawful basis, consent status, review outcome, approval.

12. Responding to External Requests for Data

Why it matters: Law enforcement, regulators, courts, insurers, and other outside parties occasionally ask for information - CCTV footage, personal data, access logs, visitor records, incident reports. These are different from individual rights requests, and the core rule is the same every time: never hand data over directly.

Core rule: if an external party asks for data, don't provide it and don't release it - escalate to your privacy and legal teams, who will determine whether disclosure is lawful, verify legal authority, minimize what's shared, confirm a secure transfer method, and maintain a full record of the disclosure.

Escalate for review whenever: personal data is involved (images, names, IDs, logs, audio, biometric data); the request is voluntary rather than backed by a court order or statutory notice; information would cross a border; the scope is broad or unclear ("all footage," "all logs"); or the request touches something especially sensitive (audio, staff facilities, high-risk areas).

What to gather before escalating: requester name, organization, and official contact details (badge/registration number for law enforcement); the type of request; the legal basis (court order, subpoena, warrant, regulatory notice); the precise scope (dates, times, location, camera or system identifiers); the data type requested; and any transfer requirements.

When disclosure may proceed: the request serves the same or a directly related purpose (a security or safety investigation), it's required or authorized by law, or the individual has actually consented. Minimize wherever possible - a specific camera, a specific timeframe, a specific incident, never a blanket handover.

Always

- Use secure transfer methods, restrict recipients, apply password protection and link expiration, minimize what's shared, and document the disclosure.
- Get external recipients to agree to use the information only for the approved purpose, avoid forwarding it, store it securely, delete it after use, and confirm deletion.

Never

- Send footage or data as an ordinary email attachment, share more than necessary, or release anything independently without review.

Orders and requests from outside the EU: under EDPB Guidelines 02/2024 on Article 48 GDPR (final version June 2025), a judgment or decision of a court or authority in a non-EU country is not by itself a lawful basis for disclosing personal data, nor a ground for transferring it: it can only be acted on where an international agreement such as a mutual legal assistance treaty applies, and the organization still needs a GDPR legal basis and a Chapter V transfer tool. Route any foreign subpoena, warrant or regulator request straight to legal. On transfers to the United States, the EU-US Data Privacy Framework remains valid: the General Court dismissed the *Latombe* challenge on 3 September 2025 and the appeal to the Court of Justice is pending.

Emergency disclosures (rare): serious threat to life, medical emergency, missing person, natural disaster, or a court order can justify disclosure without consent - but even then, verify identity, share only what's necessary to manage the emergency, minimize (confirm presence or approximate location before anything broader), document everything (legal basis, requester, data disclosed, date, time, approver), and notify your privacy team immediately afterward. A request from a family member or friend, or from a third-party partner like a

hotel or airline, should not lead to direct disclosure - refer it to emergency services or verified authorities instead.

KEY TAKEAWAYS

- The core rule has no exceptions in normal conditions: never hand data to an external requester directly. Escalate to privacy and legal.
- External requests are not rights requests. Different process, different risk, different approver.
- Gather the facts before escalating: requester identity and official contact details, request type, legal basis, precise scope, data type, transfer requirements.
- Minimise every disclosure to a specific camera, timeframe or incident. Never a blanket handover, never an ordinary email attachment.
- Emergencies (threat to life, medical emergency, missing person, disaster, court order) can justify disclosure, but still require verification, minimisation, documentation and immediate notification to privacy afterwards. Family members and commercial third parties get referred to authorities, not answered.

13. AI, Analytics & Automated Decision-Making (Emerging Area)

Why it matters: AI-driven analytics and automated decision-making are moving fast, and formal guidance in this space tends to evolve quickly as tools and regulation mature. The underlying principles, though, are stable and worth applying even while detailed policy catches up.

Key actions

- Keep a human in the loop for any decision that meaningfully affects a person - treat AI outputs as a draft or input, not a final answer.
- Verify AI-generated outputs for accuracy before relying on them, especially facts, numbers, and anything used in a decision about a person.
- Use only approved AI tools for company or personal data - never paste confidential, personal, or sensitive information into a public or unapproved AI tool.
- Assess new AI-driven personalization, profiling, or automated-decision features for fairness and bias before launch, the same way you would any new data use.
- When in doubt about whether a specific automated process needs a privacy assessment, ask early rather than after launch.

The reference documents (September 2026): EDPB Opinion 28/2024 on AI models sets out how authorities decide whether a model trained on personal data is anonymous, when legitimate interests can support training and deployment, and what an unlawfully trained model means for the organizations that later deploy it; the EDPB's harmonized DPIA template (14 April 2026) is the format to use for the assessment; Guidelines 02/2026 on anonymization and 03/2026 on web scraping for generative AI (both in consultation until 30 October 2026) set the expectations for training data; and the report of the EDPB ChatGPT taskforce (May 2024) records the common position of the authorities on large language model services. On automated decisions, the Court of Justice held in *Dun & Bradstreet Austria* (C-203/22, February 2025) that a person subject to automated credit scoring is entitled to an explanation of the procedure and principles actually applied, in terms they can understand, and that a trade secret does not justify a blanket refusal. In Australia, from 10 December 2026 privacy policies must describe automated decisions that significantly affect people, and the Children's Online Privacy Code applies from the same date; a second tranche of Privacy Act reform was published as an exposure draft in August 2026.

Because this is an area where formal guidance shifts often, always check your organization's current AI/data-and-analytics policy for the latest specific requirements rather than relying solely on general principles.

KEY TAKEAWAYS

- The tooling changes quickly; the principles do not. Check the current internal AI policy rather than relying on general principle alone.
- Keep a human in the loop for any decision that meaningfully affects a person, and treat AI output as a draft rather than an answer.
- Verify facts, numbers and anything feeding a decision about a person before relying on it.
- Only approved tools touch company or personal data. Never paste confidential, personal or sensitive information into a public tool.
- Assess new personalisation, profiling or automated-decision features for fairness and bias before launch, not after.

14. Engaging with Data Protection Regulators

Why it matters: Regulators can investigate complaints, run inspections, and enforce privacy law - and how an organization responds in the first few minutes of contact matters. The core rule is simple: individuals should never engage with a regulator independently; every contact gets routed to the privacy and legal teams immediately.

Core rule - never engage independently. If a regulator calls, emails, writes, or shows up on-site, don't respond on your own. This applies just as much when a customer threatens to escalate to a regulator, or a supplier or partner signals regulator involvement.

Always involve your privacy team when: a regulator makes contact; inspectors arrive on-site; an authority requests information involving personal data; a complaint might escalate to a regulator; a privacy incident (or near miss) occurs; or a third party threatens regulatory action.

External communications discipline: don't send anything externally without approval - emails to regulators, government responses, incident reports, data extracts, screenshots, logs, or investigation notes all need review first.

If a regulator shows up unannounced:

- Reception/first contact: stay calm and professional, notify local leadership immediately, avoid handing over documents or granting access before authorized staff arrive.
- Local leadership: attend promptly, contact the privacy team immediately, wait for guidance before any substantive engagement.
- Privacy team: guides the inspection, confirms what can be disclosed, coordinates with legal and security, and records everything requested and disclosed.
- Everyone else: refer the regulator to the right lead; avoid explaining internal processes or discussing data handling unless specifically instructed to.

Two dates for the calendar: in the United Kingdom the core data protection provisions of the Data (Use and Access) Act 2025 came into force on 5 February 2026, and on 30 September 2026 the ICO becomes the Information Commission, a board-led body; the name on the letterhead changes, the process above does not. In the EU, Regulation (EU) 2025/2518 on procedures for cross-border GDPR enforcement applies from 2 April 2027, with fixed timelines and a right for the parties to be heard, so cross-border complaints should become more predictable and often faster.

Example scenario - unannounced inspection: representatives from a data protection authority arrive at an office unexpectedly. Reception notifies leadership; leadership engages politely and calls the privacy team immediately; privacy coordinates with legal and security; every request and disclosure gets documented; information is released only after appropriate review. The result: a consistent, legal, and transparent response instead of an improvised one.

KEY TAKEAWAYS

- Nobody engages a regulator independently. Every contact routes to privacy and legal immediately.
- The rule extends to threatened contact: a customer threatening escalation, or a supplier signalling regulator involvement, both trigger it.
- Nothing goes out externally without approval: emails, incident reports, data extracts, screenshots, logs, investigation notes.
- For an unannounced inspection there are four roles: reception notifies leadership, leadership attends and calls privacy, privacy guides and records, everyone else refers and says nothing about internal process.
- Politeness is not cooperation with the substance. Stay professional, hand over nothing before authorised staff arrive.

15. Website & Digital Product Privacy Compliance

Why it matters: Public-facing websites, microsites, portals, and mobile experiences all collect personal data - and just because something is technically possible on the web doesn't mean it's legally permitted. Privacy has to be considered before launch, not bolted on afterward.

When a formal review is required - raise it whenever you're:

- Launching something new (a website, microsite, portal, or campaign site).
- Adding new functionality (forms, cookies, pixels, tracking or analytics technologies).
- Changing the underlying technology (hosting provider, vendor, platform migration).
- Changing what's processed (new data categories, new markets, new AI capabilities, new automation).
- Using production/live personal data in testing, pilots, or pre-production environments.

A digital asset shouldn't launch or be materially modified without that review being complete - it should cover privacy, legal, procurement, technology, and security sign-off.

What the review should confirm: the correct lawful basis and consent mechanism; accurate, accessible, current privacy notices; defined retention and rights-handling processes; appropriate vendor contracts (processor obligations, transfer mechanisms, audit rights, deletion obligations, subprocessor terms); and secure hosting, access controls, encryption, and logging.

What may change: the European Commission's Digital Omnibus proposal of November 2025 would move the cookie and terminal-equipment rules into the GDPR as new Articles 88a and 88b, widen the exemptions from consent (security, audience measurement and service delivery among them) and require browsers and operating systems to carry machine-readable consent signals; it would also raise the threshold for keeping records of processing and adjust breach notification. As of September 2026 it is a proposal under negotiation with no Council or Parliament position, so nothing on this page changes yet: the ePrivacy rules, the 72-hour breach window and the current Article 30 threshold all apply as they stand.

Further reading: the EDPB Cookie Banner Taskforce report (January 2023) lists the banner designs that authorities agreed are non-compliant (no reject button on the first layer, pre-ticked boxes, deceptive colors and contrasts, misleading "legitimate interest" toggles); Guidelines 03/2022 on deceptive design patterns cover the same ground for interfaces generally; Recommendations 02/2021 set out when card data may be stored after a purchase; and the EDPB has warned against forcing users to create an account where a guest option would do.

Common red flags and fixes

RED FLAG	FIX
Analytics or tracking pixels firing before consent	Disable the tags, fix consent settings, retest
Outdated privacy notice	Update and republish
Excessive form fields	Remove unnecessary fields, update the notice
Undisclosed scripts	Remove, reassess, update the tracking inventory
Unapproved hosting location	Pause launch, assess cross-border transfer implications

RED FLAG	FIX
No deletion evidence from a vendor	Get written confirmation
Access left active for a former team member	Remove access, review logs
New behavioral tracking or AI introduced without review	Route back through the review process

Employee quick checklist

- Must do: get the required review, use approved vendors, use the correct privacy and cookie notices, block non-essential cookies before consent, minimize data collection, use HTTPS and MFA, restrict access, and define deletion arrangements.
- Must not: add undeclared tracking pixels or scripts, relaunch an old site without review, reuse an outdated notice, or retain data indefinitely.

Worked example - seasonal marketing microsite A marketing team plans a standalone campaign site that collects emails and competition entries and uses tracking pixels for analytics. Required controls: privacy involvement from the start, a cookie-consent banner, a campaign-specific privacy notice, data minimization in the entry form, and a defined retention schedule for entries once the campaign ends.

KEY TAKEAWAYS

- Technically possible is not legally permitted. Privacy comes before launch, not after.
- Five triggers for formal review: a new digital asset, new functionality, a technology change, a change in what is processed, or live personal data used in testing.
- The review confirms five things: lawful basis and consent mechanism, accurate current notices, retention and rights handling, vendor contract terms, and secure hosting with access control, encryption and logging.
- The most common failure is tags firing before consent. Disable, fix the consent configuration, retest.
- Relaunching an old site, or reusing an outdated notice, counts as a new launch for review purposes.

16. Data Breach Response & Incident Reporting

Why it matters: If you suspect a privacy or security incident - a misdirected email, unauthorized access, a lost device, malware, improper disposal of records - report it immediately. Speed matters more than certainty: the GDPR gives an organization 72 hours from becoming aware of a reportable breach to notify the supervisory authority, and the sector regimes are tighter still: NIS2 requires an early warning within 24 hours of a significant incident and DORA an initial notification within 4 hours of classifying a major ICT incident. Every hour spent deciding whether to report eats into those windows, and delay directly increases legal, financial, and reputational risk.

Key principle: you don't need to be certain. If something looks unusual or wrong, report it. Don't investigate alone, and don't wait until you have all the facts - early reporting is always preferred, and "when in doubt, report" is the operating rule.

How to report: through your organization's incident-reporting channel (portal, dedicated form, or direct email to your privacy/security team) - whichever your organization has published as the approved route.

Common incident types

- Email errors: sent to the wrong recipient, a "reply all" disclosure, misdirected customer or payroll data.
- System access issues: unauthorized HR or finance access, shared credentials, a former employee's account still active.
- Physical security: unattended printed documents, lost laptops, phones, or USB devices.
- Cyber threats: phishing, malware, ransomware, suspicious links.
- Improper disposal: confidential documents in general waste, hardware disposed of without wiping.

Incident lifecycle

1. **Intake** - the incident is reported (e.g., a spreadsheet sent to the wrong recipient); immediate reporting is required.
2. **Investigation** - what happened, what data and systems were involved, who was affected; containment (email recall, access removal, patching) can start immediately.
3. **Assess & decide** - severity, harm, and whether regulatory or individual notification thresholds are met.
4. **Notify** - regulators and/or affected individuals are notified where required, and post-incident improvements are considered.

Always: be alert, report immediately through the approved channel, respond to follow-up questions, and preserve evidence. **Never:** delay reporting, try to handle an incident independently, or wait until every fact is confirmed before raising it.

KEY TAKEAWAYS

- Speed beats certainty. Report on suspicion; do not wait for facts, and do not investigate alone.
- Regulator notification windows are commonly measured in hours from the moment the organisation becomes aware, so every hour of internal delay is spent from the legal budget.
- Five common incident types: email errors, system access issues, physical security, cyber threats, improper disposal.
- The lifecycle is intake, investigation and containment, assess and decide, notify. Containment can start before the assessment finishes.
- Preserve evidence, answer follow-up questions, and never handle an incident independently.

17. Records Management, Retention & Secure Sharing

Why it matters: Good record-keeping isn't just a compliance checkbox - it's how an organization protects its people and its business from information that's misused, lost, or seen by the wrong people. Every piece of information moves through a lifecycle (create, store, use, share, retain/archive, delete), and risk grows whenever data is overshared, kept too long, or stored in the wrong place.

A simple storage model

LOCATION TYPE	PURPOSE	APPROPRIATE USE
Personal working space	Individual drafts, work in progress	Not for long-term or team records
Active collaboration space	Live team projects, shared editing	Keep access limited and review it regularly
Structured organizational storage	Final, managed, long-term records	Records that must stay findable and retained

Through the lifecycle

- **Create:** collect or record only what's genuinely required; avoid "just in case" data; use existing systems of record rather than spinning up new copies; name files clearly; remember informal notes and emails can become records.
- **Store:** be intentional about which storage tier something belongs in; apply sensitivity labels to control access, and retention labels so records are kept and deleted correctly.
- **Use:** access only what your role needs; move meaningful content out of ephemeral chat channels and into governed locations - chat history that auto-deletes is not a substitute for a proper record.
- **Share:** share links instead of attachments; default to naming specific people rather than broad groups; check access before sending, especially for folders; explain security or retention expectations when sharing externally.
- **Retain & archive:** follow approved retention schedules; keep information only as long as legally or operationally required; move inactive records to designated archives; make sure backups don't quietly extend retention beyond the approved period; apply legal holds only when formally instructed.
- **Delete:** delete records once retention requirements are met, through the proper deletion process; shred paper and securely erase electronic files; confirm no legal, tax, audit, or regulatory hold applies first.

Classification labels - a simple four-tier model works well for most organizations:

LABEL	MEANING	EXAMPLES
Public	Approved for public release	Published marketing material, public reports
Internal	Routine internal material, no personal or confidential data	Internal updates, templates without personal data
Confidential	Personal data or commercially sensitive information	Names, emails, phone numbers, IDs, contracts, pricing

LABEL	MEANING	EXAMPLES
Highly confidential	Sensitive personal data or high-risk operational information	Health data, payroll, identity documents, investigations

When in doubt, choose the more restrictive label and ask.

Preventing accidental sharing of personal information

- *Check the file first:* look for hidden tabs, rows, or calculations; filters that hide rather than remove data; pivot caches with extra detail; comments, tracked changes, and old versions; embedded formulas, links, or objects. Use built-in document-inspection tools before sending anything out.
- *Share the minimum necessary:* ask what outcome the recipient actually needs; prefer aggregated, masked, or anonymized data; replace names with roles or functions where individual-level detail isn't needed; avoid exporting complete datasets.
- *Validate recipients:* confirm a genuine business need, confirm distribution-list ownership and current membership, and don't rely on autocomplete as your only recipient check.
- *Use secure methods:* prefer links over attachments, apply the correct sensitivity label, respect data-loss-prevention warnings, use time-limited and view-only external links, and disable downloads when not required.
- *Clean up afterward:* remove personal-level data from working copies once you're done with them, delete temporary files, and apply the correct retention label to the final record - but never purge anything that may be under a legal or audit hold.
- *If something is shared by mistake:* contact recipients and ask them to delete all copies, pause further sharing, tell your manager, report it to your privacy team immediately, and record who received it, when, what fields were included, and what containment steps were taken. Don't create new copies or request unnecessary screenshots containing the personal data in the process.

Using AI assistants (e.g., Copilot-style tools) responsibly

- Be clear about the task, tone, and output format you want, and work step by step.
- Review and verify outputs - especially facts, numbers, and assumptions - before relying on them.
- Never paste highly sensitive or restricted personal data into an AI assistant.
- Use only your organization's approved, sanctioned environment for it.
- Maintain human judgment and accountability throughout - don't use an AI assistant as a data repository, and clean up duplicate AI-generated content when retention rules allow.

Everyday security habits

- Change passwords when prompted (and sooner if you suspect compromise); never reuse the same password across services; never store passwords in notebooks, screenshots, or email drafts.
- Approve multi-factor authentication prompts only when you triggered them yourself - decline and report anything unexpected.
- Keep devices and key applications updated; avoid unapproved browser extensions; periodically review who has access to your documents and team spaces, especially external guests.
- Don't link personal email, cloud storage, or messaging accounts to a work device, and don't send work files through personal channels.

- Lock your device whenever you step away; don't leave printed personal data unattended; shred paper containing personal data.

Manager checklist

- Reinforce minimum-necessary sharing and avoid emailing large datasets; make sure staff can spot and remove hidden content in files.
- Review report recipients and distribution lists regularly, and prefer aggregated or pseudonymized data by default.
- Review team access, permissions, and file locations at least quarterly; remove departed team members and unnecessary access; prefer group-based over individual direct permissions.
- Make sure incidents and near-misses get reported immediately, and periodically review whether there's a safer way to handle recurring reporting needs.

KEY TAKEAWAYS

- Risk grows in three specific ways: oversharing, keeping too long, storing in the wrong place. The lifecycle is create, store, use, share, retain and archive, delete.
- Three storage tiers do most of the work: personal working space for drafts, collaboration space for live team work, structured storage for final managed records.
- Four classification labels: public, internal, confidential, highly confidential. When in doubt, choose the more restrictive one and ask.
- The hidden-content check is the practical skill: hidden tabs and rows, filters that hide rather than remove, pivot caches, comments and tracked changes, embedded formulas and links. Inspect before sending.
- Backups quietly extend retention past the approved period, and auto-deleting chat history is not a record. Both are places the retention schedule silently fails.
- Never purge anything that may be under legal, tax, audit or regulatory hold, even when the retention rule says delete.

18. Marketing & Direct Communications Compliance

Why it matters: Marketing uses personal information - emails, phone numbers, device and cookie identifiers, behavioral profiles - and is one of the most heavily regulated areas of data use. It carries meaningfully higher regulatory risk than routine operational customer communication, and regulators actively enforce against violations.

What counts as marketing: any communication whose primary purpose is to promote products or services, increase sales or engagement, or drive sign-ups - promotional emails, SMS campaigns, push notifications, newsletters, loyalty programs, competitions, product recommendations, cross-selling, event invitations, and behaviorally targeted advertising. It's still marketing even when sent to existing customers, and adding a promotional link to an otherwise operational message can convert the whole thing into marketing.

Core requirements

- **Consent:** valid opt-in consent before sending marketing, recorded with a timestamp, the exact wording shown, the channel, and the source - and consent should be channel-specific (email consent doesn't cover SMS).
- **The soft opt-in (EU and UK):** the one exception to prior consent for email and SMS. Under Article 13(2) of the ePrivacy Directive (regulation 22 of PECR in the UK) an organization may market its own similar products or services to existing customers whose address it obtained in the course of a sale, provided they were offered a free and easy way to refuse when the address was collected and in every message since. The Court of Justice confirmed in C-654/23 (13 November 2025) that a free account created in exchange for an email address counts as a "sale" for this purpose, and that a mailing that meets these conditions needs no separate consent under the GDPR. Anything outside those conditions is back to opt-in.
- **Transparency:** people should understand who's collecting their data, why, how it's used, and how to unsubscribe.
- **Unsubscribe:** every marketing message needs a genuinely working, easy opt-out, processed promptly (some jurisdictions set a hard deadline - Australia, for example, requires processing within five business days).
- **Truthful classification:** never mislabel marketing as a service communication, or hide promotional content inside an operational message - this is one of the most commonly enforced violations.
- **Data security:** marketing data should be securely stored, appropriately protected, and only shared with approved vendors under proper transfer mechanisms.

Before launching any campaign, confirm: clear opt-in exists, the data source is lawful, the unsubscribe mechanism actually works, the vendor is approved, data collected is minimized, targeting isn't inappropriate, and any required privacy review is complete. If any of these isn't satisfied, don't launch.

Profiling and personalization: before using segmentation, behavioral analytics, audience modeling, or lookalike audiences, confirm the privacy notice actually covers it, apply data-minimization principles, and avoid any sensitive-category profiling (health- or ethnicity-based inferences, for example).

Marketing to children needs enhanced controls: never knowingly target, profile, or track children's behavior without review, and always involve privacy and legal before any campaign involving minors. EDPB Statement 1/2025 on age assurance sets the principles for

checking age without over-collecting (proportionate methods, no tracking of the child through the check itself), and Guidelines 08/2020 on targeting social media users explain when the platform and the advertiser are joint controllers for a targeted campaign and what each must do.

Using third-party/broker data: confirm it was lawfully collected and that individuals were informed (no scraping or deceptive collection); don't repurpose it for profiling or matching without review; make sure people are told when data comes from an indirect source; and put contractual controls in place (processing restrictions, security, audit rights, offshore-processing terms) before use.

What must never happen

1. Mixing promotional content (discounts, product links) into service communications like delivery notices or order confirmations.
2. Sending marketing without a functional, free unsubscribe mechanism.
3. Assuming a message isn't "marketing" just because it's automated, triggered, or framed as a renewal or alert - any promotional content makes it marketing.
4. Assuming a vendor will handle compliance for you - the sending organization remains accountable for template review, governance, and approvals.

A real-world cautionary example: on 11 March 2026 the Australian Communications and Media Authority fined the retailer Lululemon AUD 702,900 for sending more than 370,000 emails without a working unsubscribe mechanism - the messages contained promotional content but were treated as service communications. The lesson holds everywhere: keep service and marketing communications completely, structurally separate.

Marketing golden rules: get valid consent first and keep evidence of it; use only approved vendors; always include a working unsubscribe; never hide marketing inside a service message; minimize personal data collected; protect customer information; involve privacy for profiling, children's data, broker data, or unusual campaigns; keep it transparent; and if you're not sure, ask your privacy team before launching.

KEY TAKEAWAYS

- Marketing is defined by primary purpose, not by channel or by whether the recipient is already a customer. Adding a promotional link to an operational message converts the whole message.
- Consent for marketing is channel-specific: email consent does not cover SMS. Record the timestamp, the exact wording shown, the channel and the source.
- Every marketing message needs a working, free, promptly processed unsubscribe. Australia sets a five business day deadline as an example of a hard one.
- Mislabelling marketing as a service communication is one of the most commonly enforced violations, and the cautionary example is a roughly AUD 700,000 fine for 370,000+ emails with no working unsubscribe.
- Profiling, children's data and third-party broker data are the three areas that always need privacy involvement before launch.
- The vendor does not carry your compliance. The sending organisation stays accountable for templates, governance and approvals.

Part 1 self-test

Cover the answers. Say or write your answer in full before you check it: recall you have to construct is worth several times a line you merely recognise. Answers begin on the next page.

1. A team wants to install cameras covering the staff car park and the row of desks nearest the entrance. Which part of that is a problem, and why?
2. Name the four things signage must tell people.
3. A leaver deletes their personal photos and also deletes three years of project emails. What did they get wrong?
4. An account manager is unreachable and a customer needs a document in their inbox. What is the correct shape of the response?
5. Why prefer a standalone meeting invite over a channel meeting for a sensitive discussion?
6. Which three lenses apply to remote work?
7. An employee survey collects no names but does record IP addresses and department for a team of four. Is it anonymous?
8. Which of these is not a rights request: 'send me a copy of my data', 'change my billing email', 'stop contacting me', 'who did you share my data with'?
9. What is the GDPR-style response window, and what is the condition on extending it?
10. List the three gates, any one of which can permit special-category processing.
11. What makes a project a biometrics project?
12. Give two everyday activities where consent is the wrong lawful basis, and say why.
13. What is the difference between a privacy notice and consent?
14. A logistics team wants to reuse delivery data for a marketing model. Name three things this triggers.
15. A police officer calls and asks for CCTV footage of an incident. What do you do?
16. What is the minimum you must do before relying on an AI-generated meeting summary or analysis?
17. Five triggers require a formal review of a website or digital product. Name three.
18. Why is 'I will report it once I have checked what happened' the wrong instinct after a suspected breach?
19. Name three places where a retention schedule silently fails.
20. A renewal reminder email includes a 20% discount code for a different product. What has it become, and what does it now need?

Part 1 self-test: answers

1. A team wants to install cameras covering the staff car park and the row of desks nearest the entrance. Which part of that is a problem, and why?
The desks. Pointing cameras at individual workstations is on the never list, because continuous monitoring of identified people at work is disproportionate to almost any stated purpose. The car park can be justified with a narrow purpose, signage naming controller, purpose, retention and rights, and a completed assessment.
2. Name the four things signage must tell people.
Who the controller is, the purpose, the retention period, and how to exercise rights or get more information.
3. A leaver deletes their personal photos and also deletes three years of project emails. What did they get wrong?
The project emails. Offboarding deletes personal content only; business records must stay available for legal, retention and operational purposes.
4. An account manager is unreachable and a customer needs a document in their inbox. What is the correct shape of the response?
Document the justification, get privacy sign-off, grant temporary time-boxed delegated access to the specific relevant messages rather than the whole mailbox, log the access, and remove it when done. Tell the person afterwards unless that would compromise an investigation.
5. Why prefer a standalone meeting invite over a channel meeting for a sensitive discussion?
Channel meetings inherit the channel's broader permissions, so the recording, transcript and chat become visible to a wider group than the discussion warrants. A standalone invite has a defined attendee list.
6. Which three lenses apply to remote work?
Privacy principles (fairness, purpose limitation, minimisation), security controls (device management, access, monitoring), and records hygiene (approved storage, retention, timely deletion).
7. An employee survey collects no names but does record IP addresses and department for a team of four. Is it anonymous?
No. With a team that small, department plus IP is realistically re-identifiable, so it should be treated as identified data, with the transparency and access controls that follow, or the identifiers should be dropped.
8. Which of these is not a rights request: 'send me a copy of my data', 'change my billing email', 'stop contacting me', 'who did you share my data with'?
'Change my billing email.' That is a routine operational request, even though it involves personal data.
9. What is the GDPR-style response window, and what is the condition on extending it?
One month, extendable by up to two further months for complex cases, provided the requester is told about the extension within the first month.
10. List the three gates, any one of which can permit special-category processing.
A clear legal obligation; explicit, informed, documented consent; or a purpose that is necessary, defined and proportionate. If none applies, do not collect it.

11. What makes a project a biometrics project?
It scans a face, voice or behaviour; or compares physical features against a stored record; or uses those features to decide about identity, access, attendance or classification.
12. Give two everyday activities where consent is the wrong lawful basis, and say why.
Any two of payroll, IT security, safety checks, performance management, access control, mandatory compliance activity. Refusal carries a negative work consequence, so the choice is not free, which is what consent requires.
13. What is the difference between a privacy notice and consent?
A notice informs; consent grants permission. A notice can never be treated as consent, and consent without a notice fails the informed limb.
14. A logistics team wants to reuse delivery data for a marketing model. Name three things this triggers.
It is secondary use, so: confirm the original purpose and run a compatibility assessment; check whether a new notice, consent or lawful basis is needed; and document the decision. Prefer pseudonymised data, and escalate if a new vendor or cross-border move is involved.
15. A police officer calls and asks for CCTV footage of an incident. What do you do?
Do not release anything. Collect the requester's name, organisation, badge or registration number, the legal basis, the precise scope (date, time, camera) and any transfer requirement, then escalate to privacy and legal, who decide whether and how to disclose.
16. What is the minimum you must do before relying on an AI-generated meeting summary or analysis?
Review it for accuracy, validate the decisions and actions it records, remove unnecessary personal data, and correct errors. Treat it as a draft, never as an official record on its own.
17. Five triggers require a formal review of a website or digital product. Name three.
Any three of: launching something new; adding functionality such as forms, cookies, pixels or analytics; changing the underlying technology, host or vendor; changing what is processed (new data, new markets, new AI, new automation); or using live personal data in testing or pre-production.
18. Why is 'I will report it once I have checked what happened' the wrong instinct after a suspected breach?
Notification clocks run from organisational awareness and are commonly measured in hours. Internal verification time is spent out of the legal budget, and containment can start in parallel anyway. The rule is report on suspicion.
19. Name three places where a retention schedule silently fails.
Backups that extend retention past the approved period; exports and extracts into spreadsheets and email; archived or decommissioned system instances. Auto-deleting chat also fails the other way, destroying something that should have been a record.
20. A renewal reminder email includes a 20% discount code for a different product. What has it become, and what does it now need?
Marketing. It now needs valid channel-specific opt-in consent, a working free unsubscribe, truthful classification, and the campaign checks before sending. Hiding promotional content inside an operational message is one of the most commonly enforced violations.

PART 2

Practical AI Act Advice

Thirteen sections covering what applies to you, what you have to build, and what you have to go and check on other people's systems.

This section distills the EU AI Act into the questions a working practitioner actually needs answered: what applies to me, what do I have to build, and what do I have to go check on other people's systems. It is written as practical orientation, not legal advice, and it is genericized - none of it describes any single organization's actual program. If a specific obligation could change the outcome of a real decision, get that decision checked by counsel who knows your facts.

SOURCES [2] [6] [19]

1. Scope, Territorial Reach & Key Definitions

Why it matters. The Act is a horizontal law - it does not sit inside one industry, it sits underneath all of them. That surprises two kinds of organizations: the ones who assume "AI regulation" means something for foundation-model labs and not for the internal tool their ops team built, and the ones outside the EU who assume a law with "EU" in the name can't reach them. Both assumptions are wrong often enough to be worth checking explicitly, up front, before any deeper compliance work.

What the law requires.

- *What counts as AI.* The Act's definition is broad on purpose: a system that operates with some degree of autonomy, can keep adapting its behavior after it's deployed, and turns the input it receives into outputs - predictions, generated content, recommendations, or decisions - that can affect the physical or digital world. It's built to track the OECD's definition, and it is intentionally technology-neutral rather than tied to a specific technique like machine learning.
- *Who has obligations.* Four roles carry different duties: a **provider** builds an AI system or model (or has it built) and puts it into service or on the market under its own name; a **deployer** uses a system under its own authority (personal, non-professional use doesn't count); **importers** and **distributors** move other providers' systems into or through the EU market. Most of the Act's weight sits on providers, but that doesn't make the other three roles optional reading - and a deployer that substantially modifies a system, or rebrands it under its own name, can find itself reclassified as a provider with a provider's full obligation set.
- *Territorial reach.* Three separate triggers each independently pull an organization into scope: being a provider placing a system or model on the EU market regardless of where you're headquartered; being a deployer established in the EU; or being a provider or deployer located anywhere else in the world whose AI output is used within the EU. That third trigger is the one non-EU organizations most often miss.
- *What's carved out.* The Act does not reach AI used solely for military, defense, or national security purposes; AI developed and used purely for scientific research; research, testing, or development work done before a system is placed on the market or put into service; non-EU public authorities and international organizations using AI for law-enforcement or judicial cooperation with the EU; individuals using AI for purely personal, non-professional reasons; or open-source AI systems - but that last exemption stops the moment the system in question is prohibited, high-risk, subject to the transparency rules, or a general-purpose AI model with systemic risk.
- *Terms worth actually knowing cold,* because they gate everything downstream: a **serious incident** is a malfunction or incident that leads (directly or indirectly) to death, serious harm to health, serious disruption of critical infrastructure, breach of an EU fundamental right, or serious harm to property or the environment; a **deep fake** is AI-generated or manipulated image, audio, or video content resembling a real person, object, place, entity, or event, in a way that would falsely read as authentic; a **general-purpose AI model** is a model trained on large amounts of data (often via large-scale self-supervision) that shows broad general competence across many distinct tasks and can be plugged into many different downstream systems - research/prototyping models not yet on the market are excluded; and **biometric identification** is automated recognition of physical, physiological, behavioral, or psychological traits used to establish who someone is by matching their biometric data against a stored database.

Practical steps.

- Map every internal and customer-facing AI activity against the four roles - don't assume "we're just a user of someone else's tool" settles the question; check whether you modify, rebrand, or repurpose what you buy.
- Run the territorial test even with zero EU headcount: if your output lands in the EU, you may be in scope.
- Treat "it's open source" as a question, not an answer - check whether the specific use crosses into prohibited, high-risk, transparency-triggering, or systemic-risk territory.
- Keep a one-page scope memo per major AI initiative recording which role(s) apply and why; you'll need that reasoning again at every later compliance stage.

Worked example. A software company headquartered outside the EU embeds a generative chatbot into a SaaS product sold to EU-based customers. It has no EU office and no EU staff. It is still a provider under the Act, because its AI's output is used within the EU - the extraterritorial trigger applies regardless of where the company sits.

KEY TAKEAWAYS

- The Act is horizontal: it sits underneath every industry rather than inside one. An internal ops tool is as in scope as a foundation model.
- Four roles carry different duties: provider, deployer, importer, distributor. Most weight sits on providers.
- Role is not fixed. A deployer that substantially modifies a system, or rebrands it under its own name, becomes a provider with the full provider obligation set.
- Three independent territorial triggers: placing a system or model on the EU market from anywhere; being an EU-established deployer; or being anywhere in the world when your AI's output is used in the EU. The third is the one non-EU organisations miss.
- The open-source carve-out stops the moment the system is prohibited, high-risk, transparency-triggering, or a GPAI model with systemic risk. Treat 'it is open source' as a question, not an answer.

2. Prohibited AI Practices

Why it matters. This is the one tier of the Act with no proportionality dial - no risk-based mitigation gets a prohibited practice back to "acceptable." It's also the tier with the harshest financial exposure (up to 7% of global annual turnover), which is the Act's way of signaling that these uses are considered incompatible with EU values outright, not merely risky. Every new AI use case should be screened against this list before any other compliance work starts, because nothing downstream fixes a practice that's banned at the root.

What the law requires. Ten categories of practice are prohibited, eight from the original Act and two added by Regulation (EU) 2026/1744 with effect from 2 December 2026:

1. **Manipulation through subliminal or deceptive design** - systems built to distort behavior below someone's conscious awareness or through deception, where that distortion causes or is likely to cause significant harm.
2. **Exploiting vulnerability** - targeting people because of age, disability, or socioeconomic situation to distort their behavior in a way that causes or is likely to cause significant harm.
3. **Social scoring** - evaluating or ranking people by social behavior or personal traits in a way that leads to detrimental treatment disconnected from, or disproportionate to, the context the data came from.
4. **Individual predictive policing based purely on profiling** - assessing or predicting someone's likelihood of committing a crime based solely on automated profiling of traits and characteristics, with no other basis.
5. **Emotion inference in the workplace and in education** - banned outright, with a narrow carve-out where the purpose is medical or safety-related.
6. **Untargeted scraping to build facial recognition databases** - harvesting facial images in bulk from the internet or CCTV footage to create or expand such a database.
7. **Biometric categorization used to infer protected traits** - using biometric data to sort people by race, political opinion, trade union membership, religious belief, sex life, or sexual orientation.
8. **Real-time remote biometric identification in public by law enforcement** - banned as a default rule, with narrow, pre-defined exceptions: searching for victims of specified serious crimes, or preventing an imminent threat to life such as a terrorist attack. Even within those exceptions, prior authorization from an independent judicial or administrative body is required, and law enforcement must apply appropriate safeguards.
9. **Generating non-consensual sexually explicit or intimate imagery** - added as Article 5(1)(ba) by the Digital Omnibus on AI, applicable from 2 December 2026. For providers the test is the system's intended purpose, or a reasonably foreseeable and reproducible outcome without adequate safeguards; for deployers it is intent (new Article 5(1a)).
10. **Generating child sexual abuse material** - added as Article 5(1)(bb) on the same basis and from the same date. The Commission's February 2025 guidelines on prohibited practices predate both additions and have not yet been revised to cover them.

Practical steps.

- Build a short screening questionnaire into project intake: does this system score or rank people by behavior or characteristics? Does it use biometric data to infer something the person didn't choose to disclose? Does it read emotion in a workplace or classroom setting? Can it generate sexual or intimate imagery of real people, and what stops it?

- Route anything touching biometrics, profiling, or emotion inference to legal sign-off before development starts, not after a prototype exists.
- For any real-time biometric use by or for law enforcement, confirm the authorization pathway exists and is documented before deployment, not retroactively.
- Don't rely on "we'd never do that on purpose" - the risk is usually a well-intentioned feature (engagement scoring, wellness monitoring) drifting into a banned category without anyone naming it that way.

Worked example. An employer wants to add webcam-based emotion analysis to video meetings to gauge team engagement. There's no medical or safety purpose behind it - it's a productivity feature. That puts it squarely inside the workplace emotion-recognition prohibition; no mitigation plan brings it back into bounds. The only fix is not building it.

KEY TAKEAWAYS

- This is the one tier with no proportionality dial. No mitigation brings a prohibited practice back into bounds, and exposure runs to 7% of global turnover.
- Screen against this list first, before any other compliance work. Nothing downstream fixes a practice banned at the root.
- The ten categories, eight original and two added by Regulation (EU) 2026/1744 from 2 December 2026: subliminal or deceptive manipulation; exploiting vulnerability (age, disability, socioeconomic situation); social scoring; individual predictive policing based purely on profiling; emotion inference at work and in education; untargeted facial-image scraping; biometric categorisation inferring protected traits; real-time remote biometric identification in public by law enforcement; generating non-consensual intimate imagery; generating child sexual abuse material.
- Two of the original eight have carve-outs: emotion inference for medical or safety purposes, and real-time biometric identification for specified serious crimes or an imminent threat to life, with prior judicial or administrative authorisation.
- The realistic risk is drift, not intent: a well-meant engagement or wellness feature crossing into a banned category without anyone naming it that way.

3. High-Risk AI Systems: What Counts

Why it matters. "High-risk" is the tier that carries the Act's heaviest ongoing obligation set, so getting the classification right - including correctly concluding a system is *not* high-risk - is foundational. Two different routes get a system there, and they're evaluated independently.

What the law requires.

- **Route one: the Annex III use-case list.** A system is high-risk if it falls into one of the listed use-case categories:

CATEGORY	REPRESENTATIVE USES
Biometrics	Remote biometric identification; biometric categorization; emotion recognition
Critical infrastructure	Safety components managing road traffic, digital infrastructure, water, gas, heating, electricity
Education & vocational training	Admissions/access decisions; evaluating learning outcomes; monitoring for prohibited behavior
Employment & worker management	Recruitment, hiring, job advertising; promotion, termination, pay decisions; task allocation and performance monitoring
Essential services & benefits	Public benefits eligibility; life and health insurance pricing; emergency-service dispatch; credit scoring
Law enforcement	Assessing victim risk; polygraph-type tools; evaluating reliability of evidence
Migration, asylum & border control	Visa and asylum application processing; identity verification; security risk assessment; polygraph-type tools
Judicial & democratic processes	Researching, interpreting, and applying the law; influencing the outcome of elections or referendums

- **Route two: regulated products and safety components.** A system is also high-risk if it is a product, or a safety component of a product, already governed by one of a specific set of EU product-safety laws - machinery (Directive 2006/42/EC), toys (Directive 2009/48/EC), medical devices (Regulation (EU) 2017/745 and 2017/746), motor vehicles (Regulation (EU) 2019/2144 and No 168/2013), aviation (Regulation (EU) 2018/1139 and (EC) 300/2008), marine equipment (Directive 2014/90/EU), rail (Directive (EU) 2016/797), gas-burning appliances (Regulation (EU) 2016/426), personal protective equipment (Regulation (EU) 2016/425), cableway installations (Regulation (EU) 2016/424), pressure equipment (Directive 2014/68/EU), lifts (Directive 2014/33/EU), and radio equipment (Directive 2014/53/EU).
- **The carve-out.** A system that falls into an Annex III use case is not treated as high-risk if it doesn't pose a significant risk of harm to health, safety, or fundamental rights - for example, because it performs a narrow task that doesn't materially influence the outcome of a decision. The Act doesn't hand out a blanket pass here; it's a narrow, fact-specific exception, so don't lean on it without a documented rationale.
- **Registration.** All systems classified as high-risk must be registered in the EU's public database before they go into use, and the Omnibus kept a simplified registration for Annex III systems a provider has assessed as not high-risk under the carve-out. The obliga-

tion applies from 2 December 2027; as of September 2026 the database itself was reported as not yet operational, so build the step into the launch checklist and watch for the opening date.

Practical steps.

- Run every AI use case through both routes independently - a system can clear the product-safety route and still land in Annex III, or vice versa.
- When you conclude a system escapes high-risk status via the "no significant risk" carve-out, write down why, not just that it does - that record is what you'll need to defend the conclusion later.
- Build registration into your launch checklist for anything that does clear the high-risk bar, rather than treating it as a late-stage afterthought.
- Revisit classification when a system's use case changes - a tool built for one purpose that gets repurposed into, say, a hiring decision can cross the line without any code changing.

KEY TAKEAWAYS

- Two independent routes to high-risk. Run both: a system can clear the product-safety route and still land in Annex III, or the reverse.
- Route one is the Annex III use-case list: biometrics; critical infrastructure; education and vocational training; employment and worker management; essential services and benefits; law enforcement; migration, asylum and border control; judicial and democratic processes.
- Route two is products and safety components already covered by named EU product-safety laws: machinery, toys, medical devices, vehicles, aviation, marine, rail, gas appliances, PPE, cableways, pressure equipment, lifts, radio equipment.
- The carve-out (no significant risk of harm, for example a narrow task that does not materially influence a decision) is narrow and fact-specific. Write down why you concluded it applies, not just that it does.
- Classification is not permanent. Repurposing a tool into, say, a hiring decision can cross the line with no code change.
- Every high-risk system must be registered in the EU public database before use. The obligation applies from 2 December 2027 and the database was not yet open in September 2026.

4. Obligations for AI Providers

Why it matters. If you provide a high-risk AI system, the Act expects you to have engineered compliance into the system itself, not bolted it on afterward. The requirement set below is meant to be threaded through the whole development lifecycle - risk management and data governance start at design time, not at ship time.

What the law requires - provider checklist for high-risk systems.

- **Risk management system.** Identify, evaluate, mitigate, and monitor risks continuously and iteratively - this is a running process, not a one-time assessment filed away after launch.
- **Data and data governance.** Training, validation, and test datasets must be relevant, representative, and of sufficient quality to keep bias risk down; be ready to explain your data sourcing and curation choices.
- **Technical documentation.** Maintain a record covering the system's description, its performance metrics, test results, data lineage, and its conformity declaration - this is the file a regulator or auditor will ask to see first.
- **Automatic logging.** The system must record its own logs - inputs, outputs, usage data - and those logs need to be retained, not just generated.
- **Instructions for use.** Provide deployers with documentation that actually lets them operate the system safely - this is the artifact deployers are legally entitled to rely on.
- **Human oversight by design.** Build the system so a human can meaningfully interpret and explain what it's doing, not just switch it off in an emergency.
- **Accuracy, robustness, and cybersecurity.** Demonstrate - through testing and documentation, not assertion - that the system holds up to an appropriate standard on all three.
- **Quality management system.** Document your organization's strategy for regulatory compliance, quality control, and risk management as a coherent whole, not scattered across teams.
- **Accessibility.** High-risk systems must meet EU accessibility requirements under Directives 2016/2102 and 2019/882.
- **Conformity assessment.** Complete the required conformity assessment and produce a Declaration of Conformity before the system goes to market.
- **Registration.** Register the system in the European Commission's public database for high-risk AI.
- **Regulatory cooperation.** Be prepared to share information about the system with regulatory authorities on request.

Practical steps. Turn the twelve items above into a stage-gated internal checklist - some belong at design (data governance, oversight design), some at pre-launch (conformity assessment, registration), and some are ongoing (logging, cooperation, risk monitoring). Assign an owner to each item rather than treating "compliance" as one team's job; documentation and quality-management obligations in particular tend to fall through cracks between engineering and legal.

KEY TAKEAWAYS

- The provider obligation set is engineered in, not bolted on: risk management and data governance start at design time.
- The twelve items: risk management system; data and data governance; technical documentation; automatic logging; instructions for use; human oversight by design; accuracy, robustness and cybersecurity; quality management system; accessibility; conformity assessment; registration; regulatory cooperation.
- Technical documentation is the file a regulator or auditor asks for first: description, performance metrics, test results, data lineage, conformity declaration.
- Human oversight by design means a human can meaningfully interpret and explain what the system is doing, not merely switch it off.
- Stage-gate the twelve: some at design, some pre-launch, some ongoing, each with a named owner. Documentation and quality management are the two that fall between engineering and legal.

5. Obligations for AI Deployers

Why it matters. Most organizations touched by the Act are deployers, not providers - they're buying and using AI built by someone else, not building it themselves. That makes vendor selection a compliance decision, not just a procurement one: a deployer can be exposed by a provider's shortcomings even when the deployer did nothing wrong on its own systems. Choosing providers carefully, and doing real due diligence on them, is not optional risk hygiene here - it's load-bearing.

What the law requires - deployer obligations for high-risk systems.

- **Follow the instructions for use.** Obtain the provider's instructions and operate the system within them - deviating from documented use is where a deployer's own liability starts.
- **Human oversight.** Assign oversight of the system to people who actually have the competence, training, and authority to exercise it - a formal sign-off from someone who doesn't understand the system doesn't satisfy this.
- **Input data quality, where you control it.** If the deployer feeds the system its own input data, that data has to be relevant and sufficiently representative for the system's actual use.
- **Ongoing monitoring.** Watch how the system operates in practice and report serious incidents, along with risks to health, safety, or fundamental rights, as they surface.
- **Record-keeping.** Retain the logs the system generates - inputs, outputs, usage - for an appropriate period, aligned with GDPR retention principles.
- **Transparency to affected people.** Inform workers' representatives and affected employees when a high-risk system is used in the workplace, and inform individuals when a system is making or materially assisting decisions about their lives.
- **Regulatory cooperation.** Cooperate with authorities, including during investigations or enforcement actions.
- **Data protection impact assessment.** Complete a DPIA where one applies, drawing on the documentation the provider supplied.

Fundamental rights impact assessment (FRIA). This is not a blanket requirement across all high-risk deployments - it applies to a specific subset: deployers that are bodies governed by public law, private entities providing public services, and deployers of two Annex III use cases: evaluating the creditworthiness of natural persons or establishing their credit score (excluding systems used to detect financial fraud), and risk assessment and pricing of natural persons for life and health insurance. Motor, property and other insurance lines are not in the list. The Omnibus lets the FRIA cross-reference an existing DPIA rather than repeat it (Article 27(4)) and tasks the AI Office with a template questionnaire and an automated tool (Article 27(5)). The obligation applies from 2 December 2027.

Importers and distributors. Their duty is narrower but non-negotiable: verify that the high-risk system is actually in conformity with the Act's requirements before passing it along, typically by checking the Declaration of Conformity and the CE marking rather than taking the provider's word for it.

Practical steps. Build a standing vendor-vetting process specifically for AI providers, distinct from general procurement due diligence - request the instructions for use and technical documentation before signing, not after. Pre-identify which of your deployments fall into

the FRIA-triggering categories (public-law body, public service, credit scoring, life and health insurance) so the assessment isn't discovered as a last-minute gap during an audit.

Worked example. A bank deploys a third-party AI system to help price consumer credit. As deployer, the bank needs the provider's instructions for use, must assign competent human oversight of the pricing decisions, must complete a fundamental rights impact assessment (creditworthiness evaluation is one of the two triggering Annex III use cases), and must be ready to show its logs if a serious incident or a regulator's inquiry arises. None of that is satisfied by the vendor's own compliance work - it's the bank's obligation as deployer.

KEY TAKEAWAYS

- Most organisations are deployers, which makes vendor selection a compliance decision rather than a procurement one.
- The eight deployer duties: follow the instructions for use; assign competent human oversight; ensure input data quality where you control it; monitor and report serious incidents; keep the logs; be transparent to workers' representatives, affected employees and affected individuals; cooperate with regulators; complete a DPIA where one applies.
- Deviating from the documented use is where a deployer's own liability starts.
- Oversight must be assigned to someone with the competence, training and authority to exercise it. A sign-off from someone who does not understand the system does not satisfy the obligation.
- A fundamental rights impact assessment is not universal. It applies to public-law bodies, private providers of public services, and deployers of two Annex III use cases: creditworthiness evaluation or credit scoring of natural persons (excluding fraud detection) and life and health insurance risk assessment and pricing. It may cross-reference a DPIA, and applies from 2 December 2027.
- Importers and distributors have a narrower but non-negotiable duty: verify conformity via the Declaration of Conformity and CE marking rather than taking the provider's word.

6. General-Purpose AI Models (GPAI)

Why it matters. GPAI models are a separate regulatory lane from high-risk *systems* - a foundation model can sit underneath a high-risk system, a limited-risk system, or nothing classified as high-risk at all, and it has its own obligations regardless of where it ends up being used. If your organization builds or fine-tunes large general-purpose models, this lane applies to you even before you know exactly how customers will deploy them downstream.

What the law requires.

- **Definition.** A GPAI model is one trained on large amounts of data - often through large-scale self-supervision - that shows broad, general competence across many distinct tasks and can be integrated into a wide range of downstream systems. Models still in research, development, or prototyping, not yet placed on the market, don't count yet.
- **Baseline obligations for GPAI providers.** Publish a detailed summary of the content and data used to train the model; maintain a policy for complying with EU copyright and intellectual-property law; keep technical documentation current; and produce documentation that lets downstream providers integrating the model understand its capabilities and limitations.
- **The open-source carve-out.** These baseline obligations don't apply to providers of open-source GPAI models - unless that model is also classified as posing systemic risk, in which case the full obligation set (below) kicks back in regardless of license.
- **Systemic-risk classification.** A model is treated as posing systemic risk if it has high-impact capabilities - measured primarily by the cumulative compute used to train it - or if the European Commission designates it as such by decision.
- **The 10²⁵ FLOPS threshold, in plain terms.** FLOPS (floating-point operations) are just a way of measuring how much raw computation went into training a model. The Act uses cumulative training compute above 10²⁵ FLOPS as its main proxy for "this model is powerful enough that its capabilities could be hard to fully predict or control" - the underlying logic being that more training compute tends to track with more general capability, and more general capability is where systemic risk tends to concentrate. This is explicitly a moving target: the threshold is designed to be reviewed and adjusted as the technology develops, not fixed forever.
- **Extra obligations once a model crosses into systemic risk.** On top of the baseline four: notify the European Commission; run model evaluation and adversarial testing; maintain adequate cybersecurity protections; report serious incidents; and actively assess and mitigate the model's key systemic risks.
- **Timing and compliance tools.** GPAI obligations became applicable on 2 August 2025, twelve months after the Act's entry into force; the Commission's own enforcement powers over GPAI providers apply from 2 August 2026, and models already on the market before 2 August 2025 have until 2 August 2027 to comply. Providers can point to Codes of Practice and standardized templates - issued by the AI Office - as a recognized way of demonstrating compliance, and are expected to cooperate with regulators and share relevant documentation on request.

Practical steps. If you train or substantially fine-tune large models, track your cumulative training compute against the 10²⁵ FLOPS marker proactively - don't wait for a Commission designation to find out you're already over it. Treat the training-data summary and copyright-compliance policy as standing deliverables that need to be kept current across model versions, not one-off documents. If you rely on the open-source carve-out, re-check

that classification every time you retrain, since crossing into systemic risk cancels the exemption.

KEY TAKEAWAYS

- GPAI is a separate lane from high-risk systems. A model carries its own obligations regardless of what it ends up inside.
- The four baseline obligations: publish a detailed training-data summary; maintain an EU copyright compliance policy; keep technical documentation current; document capabilities and limitations for downstream providers.
- The open-source carve-out from those four disappears if the model is classified as systemic-risk.
- Systemic risk is set by high-impact capability, measured primarily by cumulative training compute, or by Commission designation. The headline proxy is 10^{25} FLOPS, explicitly a moving target.
- Systemic risk adds five duties: notify the Commission; run model evaluation and adversarial testing; maintain adequate cybersecurity; report serious incidents; assess and mitigate key systemic risks.
- GPAI obligations applied from 2 August 2025, twelve months after entry into force; the Commission's fining powers over GPAI providers from 2 August 2026; pre-existing models must comply by 2 August 2027. Codes of Practice plus AI Office templates are the recognised route to demonstrating compliance.

7. Compliance & Conformity Assessment

Why it matters. The Act doesn't hand you one compliance checklist - it hands you several, layered at the level of the use case, the model, the system, and the organization, and which ones apply depends on your role and on which risk tiers are actually in play. Treating this as a single linear project ("get compliant, then done") misses that the requirement set shifts as your AI portfolio and your roles shift.

What the law requires - a working compliance sequence.

1. **Screen out prohibited practices first.** Nothing else matters if a use case is banned outright - this has to be the first gate, not a later one.
2. **Inventory and track high-risk AI.** Identify every system you develop or use that clears either high-risk route (Annex III use case, or regulated product/safety component), and keep that inventory current as use cases evolve.
3. **Run a gap analysis.** For everything you've flagged as high-risk, measure current practice against the full requirement set and identify what needs to be built or fixed.
4. **Register what needs registering.** Get high-risk systems into the EU's public database once it opens - this is a discrete, trackable action item due before the 2 December 2027 application date, not a vague aspiration.
5. **Roll out AI literacy training.** Employees actually working with or governing these systems need to understand them and their risks - this is itself a legal requirement (see Section 12), not just good practice.

Conformity assessment, in brief. High-risk systems must go through a conformity assessment before they're placed on the market or put into service - the process exists to test, demonstrate, and formally declare that the system meets the Act's requirements. Which specific assessment procedure applies varies by system type, so this isn't a single universal form.

Limited-risk transparency obligations. A separate, lighter tier applies to systems that interact with people or generate content, independent of whether they're also high-risk:

- Providers must design systems so people are told they're interacting with AI.
- Deployers using emotion-recognition systems must notify the people being assessed.
- Deployers must disclose when content is a deep fake and AI-generated.

The overlap point that trips people up. These categories are not mutually exclusive boxes - a system can be high-risk *and* separately subject to the limited-risk transparency rules (say, a high-risk hiring tool that also generates content and therefore has to disclose it's AI). A GPAI model can be embedded inside a high-risk system, exist as a standalone product, or sit inside a system that isn't high-risk at all - and, in principle, a GPAI model embedded in a high-risk system can also be used in a way that triggers the transparency rules on top. The practical consequence: never answer "what do we have to comply with" for an AI initiative in the abstract - the honest answer always depends on the specific combination of role, risk tier, and use case in front of you.

KEY TAKEAWAYS

- There is no single checklist. Requirements are layered at use case, model, system and organisation level, and shift as your portfolio and roles shift.
- The working sequence is five steps: screen out prohibited practices; inventory and track high-risk AI; run a gap analysis; register what needs registering; roll out AI literacy training.
- Prohibited-practice screening is the first gate, not a later one.
- Conformity assessment happens before market placement or putting into service, and the applicable procedure varies by system type. There is no universal form.
- Limited-risk transparency is a separate, lighter tier: tell people they are interacting with AI; notify people assessed by emotion recognition; disclose deep fakes and AI-generated content.
- The tiers are not mutually exclusive. A high-risk hiring tool that also generates content owes both sets of duties, and a GPAI model can sit inside any of them. Never answer 'what applies to us' in the abstract.

8. Governance & Enforcement

Why it matters. Enforcement isn't centralized in one Brussels office - it's distributed across every member state plus two EU-level bodies, and different obligations came online on different dates rather than all at once. Knowing the actual calendar and the actual regulator map matters for anyone trying to sequence a compliance program realistically.

The regulatory landscape.

- **Member state regulators.** Each member state must appoint at least one market surveillance authority and at least one notifying authority (together, the "national competent authorities"), meaning multiple regulators typically operate within a single country, each responsible for a different slice of enforcement. One market surveillance authority is designated as the primary point of contact for the Act within that jurisdiction.
- **The European AI Office.** Sits inside the European Commission and is responsible for enforcing the rules on general-purpose AI models specifically - developing Codes of Practice and guidance, and working to keep enforcement of the Act coherent and coordinated across the EU.
- **The European AI Board.** Made up of one representative per member state, it works to harmonize how the Act is implemented across the bloc, issuing opinions and guidance, and is supported by an Advisory Forum and a Scientific Panel of experts.

Where things stand in September 2026. The Commission's AI Act Service Desk and Single Information Platform, launched 8 October 2025, are the official help desk, with an article explorer and a compliance checker (whose text has not yet been updated for the Omnibus). The Scientific Panel of independent experts and the Advisory Forum were appointed on 1 June 2026. Most member states have designated their market surveillance authorities; the EDPB has asked them (Statement 3/2024) to give that role to the data protection authorities for the Annex III use cases in law enforcement, migration, justice and democratic processes, and more broadly for high-risk systems that process personal data. The Commission's guidelines on high-risk classification are still a draft (19 May 2026); its Code of Practice on transparency of AI-generated content and the Article 50 guidelines were published in July 2026. No harmonized standard has yet been cited in the Official Journal, so the presumption of conformity under Article 40 is not yet available and providers work from the draft CEN-CENELEC JTC 21 standards.

Enforcement timeline.

DATE	WHAT HAPPENS
12 July 2024	The Act is published in the Official Journal of the EU
1 August 2024	The Act enters into force
2 February 2025	Rules on prohibited AI practices become applicable
2 August 2025	Obligations for providers of general-purpose AI models become applicable
2 August 2025	Deadline for member states to appoint their regulatory authorities
27 July 2026	Regulation (EU) 2026/1744, the Digital Omnibus on AI, enters into force and rewrites the remaining application dates

DATE	WHAT HAPPENS
2 August 2026	Transparency obligations (Article 50), penalties, governance, national authorities and the Commission's enforcement powers over general-purpose AI models become applicable
2 December 2026	The two prohibitions added by the Omnibus (non-consensual intimate imagery, child sexual abuse material) become applicable; grace period ends for machine-readable marking on generative systems already on the market
2 August 2027	General-purpose AI models placed on the market before 2 August 2025 must comply; national regulatory sandboxes due
2 December 2027	Obligations for Annex III high-risk AI systems become applicable, including deployer duties, fundamental rights impact assessments, registration and serious incident reporting
2 August 2028	Obligations for high-risk AI systems embedded in regulated products (Annex I) become applicable

The original Act set 2 August 2026 for most provisions and 2 August 2027 for Annex I systems. Regulation (EU) 2026/1744, adopted 8 July 2026 and in force from 27 July 2026, replaced those with the fixed dates above rather than a standards-linked trigger, softened the Article 4 literacy wording, added two prohibited practices, gave the AI Office direct competence over systems built on a general-purpose model from the same provider and over systems embedded in very large online platforms, and extended the SME simplifications to small mid-caps. What did apply on 2 August 2026 is transparency, penalties, governance and enforcement powers; the whole high-risk regime now starts on 2 December 2027.

Penalty tiers.

BREACH	MAXIMUM PENALTY
Non-compliance with the prohibited-practices rules	Up to 7% of global annual turnover, or €35m - whichever is higher
Non-compliance with obligations for providers/deployers of high-risk systems	Up to 3% of global annual turnover, or €15m - whichever is higher
Supplying incorrect or misleading information to regulators	Up to 1% of global annual turnover, or €7.5m - whichever is higher

Each member state sets up its own penalty regime within these EU-wide ceilings, and the Act calls for lower, more proportionate fines for SMEs and startups rather than applying the same scale uniformly regardless of company size.

Practical steps. Build your compliance roadmap against the actual dated timeline above rather than treating "the AI Act" as one deadline - prohibited-practice screening and GPAI provider obligations were live well before the 2026 date most people associate with the law, and the high-risk regime now starts on 2 December 2027 rather than 2 August 2026. Identify which national competent authority is your primary point of contact in each member state where you operate, before you need to find that out under time pressure.

KEY TAKEAWAYS

- Enforcement is distributed, not centralised: each member state appoints at least one market surveillance authority and one notifying authority, with one designated as the primary contact point.
- Two EU-level bodies: the European AI Office inside the Commission, which enforces GPAI rules and develops Codes of Practice, and the European AI Board, one representative per member state, which harmonises implementation.
- The dates that matter: published 12 July 2024; in force 1 August 2024; prohibited practices applicable 2 February 2025; GPAI provider obligations and the authority-appointment deadline 2 August 2025; transparency, penalties, governance and enforcement powers 2 August 2026; the two new prohibitions 2 December 2026; Annex III high-risk obligations 2 December 2027; Annex I product-embedded systems 2 August 2028. The last two were moved by Regulation (EU) 2026/1744, in force 27 July 2026.
- Three penalty tiers: 7% of global turnover or EUR 35m for prohibited practices; 3% or EUR 15m for high-risk provider and deployer obligations; 1% or EUR 7.5m for supplying incorrect or misleading information to regulators. In each case whichever is higher.
- Member states set their own regimes within those ceilings, with lower, more proportionate fines called for in respect of SMEs and startups.

9. Building an Enterprise AI Governance Program: 10 Foundations

Why it matters. Point compliance with the Act - one gap analysis, one registration, one training module - doesn't hold up over time as your AI portfolio grows. A governance program needs standing structure so that new use cases get evaluated the same way every time, without reinventing the process per project.

What a program actually needs - 10 foundations.

1. **A policy and standards framework.** Written rules covering how AI gets developed, procured, deployed, and used - not a single AI policy document, but a coherent set that different teams can actually apply to their own decisions.
2. **A risk management framework.** A defined method for classifying and assessing AI risk, with clear ownership of each risk, oversight of the framework itself, and a reporting line that surfaces issues to people who can act on them.
3. **A live AI inventory.** Discover and catalogue every AI system, model, project, vendor relationship, and use case across the organization - you cannot govern what you haven't found, and shadow AI adoption is usually larger than leadership assumes.
4. **A governance board with a real operating model.** Defined roles and decision rights, not an advisory committee that meets quarterly with no authority to block a launch.
5. **Third-party risk management specific to AI.** Due diligence and ongoing risk assessment for every vendor and partner engagement that touches AI - general vendor security review isn't a substitute for this.
6. **Regulatory horizon-scanning.** Active monitoring of the regulatory landscape across every jurisdiction you operate in, feeding back into policy updates - the AI regulatory environment is moving faster than most compliance calendars are built for.
7. **Metrics, assurance, and audit.** A way to actually measure whether the governance program is working - not just whether it exists - and to periodically test that on the ground.
8. **Education and training.** Structured upskilling on AI ethics, governance, risk, and compliance across the workforce (see Section 12 for how to layer this).
9. **Technical tooling and guardrails.** Evaluate whether you need dedicated technology for testing, ongoing monitoring, and MLOps - governance that lives only in policy documents, with no technical enforcement, tends to erode under delivery pressure.
10. **Alignment with existing digital governance functions.** Privacy, cybersecurity, and data governance teams are already doing adjacent work - build AI governance to collaborate with them, not duplicate or compete with what already exists.

Practical steps. Stand up the inventory (foundation 3) early - most of the rest depends on knowing what you actually have. Resist building governance as a standalone silo; the fastest path to a workable program usually runs through extending structures (risk committees, vendor review, data governance) that already exist rather than creating parallel ones.

KEY TAKEAWAYS

- Point compliance does not survive portfolio growth. The goal of a program is that new use cases get evaluated the same way every time.
- The ten foundations: policy and standards framework; risk management framework; live AI inventory; governance board with real decision rights; AI-specific third-party risk management; regulatory horizon-scanning; metrics, assurance and audit; education and training; technical tooling and guardrails; alignment with existing digital governance functions.
- Start with the inventory. You cannot govern what you have not found, and shadow AI adoption is usually larger than leadership assumes.
- A governance board without authority to block a launch is an advisory committee, not governance.
- General vendor security review is not AI third-party risk management, and governance that lives only in policy documents erodes under delivery pressure.
- Extend existing structures (risk committees, vendor review, data governance) rather than building a parallel silo.

10. Assessing AI Risk: Questions Worth Asking

Why it matters. Before a new AI initiative gets built or deployed, someone needs to ask a consistent set of questions - not as a bureaucratic gate, but because the answers are what determine which of the Act's obligations actually apply, and what the real-world blast radius looks like if the system gets something wrong.

A practical internal risk-assessment framework - ten questions to put in front of every new AI initiative:

1. **Purpose.** What problem is this actually solving, and why does it need AI specifically rather than a simpler method?
2. **Value.** How much value does this generate, and how important is it to the business - worth understanding before you calibrate how much rigor the risk process gets.
3. **Data rights.** What data is used for development and for live input, and do you actually have the right to use it?
4. **Geography.** Which jurisdictions is the system being developed in, made available in, and used in?
5. **Model choice.** What type of model is being used, and why that type specifically, rather than a simpler or more explainable alternative?
6. **Third-party dependencies.** Does the system rely on any third-party models, tools, or services - and if so, whose obligations apply where?
7. **Output.** What does the system actually produce, and how is that output used downstream?
8. **Human oversight.** Is there human oversight, and - critically - can the person doing the overseeing actually verify and act on what the AI produced, or are they rubber-stamping it?
9. **Impact of failure.** What happens if the output is wrong, biased, or incomplete - who is affected, and how badly?
10. **Ongoing monitoring.** How will performance and usage be tracked over time, so that drift or failure gets caught rather than discovered after the fact?

Practical steps. Make this a standard intake form, not a one-off interview - the value is in asking every initiative the same ten questions, so risk levels are comparable across the portfolio rather than assessed inconsistently project by project. Route answers that reveal high-risk classification, prohibited-practice overlap, or weak human oversight to a mandatory second review before build work proceeds. For the data protection side of the same assessment, EDPB Opinion 28/2024 on AI models sets out how supervisory authorities decide whether a model trained on personal data is anonymous, when legitimate interests can support training and deployment, and what an unlawfully trained model means for the organizations that deploy it; the EDPB's harmonized DPIA template (14 April 2026) and its 2026 guidelines on anonymization and web scraping for generative AI supply the method.

KEY TAKEAWAYS

- The value of a standard intake form is comparability. Ten identical questions across the portfolio beat ten bespoke interviews.
- The ten questions: purpose; value; data rights; geography; model choice; third-party dependencies; output; human oversight; impact of failure; ongoing monitoring.
- Two questions carry most of the weight: whether you actually have the right to use the data, and whether the person overseeing can genuinely verify and act rather than rubber-stamp.
- Geography is asked three ways: where developed, where made available, where used. Those can be three different answers and three different obligation sets.
- Route answers that reveal high-risk classification, prohibited-practice overlap or weak oversight to a mandatory second review before build work proceeds.

11. Vetting AI Vendors: A Procurement Due-Diligence Framework

Why it matters. As established in Section 5, deployers can inherit a provider's compliance failures - so the procurement conversation with an AI vendor needs to go well beyond price and functionality. Treat this as the point where most of your actual downstream risk gets decided.

A practical due-diligence framework - ask every AI vendor:

1. **Governance.** What is your organization's own approach to AI governance and risk management - do they have one, or are they answering for the first time?
2. **Training data.** What data was used to train the system, and under what legal basis was it collected and used?
3. **Use of your data.** Will they use your organization's data to train, retrain, or otherwise improve their models and services - and did you actually agree to that?
4. **Litigation exposure.** Are they currently facing legal challenges or enforcement action related to the product?
5. **IP indemnity.** Will they provide copyright and intellectual-property indemnity protection if their system's output infringes someone else's rights?
6. **Sub-dependencies.** Are they themselves relying on third-party models, tools, or services to deliver this product - and do you know who those parties are?
7. **Output ownership.** What type of output does the system generate, and who actually owns it - you, or them?
8. **Documentation.** What guidance and instructions for use will they actually provide, in enough detail for you to meet your own deployer obligations?
9. **Regulatory compliance.** Can they demonstrate compliance with the AI Act and other applicable AI regulation - with evidence, not just assurance?
10. **Support.** What professional services and support will they provide for implementation and ongoing use?

Practical steps. Get answers to all ten in writing before contract signature, not as a post-signature follow-up - several of them (IP indemnity, data-use rights, output ownership) are things you want negotiated into the contract itself, not just disclosed informally. Treat a vendor who can't answer the compliance and documentation questions with specifics as a risk signal in itself, regardless of how good the product demo was.

KEY TAKEAWAYS

- Procurement is where most downstream risk is decided, because a deployer inherits a provider's failures.
- The ten questions: their governance; training data and its legal basis; whether they use your data to train; litigation exposure; IP indemnity; sub-dependencies; output ownership; documentation; demonstrable regulatory compliance; support.
- Three of the ten belong in the contract, not in an email: IP indemnity, data-use rights, output ownership.
- Get all ten answered in writing before signature. After signature you have lost the leverage.
- A vendor who cannot answer the compliance and documentation questions with specifics is itself the risk signal, however good the demo was.

12. Building AI Literacy Across an Organization

Why it matters. AI literacy isn't a nice-to-have training slide - Article 4 of the Act has required providers and deployers to act on it since 2 February 2025. The original text asked for a "sufficient level" of AI literacy; Regulation (EU) 2026/1744 rewrote it so that providers and deployers must "take measures to support the development of AI literacy" of their staff and of others operating AI systems on their behalf, and the Commission's guidance now states that no specific or sufficient level is mandated. Enforcement sits with national market surveillance authorities from 2 August 2026. The obligation still underpins another one directly: human oversight of high-risk systems has to be assigned to people with the necessary competence and training, and that duty was not softened, so a literacy program remains the practical foundation for it.

A structure that actually differentiates by audience - four layers.

- **Layer one: governance fundamentals for everyone.** Mandatory, organization-wide, and deliberately simple - the goal is that every employee understands the basic pillars of responsible AI and the organization's own policies, not that they become experts.
- **Layer two: generative AI enablement.** Aimed at building comfort and skill using AI tools day to day - this layer works best when it's inspirational and interactive rather than compliance-flavored, and incentives like internal accreditation can help drive voluntary uptake.
- **Layer three: role-based training.** Tailored content for the specific people who build, buy, use, or govern AI as part of their actual job - governance staff, privacy staff, procurement staff, data scientists, IT partners - each needs different depth on different topics, and generic training tends to under-serve all of them at once.
- **Layer four: system-specific operational training.** Mandatory for anyone actually operating a high-risk system, or otherwise responsible for it - bespoke instructions on exercising human oversight and other risk-mitigation duties for that specific system, precise enough that end users can actually interpret the system's outputs and recognize a serious incident when one happens.

Practical steps. Don't run one generic "AI training" module and call the literacy obligation satisfied. The amended Article 4 no longer sets a level, so the defensible position is evidence of measures that fit the audience and the risk exposure, and for anyone assigned to human oversight of a high-risk system the competence requirement is unchanged and specific. A single one-size module demonstrates neither. Tie layer four specifically to your high-risk system inventory (Section 3) so operational training rolls out to exactly the people who need it, not organization-wide by default.

KEY TAKEAWAYS

- AI literacy is a legal requirement, not a training nicety: Article 4, applicable since 2 February 2025, reworded by Regulation (EU) 2026/1744 to require measures that support the development of AI literacy, with no sufficient level mandated.
- It also props up another obligation: human oversight of high-risk systems must sit with competent, trained people, which is meaningless without a literacy program behind it.
- Four layers: governance fundamentals for everyone; generative AI enablement; role-based training; system-specific operational training.
- Layer two works best when it is inspirational and interactive rather than compliance-flavoured. Layer four is mandatory for anyone operating a high-risk system.
- One generic module does not satisfy the obligation. Auditors look for evidence that training differs by audience and by risk exposure, and layer four should be tied to the high-risk inventory rather than rolled out organisation-wide.

13. Copyright & Generative AI

Why it matters. Copyright protects original creative and intellectual work - books, articles, images, music, software - to encourage people to keep making it. Generative AI creates friction with that system at both ends: models are trained on enormous amounts of copyrighted material, and they can reproduce or closely resemble that material in their outputs. A second, separate question sits alongside the infringement risk: whether the organization's own AI-generated output is protectable at all. Both questions are now being answered by courts rather than commentators, and the answers so far point in one direction: how the training data was obtained, and what the model reproduces, matter more than the fact of training itself.

Where copyright exposure shows up across the AI lifecycle.

- **Training.** Base models are trained on large datasets that incorporate copyrighted material, often without individualized permission from each rightsholder. The first US merits rulings turned on how that material was acquired, not only on how it was used.
- **Fine-tuning.** Adjusting a pre-trained model on a narrower dataset can draw on copyrighted material just as the original training run did.
- **Retrieval-augmented generation.** RAG systems pull from a retrieval corpus at query time - if that corpus contains copyrighted material, it can be reproduced in the augmented output.
- **Prompts and inputs.** Users routinely upload or paste copyrighted material - images, documents, text excerpts - directly into prompts, sometimes without thinking of it as a copyright-relevant act.
- **Inference and outputs.** Generated content can reproduce, or come close enough to resemble, existing copyrighted work. This is now the live battleground: lyrics, characters and verbatim article text are what the 2025 and 2026 cases are about.

Whether AI output itself is copyrightable. Across most jurisdictions, some degree of human authorship is required for copyright to attach - content that is purely AI-generated, with no meaningful human creative input, generally isn't protectable, while "AI-assisted" work often is. The dividing line is the nature and degree of human creative contribution: in the US, typing a prompt isn't enough on its own, but the analysis changes once a human's own creative choices are perceptible in the resulting output. That position is now settled at the top: the Supreme Court declined on 2 March 2026 to review *Thaler v Perlmutter*, leaving the D.C. Circuit's human-authorship holding in place.

A comparative regulatory snapshot - the applicable rules are generally determined by where the copying itself took place, and the landscape still diverges sharply by jurisdiction:

JURISDICTION	CURRENT POSTURE (SEPTEMBER 2026)
United States	No AI-specific copyright statute; fair use decided case by case, and three district courts have now ruled on the merits. <i>Bartz v Anthropic</i> (June 2025) held training on lawfully acquired books to be fair use and the use of a pirated library not to be; the resulting class settlement of about USD 1.5 billion over roughly 482,000 works, around USD 3,000 per work, received final approval on 21 July 2026 and covers acquisition and storage only, not outputs. <i>Kadrey v Meta</i> (June 2025) found fair use on narrow facts, with a distribution claim continuing into 2027. <i>Thomson Reuters v Ross</i> found no fair use; the Third Circuit heard argument on 11 June 2026 and its decision will be the first appellate ruling on AI training. The <i>New York Times</i> case is now the consolidated OpenAI multidistrict litigation in New York, in summary judgment briefing since September 2026, with the US government filing in support of training as transformative.
European Union	The AI Act reinforces that existing EU copyright law applies to AI systems and adds a training-data transparency obligation for general-purpose models, given concrete shape by the Commission's summary template (July 2025) and the copyright chapter of the GPAI Code of Practice: lawful access only, respect for machine-readable reservations including robots.txt, no circumvention of paywalls, output safeguards and a rightsholder complaint channel. The Commission's fining powers over GPAI providers apply from 2 August 2026. The Copyright Directive's two text-and-data-mining exceptions stand: one for scientific research, one general and subject to rightsholder opt-out. The Court of Justice heard <i>Like Company v Google</i> (C-250/25), the first reference on training and chatbot outputs, in March 2026; judgment is pending. Parliament adopted a non-binding resolution in March 2026 calling for remuneration and a standardized opt-out, and the Commission is studying an EU-level opt-out registry.
Germany	The Munich Regional Court held in <i>GEMA v OpenAI</i> (November 2025) that memorization of lyrics in model parameters is reproduction outside the text-and-data-mining exception, and that chatbot outputs reproducing them are communication to the public; it repeated the result in <i>GEMA v Suno</i> (July 2026). Both are under appeal. The practical point: the TDM exception covers the gathering phase, not what the model retains.
United Kingdom	The opt-out proposal from the December 2024 consultation was not taken forward. The government's report and impact assessment under the Data (Use and Access) Act, published 18 March 2026, assessed four options and endorsed none; legislation is described as not imminent. <i>Getty Images v Stability AI</i> was decided at first instance on 4 November 2025: the secondary infringement claim failed because model weights do not store or reproduce the works, with a limited trade mark finding on older models; Getty has permission to appeal the secondary infringement point.
Japan	Still permissive but conditional: Article 30-4 of the Copyright Act allows training on copyrighted material except where it would unfairly prejudice rightsholders' interests. A non-binding government code on IP protection and transparency in training was consulted in early 2026 and does not amend the statute.
China	Comparatively strict, with no explicit exemption for text-and-data-mining or AI training. Mandatory labelling of AI-generated content has applied since 1 September 2025, and the Supreme People's Court's opinions of 7 September 2026 set fault-based liability for platforms and allow courts to order disclosure of training data, while leaving the legality of training itself open.

Litigation and the fair-use test. The most cited US tracker counted 142 copyright suits against AI companies on 15 September 2026, up from the high thirties two years earlier,

and the milestones to watch are the Third Circuit in *Ross*, the Court of Justice in *Like Company*, the Munich appeal court in *GEMA v OpenAI* and the Court of Appeal in *Getty*. US courts assess fair use through four factors: the purpose and character of the use, the nature of the copyrighted work, the amount and substantiality of the portion used, and the effect on the market for the original work. The rulings so far treat training on lawfully obtained material as strongly transformative and treat piracy, memorization and output reproduction as the exposure.

Practical steps to mitigate risk.

- **License deliberately, and prove provenance.** Prefer data and content that's explicitly licensed for use in AI training or generation. The distinction between lawfully acquired and pirated material was decisive in *Bartz*, and the settlement priced the difference at about USD 3,000 per work.
- **Negotiate contractual protection.** Push for IP indemnity clauses in vendor and licensing agreements rather than assuming the risk sits with the AI provider by default, and cover outputs as well as training, since the largest settlement so far excluded outputs.
- **Test for memorization and output reproduction.** Lyrics, characters and verbatim article text are what the live cases turn on. Build output filtering and reproduction testing into deployment, not only into training due diligence.
- **Track data lineage.** Make copyright provenance a standing part of your AI risk assessments, not a one-time diligence exercise done at the start of a project.
- **Train employees on prompting and uploads.** A large share of practical exposure comes from ordinary employees pasting copyrighted documents, images, or text into prompts without thinking about it - this is a literacy-program topic (see Section 12), not just a legal one.
- **Meet the GPAI training-data transparency obligation.** If you provide general-purpose AI models, the training-data summary from Section 6 and the Code of Practice copyright measures directly overlap with copyright risk management - a legal obligation and a genuine risk-reduction step, now backed by Commission fining powers.

KEY TAKEAWAYS

- Two separate questions sit side by side: does your AI use infringe someone's copyright, and is your AI output protectable at all.
- Exposure appears at five points in the lifecycle: training, fine-tuning, retrieval-augmented generation, prompts and inputs, and inference and outputs.
- Output protectability turns on human authorship. Purely AI-generated content with no meaningful human creative input generally is not protectable; AI-assisted work often is. In the US, typing a prompt alone is not enough, and the Supreme Court declined to review *Thaler v Perlmutter* in March 2026.
- Applicable rules are generally determined by where the copying took place, and the jurisdictions diverge sharply: US fair use worked out case by case; EU copyright law applies plus a training-data transparency duty and two text-and-data-mining exceptions, the broader one subject to rightsholder opt-out; the UK dropped its opt-out proposal and endorsed no option in its March 2026 report; Japan permissive but conditional; China comparatively strict with no explicit exemption and mandatory labelling since September 2025.
- Three US merits rulings so far: *Bartz v Anthropic* (training on lawfully acquired books fair use, pirated library not, USD 1.5bn settlement approved July 2026), *Kadrey v Meta* (fair use on narrow facts), *Thomson Reuters v Ross* (no fair use, Third Circuit pending). Germany's Munich court held memorisation of lyrics to be reproduction outside the TDM exception in *GEMA v OpenAI* and *GEMA v Suno*. The four US fair-use factors: purpose and character of the use, nature of the work, amount and substantiality used, and effect on the market for the original.
- The six mitigations: license deliberately and prove provenance; negotiate IP indemnity covering outputs; test for memorisation and output reproduction; track data lineage as a standing part of risk assessment; train employees on prompting and uploads; and meet the GPAI training-data transparency obligation, now backed by Commission fining powers.

Part 2 self-test

Cover the answers. Say or write your answer in full before you check it: recall you have to construct is worth several times a line you merely recognise. Answers begin on the next page.

1. A US company with no EU office sells a SaaS product with an embedded chatbot to EU customers. In scope or not, and on which trigger?
2. You buy a third-party model, fine-tune it heavily and ship it under your own brand. What changed?
3. Name the four roles the Act assigns and say which carries the most weight.
4. List four of the ten prohibited practices.
5. An employer proposes webcam emotion analysis in meetings to measure engagement. What is the analysis, and what is the fix?
6. What are the two routes to high-risk classification, and how do you test them?
7. Four of the Annex III categories, please.
8. You conclude an Annex III system is not high-risk because it performs a narrow task. What must you do?
9. Name six of the twelve provider obligations for high-risk systems.
10. Which three categories of deployer must complete a fundamental rights impact assessment?
11. A bank deploys a third-party credit-pricing AI. List what the bank owes as deployer.
12. What are the four baseline GPAI provider obligations, and when do they stop applying?
13. What does 10^{25} FLOPS mean in this context, and why is it not a permanent number?
14. Give the five-step working compliance sequence.
15. Three limited-risk transparency obligations.
16. Match the dates: prohibited practices, GPAI provider obligations, transparency and penalties, Annex III high-risk systems, Annex I product-embedded systems.
17. State the three penalty ceilings.
18. Which of the ten governance foundations should be stood up first, and why?
19. Which three of the ten vendor questions belong in the contract rather than an email?
20. Why does one generic AI training module fail the Article 4 obligation?
21. At which five points in the AI lifecycle does copyright exposure arise?
22. Is AI output copyrightable?

Part 2 self-test: answers

1. A US company with no EU office sells a SaaS product with an embedded chatbot to EU customers. In scope or not, and on which trigger?
In scope, as a provider. The third territorial trigger catches a provider or deployer located anywhere in the world whose AI output is used within the EU, regardless of establishment.
2. You buy a third-party model, fine-tune it heavily and ship it under your own brand. What changed?
Your role. Substantially modifying a system or putting it on the market under your own name reclassifies a deployer as a provider, with the full provider obligation set.
3. Name the four roles the Act assigns and say which carries the most weight.
Provider, deployer, importer, distributor. Most of the Act's weight sits on providers.
4. List four of the ten prohibited practices.
Any four of: subliminal or deceptive manipulation causing significant harm; exploiting vulnerability by age, disability or socioeconomic situation; social scoring; individual predictive policing based purely on profiling; emotion inference in the workplace or education; untargeted scraping of facial images; biometric categorisation inferring protected traits; real-time remote biometric identification in public by law enforcement; and, from 2 December 2026, generating non-consensual intimate imagery or child sexual abuse material.
5. An employer proposes webcam emotion analysis in meetings to measure engagement. What is the analysis, and what is the fix?
It falls inside the workplace emotion-recognition prohibition, and the medical or safety carve-out does not apply to a productivity feature. There is no mitigation that brings it back into bounds. The only fix is not building it.
6. What are the two routes to high-risk classification, and how do you test them?
The Annex III use-case list, and being a product or safety component covered by one of the named EU product-safety laws. Run both independently; clearing one does not clear the other.
7. Four of the Annex III categories, please.
Any four of: biometrics; critical infrastructure; education and vocational training; employment and worker management; essential services and benefits; law enforcement; migration, asylum and border control; judicial and democratic processes.
8. You conclude an Annex III system is not high-risk because it performs a narrow task. What must you do?
Write down why, not just that. The carve-out is narrow and fact-specific, and the documented rationale is what you defend the conclusion with later.
9. Name six of the twelve provider obligations for high-risk systems.
Any six of: risk management system; data and data governance; technical documentation; automatic logging; instructions for use; human oversight by design; accuracy, robustness and cybersecurity; quality management system; accessibility; conformity assessment; registration; regulatory cooperation.

10. Which three categories of deployer must complete a fundamental rights impact assessment?
Bodies governed by public law, private entities providing public services, and deployers of two Annex III use cases: creditworthiness evaluation or credit scoring of natural persons (fraud detection excluded) and life and health insurance risk assessment and pricing.
11. A bank deploys a third-party credit-pricing AI. List what the bank owes as deployer.
Obtain and follow the provider's instructions for use; assign competent human oversight of the pricing decisions; complete a fundamental rights impact assessment, since credit assessment is a triggering use case; keep and be ready to produce the logs; monitor and report serious incidents. The vendor's own compliance work does not discharge any of it.
12. What are the four baseline GPAI provider obligations, and when do they stop applying?
Publish a detailed training-data summary; maintain an EU copyright compliance policy; keep technical documentation current; document capabilities and limitations for downstream providers. They do not apply to open-source GPAI providers, unless the model is classified as systemic-risk, which cancels the exemption.
13. What does 10^{25} FLOPS mean in this context, and why is it not a permanent number?
Cumulative training compute above that level is the Act's main proxy for high-impact capability and therefore systemic risk. It is explicitly designed to be reviewed and adjusted as the technology develops.
14. Give the five-step working compliance sequence.
Screen out prohibited practices; inventory and track high-risk AI; run a gap analysis against the full requirement set; register high-risk systems in the EU database; roll out AI literacy training.
15. Three limited-risk transparency obligations.
Providers must design systems so people are told they are interacting with AI; deployers using emotion recognition must notify the people being assessed; deployers must disclose deep fakes and AI-generated content.
16. Match the dates: prohibited practices, GPAI provider obligations, transparency and penalties, Annex III high-risk systems, Annex I product-embedded systems.
2 February 2025; 2 August 2025; 2 August 2026; 2 December 2027; 2 August 2028. The last two are the dates set by Regulation (EU) 2026/1744; the original Act said 2 August 2026 and 2 August 2027.
17. State the three penalty ceilings.
Prohibited practices: 7% of global annual turnover or EUR 35m. High-risk provider and deployer obligations: 3% or EUR 15m. Incorrect or misleading information to regulators: 1% or EUR 7.5m. Whichever is higher in each case.
18. Which of the ten governance foundations should be stood up first, and why?
The live AI inventory. Most of the rest depends on knowing what you have, and shadow AI adoption is usually larger than leadership assumes.
19. Which three of the ten vendor questions belong in the contract rather than an email?
IP indemnity, data-use rights (whether they train on your data), and output ownership.

20. Why does one generic AI training module fail the Article 4 obligation?

Because Article 4, as amended in 2026, requires measures to support the development of AI literacy for the people involved, and auditors look for evidence that training differs by audience and risk exposure. A single module cannot demonstrate that, and it cannot serve layer four, the system-specific operational training mandatory for people operating a high-risk system.

21. At which five points in the AI lifecycle does copyright exposure arise?

Training, fine-tuning, retrieval-augmented generation, prompts and inputs, and inference and outputs.

22. Is AI output copyrightable?

It depends on human authorship. Purely AI-generated content with no meaningful human creative input generally is not protectable in most jurisdictions; AI-assisted work often is. The dividing line is whether a human's own creative choices are perceptible in the result.

PART 3

The Assessment Suite

Six tools, 68 steps and 337 questions, with the scoring model that turns the answers into a verdict.

The six tools share one stepper, one country and region list of 209 entries, and one result format: a headline level, a list of factors that drove it, and an export. What differs is the model underneath. Read the cheat sheet for a tool before reading its question bank: the questions only make sense once you know what the scoring does with the answers.

How the six fit together. The Privacy Assessment is the front door and the only one that routes to another tool: it screens a process end to end and, on the Article 35(3) trigger count, hands over to the Full DPIA. The Legitimate Interest Test is the side door taken when the lawful basis is Article 6(1)(f), and the Privacy Assessment flags its absence as a factor. The AI Risk Assessment runs the EU AI Act screen over the same process when an AI system is involved. The Incident tool runs after the fact, on a breach rather than a plan. The Third-Party Security Assessment runs on a vendor rather than a process.

One design decision runs through three of them. The DPIA, the Third-Party Security Assessment and the readiness model in Part 4 all combine two dimensions through an explicit lookup table rather than multiplying them. A product lets a strong score on one axis cancel a critical score on the other: maximum severity at limited likelihood (4 x 2) would rank below significant/significant (3 x 3), and strong vendor controls would fully erase a critical amount of data at stake. The lookup tables set floors instead, so nothing at maximum severity ever falls below High, and nothing at critical inherent risk ever falls below Medium.

SOURCES [3] [7] [8] [9] [12] [14] [15] [19]

Privacy Assessment

Screen a process end to end: what data, whose, for what purposes, on what lawful basis, with what retention, who it is shared with and where it goes. It gives a risk level and says whether a full DPIA is needed. If it is, it hands straight over.

WHAT IT IS FOR Screen a process end to end and decide whether a full DPIA is needed.

SHAPE 11 steps, 62 questions. Steps 3 onward are gated on the screening answer: if no personal data is processed, the assessment ends with a recorded Not Applicable result rather than a risk level.

WHAT IT RETURNS A risk level (Low / Medium / High, or Not Applicable), a DPIA verdict (Required / Recommended / Not required), the list of Article 35(3) triggers selected, and a factor list with severities.

HOW THE SCORING WORKS

- The level starts at Low and only ever escalates. No answer can pull it back down, which is why a single High factor decides the outcome.
- Escalates to High: special-category data with no Article 9 condition selected; automated decision-making with significant effect; large-scale or systematic monitoring; vulnerable individuals combined with special-category data; an international transfer with no safeguard identified; a transfer impact assessment triggered by supplier characteristics; potential bias in targeting; sharing with competitors.
- Escalates to Medium: special-category data; no lawful basis recorded; legitimate interests without a balancing test; vulnerable individuals alone; 10,000 or more records; retention not fully defined; no privacy notice or unconfirmed coverage; extracts or reports without documented controls; system of record; application being decommissioned; employee data with no labour law check; third parties involved; unclear transfer status; tracking or profiling technology; data sourced from third parties or public sources.
- DPIA verdict: two or more Article 35(3) triggers makes it Required. One trigger makes it Required at High level, otherwise Recommended. No triggers makes it Recommended at High or Medium level, otherwise Not required.

WHERE PEOPLE GET IT WRONG

- Special-category data cannot run on an Article 6 basis alone. Selecting it without an Article 9 condition is the fastest route to High.
- Employees count as vulnerable, because they cannot freely refuse. That single fact moves many ordinary HR processes to Medium.
- Remote access from outside the region is a transfer, including support and administration access. 'Not sure' on transfers is itself scored.
- A labour law check is separate from anything the GDPR requires. A missing works council agreement can stop processing whatever the assessment says.

SOURCES [3] [5] [7] [13]

The question bank, step by step

Step 1 of 11 • Project information

Process or project name SHORT TEXT

Describe the project or planned activity: what it does, for whom, and why it is needed LONG TEXT

What type of project is this? CHOOSE ANY

OPTIONS General project · Marketing project · Business analytics project · Involves an AI system

Is this a new activity or a change to an existing one? CHOOSE ONE

OPTIONS New activity · Changed activity · Not sure

When will it become operational? (leave blank if already live or not set) DATE

Which countries or regions does this process apply to? CHOOSE ANY

OPTIONS 209 entries, listed in Appendix A.

FOLLOW-UP Specify the other country or countries

Which business area does this belong to? CHOOSE ONE

OPTIONS HR & People · Marketing & Sales · Customer Service · Finance · IT & Technology · Supply Chain & Operations · Legal & Compliance · Other

FOLLOW-UP Specify the business area

Who owns this project? (name or role of the business owner, and any other team contacts)

SHORT TEXT

Reference numbers (ticket, project or demand IDs) so this assessment can be traced back

SHORT TEXT

Step 2 of 11 • Screening

Will personal data be processed - any information relating to an identified or identifiable individual? YES / NO

FOLLOW-UP a follow-up note, worded according to the answer

Step 3 of 11 • Whose data, and what data

STEP SHOWN WHEN `hasPersonalData === "Yes"`

Whose personal data will be processed? CHOOSE ANY

OPTIONS Customers · Consumers · Employees and contractors · Job candidates · Suppliers and business partners · Website or app users · Children · Other

FOLLOW-UP Specify the other data subjects

What categories of personal data will be processed? CHOOSE ANY

OPTIONS Basic identity and personal characteristics (name, date of birth, nationality) · Private contact information (home address, personal email, personal phone) · Business contact information (job title, work email, work phone, department) · Official identification (passport, national ID, tax or social security number) · Employment administration data (contract, working time, absence, leavers) · Compensation and benefits (salary, bonuses, pension, deductions) · Education, qualifications and training records · Work activities and performance (objectives, appraisals, disciplinary records) · Bank and card data (account details, payment card data) · Financial and credit data (credit checks, financial history) · Assigned company assets (devices, access badges, company car, fines) · Travel and expense data · Family relations and dependants · Location, movement or telematics data · Logs, recordings and monitoring data (CCTV, call recordings, system logs) · Technical identifiers, authentication and authorisation data · Social media and internet activity · Lifestyle and preferences · Workplace safety and incident data · Background checks (employment, education, criminal record) · Special category data (health, genetic, biometric data used to uniquely identify a person, racial or ethnic origin, religious or philosophical beliefs, political opinion, trade union membership, sex life or orientation) · Criminal offence data · Other

FOLLOW-UP Specify the other data categories

Are any of the individuals vulnerable? Select all that apply - leave blank if none. CHOOSE ANY

OPTIONS Children (under 13) · Employees and other staff members · Patients, or people with a mental or physical illness · Elderly people · People in financial hardship or debt · Asylum seekers or people in a dependent position · Other

FOLLOW-UP Specify the other vulnerable group

Apart from personal data, is any business-critical data processed - evidence of business decisions, contracts, activities or transactions that may be needed for audit or legal purposes?

CHOOSE ONE

OPTIONS Yes · No · Not sure

FOLLOW-UP What business-critical data, and which retention rules apply to it?

Employee data is involved. Have labour law requirements, and any works council or employee representative involvement, been checked?

CHOOSE ONE

OPTIONS Yes · No · Not yet · Not required in the countries concerned

FOLLOW-UP a follow-up note, worded according to the answer

SHOWN WHEN `hasEmployeeData(a)`

Roughly how many individuals will be involved?

CHOOSE ONE

OPTIONS Fewer than 100 · 100 to 1,000 · 1,000 to 10,000 · 10,000 to 100,000 · More than 100,000 · Not yet known

Step 4 of 11 · Purposes, lawful basis & retention

STEP SHOWN WHEN `hasPersonalData === "Yes"`

Personal data cannot be kept indefinitely - every purpose needs its own retention period, defined before processing starts.

What are the purposes of processing?

CHOOSE ANY

OPTIONS Service delivery or contract performance · HR administration and workforce management · Recruitment and candidate assessment · Payroll, benefits and expenses · Customer service and support · Marketing, advertising and audience analytics · Sales, CRM and account management · Product or service improvement and research · Business intelligence and reporting · Legal and regulatory compliance · Security, fraud prevention and investigations · Health, safety and workplace incident management · Supplier and third-party management · Other

FOLLOW-UP Specify the other purpose(s)

List each purpose with its retention period. Be specific - "business analytics" is not a purpose.

LONG TEXT

Is a retention period defined and documented for every purpose above?

CHOOSE ONE

OPTIONS Yes · Partially · No

FOLLOW-UP Specify the retention period(s) and how deletion is enforced

What is the lawful basis for processing (Art. 6)?

CHOOSE ANY

OPTIONS Consent of the individual · Necessary for the performance of a contract with the individual · Necessary for compliance with a legal obligation · Necessary to protect vital interests · Necessary for a task carried out in the public interest or official authority · Necessary for the legitimate interests of the organization or a third party

Which Art. 9 condition applies to the special category data?

CHOOSE ANY

OPTIONS Explicit consent of the individual · Obligations and rights in employment, social security and social protection law · Protection of vital interests where the individual cannot consent · Processing relating to members of a not-for-profit body · Data manifestly made public by the individual · Establishment, exercise or defence of legal claims · Substantial public interest, on the basis of law · Preventive or occupational medicine, assessment of working capacity, or health or social care · Public interest in the area of public health · Archiving, scientific or historical research, or statistical purposes

SHOWN WHEN `computeSpecialCategory(a)`

Could the purposes be achieved using de-identified data instead?

CHOOSE ONE

OPTIONS Yes - and we will · Yes, partially · No - identifiable data is necessary · Not yet assessed

FOLLOW-UP Explain why identifiable data is necessary, or what will be de-identified

Is this purpose covered by an existing privacy notice?

CHOOSE ONE

OPTIONS Yes · No · Not sure

FOLLOW-UP a follow-up note, worded according to the answer

Step 5 of 11 • Access, systems & outputs**STEP SHOWN WHEN** `hasPersonalData === "Yes"`

Which departments, functions or roles will have access to the personal data, and why does each need it? LONG TEXT

Which systems, applications or services will hold or process the data? LONG TEXT

Will any system here act as the system of record - the authoritative and only storage location for this data? CHOOSE ONE

OPTIONS Yes · No · Not sure

FOLLOW-UP Which system, and are retention and deletion rules defined in it?

Does this require decommissioning an old application? CHOOSE ONE

OPTIONS Yes · No · Not sure

FOLLOW-UP What happens to the data in the old system - migrated, archived or securely destroyed?

Is there a mobile component (mobile app, wearable, handheld device)? CHOOSE ONE

OPTIONS Yes · No · Not sure

FOLLOW-UP Describe the mobile component

Can personal data be extracted to other systems or formats (spreadsheet, email, PDF)? CHOOSE ONE

OPTIONS Yes · No · Not sure

FOLLOW-UP Who can extract data, and what controls apply to the extracts?

Does it allow self-made or automated reports containing personal data? CHOOSE ONE

OPTIONS Yes · No · Not sure

FOLLOW-UP Who can build reports, and who receives them?

What controls govern report creation, distribution, storage and deletion? LONG TEXT

SHOWN WHEN `automatedReports === "Yes" || dataExtracts === "Yes"`

Step 6 of 11 • Third parties & transfers**STEP SHOWN WHEN** `hasPersonalData === "Yes"`

Will any organization outside your own come into contact with the personal data? YES / NO

FOLLOW-UP Who are they, and what will they do with the data?

Are any of them acting on your behalf as a processor? YES / NO

FOLLOW-UP Is a data processing agreement in place with each of them?

SHOWN WHEN `thirdPartySharing === "Yes"`

In which countries will they process or access the data (including hosting)? SHORT TEXT

SHOWN WHEN `processorsInvolved === "Yes"`

Will personal data be transferred outside your home region (remote access counts as a transfer)?

CHOOSE ONE

OPTIONS No · Yes · Not sure · Not applicable

Which safeguard will make that transfer lawful? CHOOSE ANY

OPTIONS Adequacy decision · EU-US Data Privacy Framework (certified US recipient) · Standard contractual clauses (controller to processor) · Standard contractual clauses (controller to controller) · Binding corporate rules · Approved code of conduct · Approved certification mechanism · Approved ad hoc contractual clauses · UK international data transfer addendum · Derogation for a specific situation · None identified yet

FOLLOW-UP Which countries is the data transferred to?

SHOWN WHEN `transfersOutside === "Yes"`

Do any of these apply to the supplier? Each one points to a transfer impact assessment. Not asked where the transfer rests only on an adequacy decision or the EU-US Data Privacy Framework. CHOOSE ANY

OPTIONS The supplier is a telecommunications carrier or internet service provider · The supplier provides a communications service (email, messaging, video) · The supplier provides cloud storage available to the general public · The supplier provides remote computing services (virtual machines, AI, financial processing) · The supplier can access communications between our users, or between us and our users · The supplier is wholly or partly state-owned · The supplier processes or stores financial or payment information · The supplier or its subcontractors store data in a country without an adequacy decision

SHOWN WHEN tiaNeeded(transfersOutside, transferSafeguards)

Step 7 of 11 • Marketing

STEP SHOWN WHEN hasPersonalData === "Yes" && (projectTypes || []).indexOf("Marketing project") !== -1

Does the activity use any technology for tracking, profiling, aggregating or predicting behaviour? CHOOSE ANY

OPTIONS Cookies · Pixel tags or web beacons · Browser fingerprinting · Analytics tools · Profiling or audience-segmentation tools · Movement sensors · Cameras · Location tracking · Automated decision-making or algorithmic targeting · None of these · Other

FOLLOW-UP Describe the technology in full - avoid abbreviations

Which social media or online networks are involved, and what is each party's data protection role? LONG TEXT

Is there any intention to use the data later for something outside the original purpose? Describe it. LONG TEXT

If the processing relies on consent, how is it obtained, layered, recorded and withdrawn? LONG TEXT

How could this activity be perceived by people outside the organization if the details became public? LONG TEXT

Describe the consumer or customer experience: profiles created, accounts, forms, and what individuals see. LONG TEXT

Is there potential bias in the behavioural or targeted advertising? CHOOSE ANY

OPTIONS Race or ethnic origin · Gender · Age · Physical characteristics · Socioeconomic status · Health status · No identified bias · Other

FOLLOW-UP Describe the bias and how it will be addressed

Have the chosen suppliers ever been sanctioned or audited by a supervisory authority? CHOOSE ONE

OPTIONS No · Yes · Not sure

FOLLOW-UP Which supplier, and what was the outcome?

Step 8 of 11 • Business analytics

STEP SHOWN WHEN hasPersonalData === "Yes" && (projectTypes || []).indexOf("Business analytics project") !== -1

Describe every source of data used, including the systems the data is pulled from and how any combined dataset was assembled. LONG TEXT

Is any data sourced through a relationship with third parties (wholesalers, data providers, B2B platforms, agencies)? YES / NO

FOLLOW-UP Which parties, and on what contractual basis?

Is any data sourced from independent platforms or publicly accessible sources? YES / NO

FOLLOW-UP Which sources, and does their licensing permit this use?

Does the data include competitor product data (in any form, including image recognition)?

YES / NO

FOLLOW-UP Describe the data and which roles can access it

Which departments or roles will have access to the competitor product data, and to the analytics output? LONG TEXT

SHOWN WHEN `competitorData === "Yes"`

What controls apply to intermediate extracts and exchanges before the final analytics output?

LONG TEXT

Will the data be shared with a parent company or affiliates? YES / NO

FOLLOW-UP Which entities, and under what agreement?

Will the data be shared with competitors (e.g. an open-innovation or industry initiative)? YES / NO

FOLLOW-UP Describe the arrangement and any competition-law review

Step 9 of 11 • Ethics & fairness

STEP SHOWN WHEN `hasPersonalData === "Yes"`

Beyond strict legal compliance: whether the processing is fair, proportionate and defensible to the people whose data it is.

Does the use of the data benefit the individuals as much as it benefits the organization?

CHOOSE ONE

OPTIONS Yes · No · Not applicable

FOLLOW-UP a follow-up note, worded according to the answer

Is there an active effort to minimise the data used over time? CHOOSE ONE

OPTIONS Yes · No · Not applicable

FOLLOW-UP Explain

Are the insights meaningful over the long term, or a one-off observation? CHOOSE ONE

OPTIONS Meaningful long term · One-off observation · Not sure

Is the use of data transparent and inclusive? CHOOSE ONE

OPTIONS Yes · No · Not applicable

FOLLOW-UP Explain how

How do you make sure the processing does not negatively affect minority or under-represented groups? LONG TEXT

How would individuals react if they knew every detail of this processing? What complaints can you anticipate? LONG TEXT

Step 10 of 11 • DPIA screening

STEP SHOWN WHEN `hasPersonalData === "Yes"`

These are the Art. 35(3) criteria. Two or more normally means a full DPIA is required.

Which of these apply to the processing? CHOOSE ANY

OPTIONS Evaluation, scoring, profiling or prediction · Automated decision-making with a legal or similarly significant effect · Systematic monitoring, including of a publicly accessible area or of employees · Special category data, criminal offence data, or data of a highly personal nature · Large-scale processing · Matching or combining datasets · Data concerning vulnerable individuals (children, employees, patients, the elderly) · Innovative use, or a new technology or organisational solution · Processing that prevents individuals from exercising a right, using a service, or entering a contract

FOLLOW-UP Any national blacklist or whitelist entry, or sector-specific requirement, that applies

Is this processing already recorded in your data inventory / RoPA? YES / NO

FOLLOW-UP When will it be added?

Step 11 of 11 • Controls already in place

STEP SHOWN WHEN `hasPersonalData === "Yes"`

Which data protection controls are already in place for this processing? CHOOSE ANY

OPTIONS Data minimisation (unnecessary fields removed) · Purpose limitation (processing scope restricted) · Access rights management and least privilege · Access logging and monitoring · Encryption in transit and at rest · Pseudonymisation · Pseudonymisation · Anonymisation or aggregation for secondary uses · Data masking in non-production environments · Data processing agreement with the supplier · Data protection clauses in third-party contracts · Intra-group data processing agreement · Appropriate safeguards for transfers outside the home region · Legitimate interest balancing test completed · Processing recorded in the RoPA · Retention and deletion rules implemented in the system · Accuracy and data quality checks · Human review of automated or AI-supported outputs · Restrictions on profiling, monitoring or automated decisions · Privacy notice covering this processing · Consent or preference management · Mechanisms for individuals to exercise their rights · Supplier due diligence · Measures tailored to employees or other vulnerable individuals · Backup and tested restore procedure · Security testing or penetration testing · Training for staff handling this data · Incident response and breach notification procedure · DPIA performed · Prior consultation with the supervisory authority

FOLLOW-UP Any other control worth recording

Privacy Assessment: 11 steps, 62 questions.

Full DPIA

The full assessment that follows when the Privacy Assessment says a DPIA is needed: necessity and proportionality, individual rights, transfers, the harms the processing could cause individuals rated before and after mitigation, and the three feared security events, all plotted on one severity × likelihood matrix.

WHAT IT IS FOR The full assessment that follows when the Privacy Assessment says a DPIA is needed.

SHAPE 11 steps, 60 questions. Steps 7, 8 and 9 are the same four questions asked three times, once per feared event: illegitimate access, unwanted modification, data disappearance.

WHAT IT RETURNS A risk level per feared event, the highest of the three, an inherent and a residual overall level, a DPIA status, and a prior-consultation flag.

HOW THE SCORING WORKS

- Every risk is rated on two four-point scales. Severity: Negligible, Limited, Significant, Maximum. Likelihood: Negligible, Limited, Significant, Maximum.
- The two combine through a fixed 4 x 4 matrix, not a product. Rows are severity, columns likelihood:

SEVERITY \ LIKELIHOOD	NEGLIGIBLE	LIMITED	SIGNIFICANT	MAXIMUM
Negligible	Low	Low	Low	Medium
Limited	Low	Medium	Medium	High
Significant	Medium	High	High	Very High
Maximum	High	High	Very High	Very High

Severity and likelihood scales in full: Negligible - no impact, or a mere inconvenience individuals will overcome without difficulty; Limited - significant inconveniences individuals can overcome despite a few difficulties; Significant - significant consequences individuals should overcome, but with serious difficulties; Maximum - significant or irreversible consequences individuals may not overcome.

- DPIA status: two or more triggers makes it Required; one makes it Recommended.
- Prior consultation with the supervisory authority is flagged when residual risk is High or Very High and the residual risk was answered as not acceptable.

WHERE PEOPLE GET IT WRONG

- Nothing at Maximum severity ever falls below High, whatever the likelihood. That floor is the entire reason the matrix exists rather than a multiplication.
- Inherent and residual are asked separately, so an unchanged residual level is itself a finding: it says the mitigation measures did not move anything.
- The three feared events come from the EBIOS-style method and are deliberately exhaustive of what can go wrong with data: someone sees it who should not, it is changed, or it is gone.

SOURCES [3] [5] [7] [12]

The question bank, step by step

Step 1 of 11 • Scope of the processing

Processing activity or project name SHORT TEXT

Describe the processing: what it does, for whom, and why it is needed LONG TEXT

Is this a new activity or a change to an existing one? CHOOSE ONE

OPTIONS New activity · Changed activity · Not sure

Planned go-live date (leave blank if not set) DATE

Which countries or regions does the processing cover? CHOOSE ANY

OPTIONS 209 entries, listed in Appendix A.

FOLLOW-UP Specify the other country or countries

What is your organization's role? CHOOSE ONE

OPTIONS Controller · Joint controller · Processor · Not sure

Which business area owns this? CHOOSE ONE

OPTIONS HR & People · Marketing & Sales · Customer Service · Finance · IT & Technology · Supply Chain & Operations · Legal & Compliance · Other

FOLLOW-UP Specify the business area

Step 2 of 11 · Why a DPIA is needed

These are the Art. 35(3) criteria as expanded by the European guidance. Meeting two or more normally means a DPIA is required; one may still warrant it depending on the processing.

Which criteria does this processing meet? CHOOSE ANY

OPTIONS Evaluation, scoring, profiling or prediction · Automated decision-making with a legal or similarly significant effect · Systematic monitoring, including of a publicly accessible area or of employees · Special category data, criminal offence data, or data of a highly personal nature · Large-scale processing · Matching or combining datasets · Data concerning vulnerable individuals (children, employees, patients, the elderly) · Innovative use, or a new technology or organisational solution · Processing that prevents individuals from exercising a right, using a service, or entering a contract

FOLLOW-UP Any national blacklist/whitelist entry or sector-specific requirement that applies

Which specific aspect of the processing makes it high risk? Name the feature or combination of factors, who it affects, and why it could interfere with their rights or reasonable expectations. Do not repeat the full processing description. LONG TEXT

Step 3 of 11 · Necessity & proportionality

Art. 35(7)(b) requires an assessment of whether the processing is necessary and proportionate to its purpose. Describe it in your own words - these narratives are the substance of the DPIA.

What are the specified, explicit and legitimate purposes of the processing? LONG TEXT

Which lawful basis or bases apply (Art. 6)? CHOOSE ANY

OPTIONS Consent of the individual · Necessary for the performance of a contract with the individual · Necessary for compliance with a legal obligation · Necessary to protect vital interests · Necessary for a task carried out in the public interest or official authority · Necessary for the legitimate interests of the organization or a third party

Does the processing involve special category or criminal offence data? YES / NO

Which Art. 9 condition applies? CHOOSE ONE

OPTIONS Not applicable - no special category data · Explicit consent of the individual · Obligations and rights in employment, social security and social protection law · Protection of vital interests where the individual cannot consent · Processing relating to members of a not-for-profit body · Data manifestly made public by the individual · Establishment, exercise or defence of legal claims · Substantial public interest, on the basis of law · Preventive or occupational medicine, assessment of working capacity, or health or social care · Public interest in the area of public health · Archiving, scientific or historical research, or statistical purposes

SHOWN WHEN `specialCategory === "Yes"`

Legitimacy - why is this processing lawful, fair and justified for these purposes? LONG TEXT

Proportionality - why is the data adequate, relevant and limited to what is necessary? What less intrusive alternatives were considered? LONG TEXT

Data quality - how is the data kept accurate and up to date? LONG TEXT

Is a retention period defined and documented for every purpose? CHOOSE ONE

OPTIONS Yes · Partially · No

FOLLOW-UP Specify the retention period(s) and how deletion is enforced

Is the data de-identified in any way? CHOOSE ONE

OPTIONS Anonymised · Pseudonymised · Partially - some fields only · No · Not possible for this purpose

Step 4 of 11 · Transparency & individual rights

Are individuals informed through a privacy notice that covers this processing? YES / NO

FOLLOW-UP a follow-up note, worded according to the answer

Transparency - what are individuals told, and when? LONG TEXT

If consent is a basis, how is it captured and withdrawn? CHOOSE ONE

OPTIONS Not applicable - consent is not a basis here · Captured explicitly, and can be withdrawn as easily as it was given · Captured, but withdrawal is harder than giving it · Not yet implemented

Can access and portability requests be fulfilled for this processing? YES / NO

FOLLOW-UP How, and what is the gap if not?

Can rectification and erasure requests be fulfilled? YES / NO

FOLLOW-UP How, and what is the gap if not?

Can restriction and objection requests be fulfilled? YES / NO

FOLLOW-UP How, and what is the gap if not?

Have the views of the individuals affected, or their representatives, been sought? (Art. 35(9))

CHOOSE ONE

OPTIONS Yes · Not appropriate for this processing · Not yet · Not sure

FOLLOW-UP a follow-up note, worded according to the answer

Step 5 of 11 · Systems, suppliers & transfers

Which systems, applications or physical assets hold or process the data? LONG TEXT

Are any processors, suppliers or subcontractors involved? YES / NO

FOLLOW-UP What do they do, and is a data processing agreement in place?

Where is the data hosted? CHOOSE ONE

OPTIONS Within the home country · Within the home region (e.g. EEA) · Outside the home region · Mixed · Not sure

Is personal data transferred outside your home region? CHOOSE ONE

OPTIONS No · Yes · Not sure

Which transfer mechanism applies? CHOOSE ANY

OPTIONS Adequacy decision · EU-US Data Privacy Framework · Standard contractual clauses · Binding corporate rules · Derogation for a specific situation · None identified yet

SHOWN WHEN `transfersOutside === "Yes"`

Has a transfer impact assessment been completed? YES / NO

FOLLOW-UP What supplementary measures were identified?

SHOWN WHEN `tiaNeeded(transfersOutside, transferMechanism)`

Step 6 of 11 • Risks to individuals

Art. 35(7)(c) asks for the risks to the rights and freedoms of individuals, which is wider than security. Record the reasonably foreseeable consequences for the people whose data this is, then rate the worst credible case as if no safeguards were in place. The three security risks that follow are rated separately, against the controls already implemented.

How could the processing adversely affect individuals? CHOOSE ANY

OPTIONS Loss of confidentiality, or of control over personal data · Identity theft, fraud or financial loss · Discrimination, unfair treatment or exclusion · Decisions based on inaccurate or incomplete data · Loss of access to employment, services, opportunities or benefits · Excessive monitoring, profiling or surveillance · Manipulation, loss of autonomy or a chilling effect on behaviour · Reputational damage, embarrassment or distress · Physical harm or a threat to personal safety · Exposure of sensitive information · Inability to exercise data protection rights · Use of data beyond what individuals would reasonably expect · Re-identification of anonymised or pseudonymised data · Unauthorised access, disclosure, alteration, loss or destruction · Inappropriate automated decisions, or over-reliance on AI-generated outputs · Disproportionate effect on vulnerable individuals or particular groups · Other

FOLLOW-UP Specify the other harm

Describe how each selected harm could arise in this processing, and who it would fall on.

LONG TEXT

Inherent severity: how serious would the impact be before any mitigation? Consider sensitivity, permanence, reversibility, the number and vulnerability of people affected, and whether several minor effects combine. CHOOSE ONE

OPTIONS Negligible - no impact, or a mere inconvenience individuals will overcome without difficulty · Limited - significant inconveniences individuals can overcome despite a few difficulties · Significant - significant consequences individuals should overcome, but with serious difficulties · Maximum - significant or irreversible consequences individuals may not overcome

Inherent likelihood: how likely is it before any mitigation? Consider scale, frequency, third parties and transfers, reliance on manual steps, new technology, and how attractive the data is.

CHOOSE ONE

OPTIONS Negligible - it does not seem possible for the identified risk sources to realise the threat · Limited - it seems difficult for the identified risk sources to realise the threat · Significant - it seems possible for the identified risk sources to realise the threat · Maximum - it seems extremely easy for the identified risk sources to realise the threat

Justify both ratings from the evidence you have. LONG TEXT

Step 7 of 11 • Risk 1 of 3 - illegitimate access to data

The first of the three feared events: someone who should not see the data gains access to it.

Which risk sources could cause unauthorized people to see the data? CHOOSE ANY

OPTIONS Internal staff acting accidentally · Internal staff acting deliberately · External people acting accidentally · External people acting deliberately · A supplier, processor or subcontractor · Hardware (device, media, network equipment) · Software (application, operating system, misconfiguration) · Non-human sources (fire, flood, power loss, malware outbreak)

Which threats are realistic for this processing? CHOOSE ANY

OPTIONS Account or password theft · Phishing or social engineering · Malware or ransomware · Lost or stolen device or media with unencrypted content · Unauthorized physical access to a device or location · System failure exposing stored data · Excessive or stale access rights · Data sent to the wrong recipient · Insecure data extract, export or interface · Fraudulent or malicious data subject request · Backup failure or accidental deletion · Supplier or subcontractor security failure

What would the impact on individuals be if this happened? LONG TEXT

Severity - how serious would the impact on individuals be? CHOOSE ONE

OPTIONS Negligible - no impact, or a mere inconvenience individuals will overcome without difficulty · Limited - significant inconveniences individuals can overcome despite a few difficulties · Significant - significant consequences individuals should overcome, but with serious difficulties · Maximum - significant or irreversible consequences individuals may not overcome

Likelihood: how easily could this happen with the controls already implemented? Do not count planned controls. CHOOSE ONE

OPTIONS Negligible - it does not seem possible for the identified risk sources to realise the threat · Limited - it seems difficult for the identified risk sources to realise the threat · Significant - it seems possible for the identified risk sources to realise the threat · Maximum - it seems extremely easy for the identified risk sources to realise the threat

Step 8 of 11 · Risk 2 of 3 - unwanted modification of data

The second feared event: the data is altered, corrupted or replaced when it should not be.

Which risk sources could cause the data to be changed without authorization? CHOOSE ANY

OPTIONS Internal staff acting accidentally · Internal staff acting deliberately · External people acting accidentally · External people acting deliberately · A supplier, processor or subcontractor · Hardware (device, media, network equipment) · Software (application, operating system, misconfiguration) · Non-human sources (fire, flood, power loss, malware outbreak)

Which threats are realistic for this processing? CHOOSE ANY

OPTIONS Account or password theft · Phishing or social engineering · Malware or ransomware · Lost or stolen device or media with unencrypted content · Unauthorized physical access to a device or location · System failure exposing stored data · Excessive or stale access rights · Data sent to the wrong recipient · Insecure data extract, export or interface · Fraudulent or malicious data subject request · Backup failure or accidental deletion · Supplier or subcontractor security failure

What would the impact on individuals be if this happened? LONG TEXT

Severity - how serious would the impact on individuals be? CHOOSE ONE

OPTIONS Negligible - no impact, or a mere inconvenience individuals will overcome without difficulty · Limited - significant inconveniences individuals can overcome despite a few difficulties · Significant - significant consequences individuals should overcome, but with serious difficulties · Maximum - significant or irreversible consequences individuals may not overcome

Likelihood: how easily could this happen with the controls already implemented? Do not count planned controls. CHOOSE ONE

OPTIONS Negligible - it does not seem possible for the identified risk sources to realise the threat · Limited - it seems difficult for the identified risk sources to realise the threat · Significant - it seems possible for the identified risk sources to realise the threat · Maximum - it seems extremely easy for the identified risk sources to realise the threat

Step 9 of 11 · Risk 3 of 3 - data disappearance

The third feared event: the data is deleted, lost or cannot be accessed when it is needed.

Which risk sources could cause the data to be lost or become unavailable? CHOOSE ANY

OPTIONS Internal staff acting accidentally · Internal staff acting deliberately · External people acting accidentally · External people acting deliberately · A supplier, processor or subcontractor · Hardware (device, media, network equipment) · Software (application, operating system, misconfiguration) · Non-human sources (fire, flood, power loss, malware outbreak)

Which threats are realistic for this processing? CHOOSE ANY

OPTIONS Account or password theft · Phishing or social engineering · Malware or ransomware · Lost or stolen device or media with unencrypted content · Unauthorized physical access to a device or location · System failure exposing stored data · Excessive or stale access rights · Data sent to the wrong recipient · Insecure data extract, export or interface · Fraudulent or malicious data subject request · Backup failure or accidental deletion · Supplier or subcontractor security failure

What would the impact on individuals be if this happened? LONG TEXT

Severity - how serious would the impact on individuals be? CHOOSE ONE

OPTIONS Negligible - no impact, or a mere inconvenience individuals will overcome without difficulty · Limited - significant inconveniences individuals can overcome despite a few difficulties · Significant - significant consequences individuals should overcome, but with serious difficulties · Maximum - significant or irreversible consequences individuals may not overcome

Likelihood: how easily could this happen with the controls already implemented? Do not count planned controls. CHOOSE ONE

OPTIONS Negligible - it does not seem possible for the identified risk sources to realise the threat · Limited - it seems difficult for the identified risk sources to realise the threat · Significant - it seems possible for the identified risk sources to realise the threat · Maximum - it seems extremely easy for the identified risk sources to realise the threat

Step 10 of 11 • Mitigation measures

Record implemented and planned measures separately. A planned measure does not lower the security ratings above. It can count towards the residual rating on the next step, but the result then flags that the rating depends on work not yet done.

Which measures are already implemented and operating? CHOOSE ANY

OPTIONS Data minimisation (unnecessary fields removed) · Purpose limitation (processing scope restricted) · Access rights management and least privilege · Access logging and monitoring · Encryption in transit and at rest · Pseudonymisation · Pseudonymisation · Anonymisation or aggregation for secondary uses · Data masking in non-production environments · Data processing agreement with the supplier · Data protection clauses in third-party contracts · Intra-group data processing agreement · Appropriate safeguards for transfers outside the home region · Legitimate interest balancing test completed · Processing recorded in the RoPA · Retention and deletion rules implemented in the system · Accuracy and data quality checks · Human review of automated or AI-supported outputs · Restrictions on profiling, monitoring or automated decisions · Privacy notice covering this processing · Consent or preference management · Mechanisms for individuals to exercise their rights · Supplier due diligence · Measures tailored to employees or other vulnerable individuals · Backup and tested restore procedure · Security testing or penetration testing · Training for staff handling this data · Incident response and breach notification procedure · DPIA performed · Prior consultation with the supervisory authority

FOLLOW-UP Any other implemented measure worth recording

Which measures are planned but not yet implemented? CHOOSE ANY

OPTIONS Data minimisation (unnecessary fields removed) · Purpose limitation (processing scope restricted) · Access rights management and least privilege · Access logging and monitoring · Encryption in transit and at rest · Pseudonymisation · Pseudonymisation · Anonymisation or aggregation for secondary uses · Data masking in non-production environments · Data processing agreement with the supplier · Data protection clauses in third-party contracts · Intra-group data processing agreement · Appropriate safeguards for transfers outside the home region · Legitimate interest balancing test completed · Processing recorded in the RoPA · Retention and deletion rules implemented in the system · Accuracy and data quality checks · Human review of automated or AI-supported outputs · Restrictions on profiling, monitoring or automated decisions · Privacy notice covering this processing · Consent or preference management · Mechanisms for individuals to exercise their rights · Supplier due diligence · Measures tailored to employees or other vulnerable individuals · Backup and tested restore procedure · Security testing or penetration testing · Training for staff handling this data · Incident response and breach notification procedure · DPIA performed · Prior consultation with the supervisory authority

FOLLOW-UP For each planned measure, who owns it and when will it be in place?

Step 11 of 11 • Residual risk & conclusion

Rate the risk again assuming every agreed measure is implemented and operating. Where a measure is incomplete, uncertain or untested, do not assume it works.

Residual severity: how serious would the impact be with every agreed measure in place?

CHOOSE ONE

OPTIONS Negligible - no impact, or a mere inconvenience individuals will overcome without difficulty · Limited - significant inconveniences individuals can overcome despite a few difficulties · Significant - significant consequences individuals should overcome, but with serious difficulties · Maximum - significant or irreversible consequences individuals may not overcome

Residual likelihood: how likely is it with every agreed measure in place? CHOOSE ONE

OPTIONS Negligible - it does not seem possible for the identified risk sources to realise the threat · Limited - it seems difficult for the identified risk sources to realise the threat · Significant - it seems possible for the identified risk sources to realise the threat · Maximum - it seems extremely easy for the identified risk sources to realise the threat

What risk remains, why can it not reasonably be reduced further, and does it fall harder on particular individuals or groups? LONG TEXT

How will the continued effectiveness of the measures be monitored? LONG TEXT

After these controls, is the residual risk to individuals acceptable? YES / NO

FOLLOW-UP a follow-up note, worded according to the answer

Has the DPO or privacy team been consulted on this DPIA? (Art. 35(2)) YES / NO

When will this DPIA be reviewed? DATE

Full DPIA: 11 steps, 60 questions.

Legitimate Interest Test

The three-part test for relying on legitimate interests: is the interest legitimate, is the processing necessary for it, and do the individual's interests override it? Weighs both sides and shows the reasoning.

WHAT IT IS FOR The three-part test for relying on legitimate interests under Article 6(1)(f).

SHAPE 8 steps, 27 questions: purpose, necessity, then four parts of the balancing test (expectations, relationship, interests, rights and controls), then safeguards and conclusion.

WHAT IT RETURNS One of four verdicts: Cannot rely on legitimate interests; Unlikely to be available; Finely balanced; Legitimate interests can likely be relied on. Plus the factors for and against, with weights.

HOW THE SCORING WORKS

- Four answers are blockers, and a blocker overrides the balance entirely: no purpose recorded; necessity not met on either the organisational or the third-party limb; a less intrusive alternative exists; special-category or criminal-offence data is involved.
- Everything else is weighed. Factors against carry weights of 1 to 4; factors in favour count 2 each.
- Heaviest factors against, at weight 4: likely to cause harm or distress; the processing limits or undermines individual rights; no privacy notice covering this purpose; the individual cannot easily object.
- Weight 3: the individual would not expect this; could be perceived as intrusive; no existing relationship; little prejudice to anyone if the processing does not happen; scope could be reduced but has not been; no safeguards recorded.
- Thresholds on the weighted total against: 12 or more is Unlikely to be available; 6 or more, or simply outweighing the total in favour, is Finely balanced; below that the basis is likely available.

WHERE PEOPLE GET IT WRONG

- Legitimate interests is an Article 6 basis only. It can never supply the Article 9 condition special-category data needs, or the Article 10 basis criminal-offence data needs.
- Three or more documented safeguards count in favour; one or two count against. A safeguard you cannot evidence does not count at all.
- Employees and job candidates carry a standing weight against, because the relationship is dependent and consent is generally not a valid alternative.
- 'Not sure' is never neutral. Every uncertain answer carries a weight against, typically half the weight of the equivalent 'no'.

SOURCES [3] [5] [8]

The question bank, step by step

Step 1 of 8 • Part 1 - the purpose test

First, identify the interest. A legitimate interest can be your own or a third party's, and it must be real and specific rather than vague.

Which processing activity is this assessment for? SHORT TEXT

What is the purpose of the processing, and whose interest does it serve? LONG TEXT

Does the GDPR, the ePrivacy rules or national law specifically recognise this kind of processing as a legitimate activity (subject to a balancing test)? CHOOSE ONE

OPTIONS Yes · No · Not sure

FOLLOW-UP Which provision or recital, or why you consider the interest legitimate

Step 2 of 8 · Part 2 - the necessity test

Necessary does not mean convenient. If the objective can reasonably be achieved another way, or with less data, legitimate interests will not hold.

Is the processing necessary to meet one or more specific objectives of your organization? YES / NO

FOLLOW-UP Explain why it matters to the organization

Is the processing necessary to meet a specific objective of a third party? YES / NO

FOLLOW-UP Name the third party and explain why it matters to them

Is there another reasonable way of achieving the same objective - with less data, or without personal data at all? CHOOSE ONE

OPTIONS No · Yes · Not sure

FOLLOW-UP a follow-up note, worded according to the answer

Step 3 of 8 · Part 3a - what the individual would expect

The balancing test starts from the individual's reasonable expectations, not the organization's intentions.

Would the individual expect this processing to take place? CHOOSE ONE

OPTIONS Yes · No · Not sure

Would they expect their data to be used specifically for this purpose? CHOOSE ONE

OPTIONS Yes · No · Not sure

Could the processing be seen as intrusive or inappropriate - by the individual, or given the nature of the relationship? CHOOSE ONE

OPTIONS No · Yes · Not sure

FOLLOW-UP Explain what could be perceived as intrusive

Is the processing likely to cause unwarranted harm or distress to the individual? CHOOSE ONE

OPTIONS No · Yes · Not sure

FOLLOW-UP Describe the harm or distress and who it would affect

Step 4 of 8 · Part 3b - the relationship

What is the individual's connection to the organization? CHOOSE ONE

OPTIONS Customer · Consumer · Employee · Job candidate · Supplier or contractor · No existing relationship · Other

FOLLOW-UP Describe the connection

Is there a two-way relationship, and how close is it? CHOOSE ONE

OPTIONS Ongoing · Periodic · One-off · None

Was the data obtained directly from the individual, or indirectly? CHOOSE ONE

OPTIONS Directly · Indirectly · Both

Is there an imbalance of power between the organization and the individual? CHOOSE ONE

OPTIONS No · Yes · Not sure

FOLLOW-UP Explain the imbalance

Step 5 of 8 • Part 3c - the interests at stake

Would the organization be prejudiced if the processing did not happen? CHOOSE ONE

OPTIONS Yes · No · Not sure

FOLLOW-UP What would the impact be?

Would a third party be prejudiced if the processing did not happen? CHOOSE ONE

OPTIONS Yes · No · Not applicable

FOLLOW-UP Which third party, and what impact?

Is the processing in the individual's own interest - does it add value to something they use?
CHOOSE ONE

OPTIONS Yes · Partly · No

FOLLOW-UP Explain the benefit to the individual

Are the individual's interests aligned with the interest being relied on? CHOOSE ONE

OPTIONS Yes · Partly · No

Step 6 of 8 • Part 3d - the data and the individual's rights

What is the nature of the data being processed? LONG TEXT

Does the data include special category or criminal offence data? YES / NO

Would the processing limit or undermine the individual's rights? CHOOSE ONE

OPTIONS No · Yes · Not sure

FOLLOW-UP Which rights, and how

Is a privacy notice provided that is clear and up front about this purpose? CHOOSE ONE

OPTIONS Yes · Partly · No

FOLLOW-UP a follow-up note, worded according to the answer

Can the individual control the processing or object to it easily? CHOOSE ONE

OPTIONS Yes · Partly · No

FOLLOW-UP How can they object, or why can they not?

Could the scope of the processing be reduced to lower the privacy impact? CHOOSE ONE

OPTIONS Yes · No · Already minimised

FOLLOW-UP What could be reduced, and will it be?

Step 7 of 8 • Part 4 - safeguards and compensating controls

Safeguards are what can tip a finely balanced assessment. They only count if they are actually in place, or committed to with a date.

Which safeguards or compensating controls are in place? CHOOSE ANY

OPTIONS Data minimisation - only the fields actually needed · Pseudonymisation or de-identification · Aggregation for any secondary use · Strict retention limits with enforced deletion · Access restrictions and least privilege · Technical and organisational security measures · A clear, specific privacy notice covering this purpose · An easy opt-out or objection mechanism · Human review of any automated outcome · Contractual controls on third parties · Training for the staff involved · A DPIA covering this processing

FOLLOW-UP Any other safeguard, and anything still to be implemented (with a target date)

Step 8 of 8 • Part 5 - your conclusion

The tool weighs your answers below, but the recorded decision is yours. Write the reasoning in your own words - this is the part a regulator would read.

Can you rely on legitimate interests for this processing? Set out why, drawing on the answers above. LONG TEXT

| When will this assessment be reviewed? DATE

Legitimate Interest Test: 8 steps, 27 questions.

AI Risk Assessment

An EU AI Act-aligned risk assessment: register the AI system, screen it for prohibited/high-risk status, and check autonomy, data, and governance controls.

WHAT IT IS FOR An EU AI Act-aligned screen of an AI system, plus the operational risk of running it.

SHAPE 6 steps, 21 questions: inventory, regulatory screening, autonomy and agentic risk, data sourcing and third-party risk, generative AI and context risk, governance.

WHAT IT RETURNS Two independent levels. A regulatory level (Prohibited / High / Limited / Minimal) and a business level (Low / Medium / High).

HOW THE SCORING WORKS

- The regulatory level comes from two questions only. A prohibited use sets Prohibited outright. Otherwise Annex III applicability sets High for yes, Limited for unsure, Minimal for no.
- The business level starts at Low and escalates on operational answers: broad autonomous action without logging, business-critical data without both logging and oversight, and possible competitor exposure all set High.
- Escalate to Medium: broad autonomy with logging; an undocumented multi-agent chain; broad access to sensitive systems or data; the provider training on your data; missing or partial context and memory safeguards; no output guardrails.
- Unsure is scored, not skipped. Unsure on prohibited use raises a high-severity factor; unsure on Annex III lands the system at Limited rather than Minimal.

WHERE PEOPLE GET IT WRONG

- The two levels are independent by design. A Minimal regulatory system with broad autonomy and no logging is a genuine High business risk, and the tool will say so.
- A missing legal review and an undefined audit cadence produce factors but do not escalate the level. They are governance debt, not risk.

SOURCES [3] [6]

The question bank, step by step

Step 1 of 6 • System inventory

AI system / use case name SHORT TEXT

Brief description of what it does LONG TEXT

What type of AI capability is this? CHOOSE ONE

OPTIONS Traditional ML / predictive model · Generative AI (content generation) · AI Agent (single, tool-using) · Agentic AI (multi-agent, autonomous orchestration) · Decision-support / rules-based AI

Lifecycle stage CHOOSE ONE

OPTIONS Idea / concept · Pilot · Production · Retired

Are a business owner and a technical owner formally assigned? YES / NO

FOLLOW-UP Who should be assigned, and by when?

Step 2 of 6 • Regulatory screening

Does the system fall into a prohibited-use category under the EU AI Act (e.g. social scoring, manipulative/subliminal techniques causing harm, exploiting vulnerabilities, untargeted facial-recognition scraping, workplace/education emotion inference, biometric categorization inferring protected attributes, or, from 2 December 2026, generating non-consensual intimate imagery or child sexual abuse material)? CHOOSE ONE

OPTIONS No · Yes · Unsure

FOLLOW-UP Briefly explain why / what triggered this concern

Does it fall under an EU AI Act Annex III high-risk category (e.g. employment/HR decisions, access to essential services, credit scoring, biometric identification, law enforcement, migration/border control, education/exam scoring, critical infrastructure safety)? CHOOSE ONE

OPTIONS No · Yes · Unsure

FOLLOW-UP Which Annex III category applies (or is suspected)?

Does a documented human-oversight and override capability exist for this system's decisions?

YES / NO

FOLLOW-UP What oversight mechanism is planned?

Step 3 of 6 • Autonomy & agentic risk

What actions can the system take without human approval? CHOOSE ONE

OPTIONS None - a human approves every action · Low-impact actions only · Broad autonomous action

FOLLOW-UP Briefly describe what it can do without approval

Are all autonomous actions and data access logged, auditable, and attributable to a responsible owner? YES / NO

FOLLOW-UP What's missing, and what's the plan to close the gap?

Does the system coordinate with other AI agents, models, or external services (multi-agent orchestration)? YES / NO

Are all connected agents/systems identified and documented? YES / NO

FOLLOW-UP a follow-up note, worded according to the answer

SHOWN WHEN `multiAgent === "Yes"`

Does it have access to sensitive or business-critical systems/data beyond what's strictly needed for its task? YES / NO

FOLLOW-UP Which systems/data, and why is that scope needed?

Step 4 of 6 • Data sourcing & third-party risk

Is training or input data sourced from third parties or public/external platforms? YES / NO

FOLLOW-UP Which third parties/platforms?

Does the AI provider use your organization's data to train its underlying model? CHOOSE ONE

OPTIONS No · Yes · Unsure

FOLLOW-UP Note any contractual restriction or opt-out status

Does the system process business-critical data (contracts, transactions, financial, legal, or audit records)? YES / NO

FOLLOW-UP Which records?

Could its output or data be exposed to competitors or unauthorized external parties? YES / NO

FOLLOW-UP Describe how exposure could occur and any controls in place

Step 5 of 6 • Generative AI & context risk**STEP SHOWN WHEN** `GENAI_TYPES.indexOf(aiType) !== -1`

Are safeguards in place to prevent context poisoning, data leakage, or use of outdated information in the system's memory/context? CHOOSE ONE

OPTIONS Yes · Partially · No

FOLLOW-UP Describe the gap and mitigation plan

Are guardrails in place to prevent unsafe, non-compliant, or unintended outputs? YES / NO

FOLLOW-UP What guardrails are planned?

Step 6 of 6 • Governance

Has this use case been reviewed by legal/compliance for regulatory risk? YES / NO

FOLLOW-UP When is legal/compliance review planned?

Is a recurring audit or monitoring frequency defined for this system? YES / NO

FOLLOW-UP a follow-up note, worded according to the answer

AI Risk Assessment: 6 steps, 21 questions.

Incident & Breach Severity

Record a privacy incident and, where it qualifies as a personal data breach, score its severity using the published ENISA method - $SE = (DPC \times EI) + CB$ - with an analysis of what drives the score and what would change it.

WHAT IT IS FOR Record a privacy incident and, where it is a personal data breach, score its severity using the published ENISA method.

SHAPE 11 steps, 56 questions: description, reporting and timing, scope and context, details and cause, four severity steps, an optional cross-check, communications and mitigation, notification.

WHAT IT RETURNS A severity score SE and a band, notification guidance for the authority and for individuals, the 72-hour deadline arithmetic, and optional EDPB and AEPD cross-checks.

HOW THE SCORING WORKS

$$SE = (DPC \times EI) + CB$$

- DPC, the data processing context, runs 1 to 4 across four data families: simple, behavioural, financial, sensitive. The highest of the four is the base.
- Aggravating factors add 0.5 each, mitigating factors subtract 0.5 each, and the result is capped at 4 and floored at 0.
- EI, ease of identification, is a correcting factor from 0.25 to 1 across six identifier families: name, ID number, contact details, email, picture, code or pseudonym. The highest applies.
- CB, circumstances of the breach, adds up to 0.5 each for loss of confidentiality, integrity and availability, so at most 1.5.
- Bands: below 2 is Low, below 3 is Medium, below 4 is High, 4 and above is Very High.
- Notification: Low means neither; Medium means notify the authority; High and Very High mean notify the authority and the individuals.

WHERE PEOPLE GET IT WRONG

- EI is a multiplier, not an addition. Data that cannot be linked to a person at all collapses the whole score, which is why pseudonymisation with a secure key is worth so much here.
- DPC is capped at 4 even when aggravating factors push it higher, so the cap is itself worth recording as a finding.
- The optional step cross-checks the same facts against the EDPB guidelines examples and the Spanish AEPD method, whose formula is volume x type x impact with a separate three-part threshold test. Three methods agreeing is a much stronger record than one.
- The 72-hour clock runs from the moment the breach qualified, not from when it was discovered or confirmed.

SOURCES [3] [5] [9] [10] [11]

The ENISA scales in full

DPC - SIMPLE DATA	SCORE
Not involved	not involved
Simple data is involved and there are no aggravating factors	1
The data can be used for profiling (e.g. social or financial status)	2
The data can support assumptions about special-category information	3
The data is critical to the physical or psychological safety of a vulnerable group	4

DPC - BEHAVIOURAL DATA	SCORE
Not involved	not involved
The data gives little insight, or could be collected just as easily from public sources	1
Behavioural data is involved and there are no aggravating factors	2
The volume and type allow a profile exposing the individual's life or habits	3
A profile can be built from sensitive data affected by the breach	4

DPC - FINANCIAL DATA	SCORE
Not involved	not involved
The data gives no real insight into financial status (e.g. only that someone is a customer)	1
Some financial information, but no significant insight into financial status (e.g. an account number alone)	2
Financial data is involved and there are no aggravating factors	3
Full financial information that could enable fraud or financial/social profiling	4

DPC - SENSITIVE DATA	SCORE
Not involved	not involved
The data gives little insight, or could be collected just as easily from public sources	1
The nature of the data supports only general assumptions	2
The nature of the data supports assumptions about sensitive information	3
Sensitive data is involved and there are no lessening factors	4

EI - FULL NAME	SCORE
Not involved	not involved
Many people in the country share the same full name	0.25
Few or no people in the country share the same full name	0.5
Few or no people in a small city share the same full name	0.75
Many share the name, but date of birth or email/postal address was also exposed	1

EI - ID NUMBER	SCORE
Not involved	not involved
No other information is available, and more cannot be found without access to the reference database	0.25
The identifier reveals further identifying detail and is linked to other data (address, email)	0.75
Information from the reference database is also available (ID card, full name, picture)	1

EI - PHONE OR POSTAL ADDRESS	SCORE
Not involved	not involved
The number or address is not listed in any publicly available register	0.25
Not listed publicly, but the population concerned is a small city	0.5
The number or address is listed in a publicly available register	1

EI - EMAIL ADDRESS	SCORE
Not involved	not involved
Reveals no identifying detail and is not the individual's primary address online	0.25
Reveals no identifying detail but is the individual's primary address online	0.75
Reveals the individual's name and is their primary address online	1

EI - PICTURE	SCORE
Not involved	not involved
Unclear or vague (e.g. distant CCTV footage)	0.25
Unclear, but the surroundings hint at further identifying detail (e.g. a specific location)	0.5
Clear, with no other identifying information attached	0.75
Clear and linked to further information (home address, membership)	1

EI - CODE OR PSEUDONYM	SCORE
Not involved	not involved
Cannot be linked to other personal data without access to the reference database	0.25
Reveals some detail (e.g. a first name) and is linked to other personal data	0.75
Reveals the individual's full name, or reference-database data is also available	1

CB - CONFIDENTIALITY	SCORE
No loss of confidentiality	0
Data was encrypted or pseudonymised, and the key was not affected and remains secure	0
No evidence that anyone accessed the data	0
The recipients are known and are cooperating	0.25
The recipients are unknown, uncooperative, numerous or potentially unlimited	0.5

CB - INTEGRITY	SCORE
No loss of integrity	0
Data was altered, but there is no sign of incorrect or unlawful use and the originals remain available	0
Data was altered and possibly misused, but the correct data can be recovered	0.25
Data was replaced with untrue or unrelated data and cannot be recovered by the organization	0.5

CB - AVAILABILITY	SCORE
No loss of availability	0
Data can be restored quickly with no consequences for individuals	0
Data can be restored, but it will take some processing	0
Data is lost but can be supplied again by the individuals concerned	0.25
Data is permanently lost, with no backup and no way for individuals to supply it again	0.5

The question bank, step by step

Step 1 of 11 • Incident description

Incident reference or short name SHORT TEXT

General description of what happened LONG TEXT

Incident type CHOOSE ONE

OPTIONS Unauthorized disclosure of information · Misdirected email · Misdirected postal mail · Lost or stolen device · Lost or stolen paper records · User account compromise · Ransomware or malware · Technical vulnerability or misconfiguration · Insider misuse · Third-party or supplier incident · Other

FOLLOW-UP Describe the incident type

Step 2 of 11 • Reporting & timing

Was the incident reported by someone internal or external to the organization? CHOOSE ONE

OPTIONS Internal · External · Unknown

FOLLOW-UP Describe the reporter's relationship to the organization

Who is leading the management of this incident? SHORT TEXT

Who first reported it? (include contact details if they are external) SHORT TEXT

Who can give further detail on the incident? Name, role and contact details. LONG TEXT

How did the incident reach the privacy team? CHOOSE ONE

OPTIONS Directly to the privacy team · Via the legal team · Via IT / security · Via the IT service desk or ticketing system · Via customer service · Via a supplier or third party · Other

FOLLOW-UP Describe the intake route

When did the incident first happen? (best estimate is fine) DATE

When was it discovered or first reported? DATE

When was it qualified as a personal data breach? (leave blank if it wasn't, or not yet) DATE

Step 3 of 11 • Scope & context

Which countries or jurisdictions are affected? CHOOSE ANY

OPTIONS 209 entries, listed in Appendix A.

FOLLOW-UP Specify the other country or countries

In which functional area did the incident happen? CHOOSE ONE

OPTIONS HR & People · Marketing & Sales · Customer Service · Finance · IT & Technology · Supply Chain & Operations · Legal & Compliance · Other

FOLLOW-UP Specify the functional area

Is this a third-party or supplier incident? YES / NO

FOLLOW-UP Describe the third party's role and what they have told you (no need to name them here)

Which processing activities in your RoPA does this relate to? (describe it here if you cannot find one) LONG TEXT

Does the incident involve one or more specific applications, systems or services? YES / NO

FOLLOW-UP Which systems or services are involved?

Step 4 of 11 • Details & cause

Was personal data exposed, altered or made unavailable - i.e. does this qualify as a personal data breach? YES / NO

Which category or categories of breach apply? CHOOSE ANY

OPTIONS Confidentiality breach (unauthorized disclosure or access) · Integrity breach (unauthorized or accidental alteration) · Availability breach (accidental or unauthorized loss of access or destruction)

SHOWN WHEN `personalDataAffected === "Yes"`

What was the root cause? CHOOSE ONE

OPTIONS Human error · Process failure or missing control · Malicious external actor · Malicious or negligent insider · Technical or system failure · Third-party or supplier failure · Unknown / still under investigation · Other

FOLLOW-UP Describe the root cause

Was the incident intentional or accidental? CHOOSE ONE

OPTIONS Accidental · Intentional · Unknown

How many records are or could be affected? CHOOSE ONE

OPTIONS Fewer than 100 · 100 to 1,000 · 1,000 to 100,000 · 100,000 to 1,000,000 · More than 1,000,000 · Not yet known

How many individuals are or could be affected? CHOOSE ONE

OPTIONS 1 to 10 · 11 to 100 · 101 to 1,000 · 1,001 to 100,000 · More than 100,000 · Not yet known

Whose personal data was exposed or potentially exposed? CHOOSE ANY

OPTIONS Customers · Consumers · Employees and contractors · Job candidates · Suppliers and business partners · Website or app users · Children · Other

FOLLOW-UP Specify the other data subjects

SHOWN WHEN `personalDataAffected === "Yes"`

Which categories of personal data were exposed or potentially exposed? CHOOSE ANY

OPTIONS Basic identity and personal characteristics (name, date of birth, nationality) · Private contact information (home address, personal email, personal phone) · Business contact information (job title, work email, work phone, department) · Official identification (passport, national ID, tax or social security number) · Employment administration data (contract, working time, absence, leavers) · Compensation and benefits (salary, bonuses, pension, deductions) · Education, qualifications and training records · Work activities and performance (objectives, appraisals, disciplinary records) · Bank and card data (account details, payment card data) · Financial and credit data (credit checks, financial history) · Assigned company assets (devices, access badges, company car, fines) · Travel and expense data · Family relations and dependants · Location, movement or telematics data · Logs, recordings and monitoring data (CCTV, call recordings, system logs) · Technical identifiers, authentication and authorisation data · Social media and internet activity · Lifestyle and preferences · Workplace safety and incident data · Background checks (employment, education, criminal record) · Special category data (health, genetic, biometric data used to uniquely identify a person, racial or ethnic origin, religious or philosophical beliefs, political opinion, trade union membership, sex life or orientation) · Criminal offence data · Other

FOLLOW-UP Specify the other data categories

SHOWN WHEN `personalDataAffected === "Yes"`

Are any of the affected individuals external to the organization (customers, consumers, candidates, suppliers, former staff)? YES / NO

FOLLOW-UP Who are they, and is the impact on them different?

Is the impact different for those external individuals, and what is being done to mitigate it for them? LONG TEXT

SHOWN WHEN `externalSubjects === "Yes"`

Could the incident lead to disciplinary measures (e.g. repeat incidents or gross negligence)?

YES / NO

FOLLOW-UP Explain

Step 5 of 11 · Severity 1 of 4 - data processing context

STEP SHOWN WHEN `personalDataAffected === "Yes"`

For each data type involved, pick the statement that best fits. The highest single score sets the base data processing context (DPC).

Simple data - name, address, education, family status, professional experience, other biographic-al data CHOOSE ONE

OPTIONS Not involved · Simple data is involved and there are no aggravating factors · The data can be used for profiling (e.g. social or financial status) · The data can support assumptions about special-category information · The data is critical to the physical or psychological safety of a vulnerable group

Behavioural data - location, traffic, preferences, habits, performance CHOOSE ONE

OPTIONS Not involved · The data gives little insight, or could be collected just as easily from public sources · Behavioural data is involved and there are no aggravating factors · The volume and type allow a profile exposing the individual's life or habits · A profile can be built from sensitive data affected by the breach

Financial data - income, tax, bank statements, investments, risk profile, card data CHOOSE ONE

OPTIONS Not involved · The data gives no real insight into financial status (e.g. only that someone is a customer) · Some financial information, but no significant insight into financial status (e.g. an account number alone) · Financial data is involved and there are no aggravating factors · Full financial information that could enable fraud or financial/social profiling

Special category data - health, racial or ethnic origin, political views, religious or philosophical beliefs, trade union membership, genetic or biometric data, sex life or orientation, criminal offences CHOOSE ONE

OPTIONS Not involved · The data gives little insight, or could be collected just as easily from public sources · The nature of the data supports only general assumptions · The nature of the data supports assumptions about sensitive information · Sensitive data is involved and there are no lessening factors

Step 6 of 11 · Severity 2 of 4 - adjusting factors

STEP SHOWN WHEN `personalDataAffected === "Yes"`

The original methodology leaves the size of these adjustments to the assessor's judgement. This tool applies a consistent ± 0.5 per selected factor so scores stay comparable - override it in your own record if your judgement differs.

Aggravating factors (each adds 0.5 to the data processing context) CHOOSE ANY

OPTIONS Large volume of data about the same individual (in content or over an extended period) · The individuals are children or otherwise vulnerable · The individuals have special characteristics or public profiles (e.g. elected officials, police) · The breach could lead to one or more further negative consequences

FOLLOW-UP Any other aggravating factor - describe it (not scored automatically)

Mitigating factors (each subtracts 0.5) CHOOSE ANY

OPTIONS The data is invalid, outdated or inaccurate, which makes it less significant · The data is already publicly available · The data does not reveal significant information about the individual

FOLLOW-UP Any other mitigating factor - describe it (not scored automatically)

Step 7 of 11 · Severity 3 of 4 - ease of identification

STEP SHOWN WHEN `personalDataAffected === "Yes"`

How easily can individuals be identified from the data involved? This is a correcting factor between 0.25 and 1 - the highest single value applies.

Full name CHOOSE ONE

OPTIONS Not involved · Many people in the country share the same full name · Few or no people in the country share the same full name · Few or no people in a small city share the same full name · Many share the name, but date of birth or email/postal address was also exposed

Unique identifier - national ID, social security or passport number CHOOSE ONE

OPTIONS Not involved · No other information is available, and more cannot be found without access to the reference database · The identifier reveals further identifying detail and is linked to other data (address, email) · Information from the reference database is also available (ID card, full name, picture)

Telephone number or home address CHOOSE ONE

OPTIONS Not involved · The number or address is not listed in any publicly available register · Not listed publicly, but the population concerned is a small city · The number or address is listed in a publicly available register

Email address CHOOSE ONE

OPTIONS Not involved · Reveals no identifying detail and is not the individual's primary address online · Reveals no identifying detail but is the individual's primary address online · Reveals the individual's name and is their primary address online

Picture or footage CHOOSE ONE

OPTIONS Not involved · Unclear or vague (e.g. distant CCTV footage) · Unclear, but the surroundings hint at further identifying detail (e.g. a specific location) · Clear, with no other identifying information attached · Clear and linked to further information (home address, membership)

Customer or employee number, code, initials or alias CHOOSE ONE

OPTIONS Not involved · Cannot be linked to other personal data without access to the reference database · Reveals some detail (e.g. a first name) and is linked to other personal data · Reveals the individual's full name, or reference-database data is also available

Step 8 of 11 · Severity 4 of 4 - circumstances of the breach

STEP SHOWN WHEN `personalDataAffected === "Yes"`

These add to the score. Pick the statement that fits for each type of security loss.

Loss of confidentiality CHOOSE ONE

OPTIONS No loss of confidentiality · Data was encrypted or pseudonymised, and the key was not affected and remains secure · No evidence that anyone accessed the data · The recipients are known and are cooperating · The recipients are unknown, uncooperative, numerous or potentially unlimited

Loss of integrity CHOOSE ONE

OPTIONS No loss of integrity · Data was altered, but there is no sign of incorrect or unlawful use and the originals remain available · Data was altered and possibly misused, but the correct data can be recovered · Data was replaced with untrue or unrelated data and cannot be recovered by the organization

Loss of availability CHOOSE ONE

OPTIONS No loss of availability · Data can be restored quickly with no consequences for individuals · Data can be restored, but it will take some processing · Data is lost but can be supplied again by the individuals concerned · Data is permanently lost, with no backup and no way for individuals to supply it again

Was the breach the result of deliberate action intended to harm the organization or the individuals? (adds 0.5) YES / NO

Step 9 of 11 · Optional - cross-check against other published methods

STEP SHOWN WHEN `personalDataAffected === "Yes"`

The ENISA score is this tool's primary result. These two are independent, separately published methods you can optionally line up against it - leave either blank to skip it.

AEPD method - if this data got out, what would the impact of disclosure be? (Combines with the records-affected and data-category answers already given, to score volume × type × impact per the Spanish supervisory authority's published guide.) CHOOSE ONE

OPTIONS No impact · Controlled internal impact (stays within the organization) · External impact (customers, suppliers, or other outside parties) · Public impact (widely public, or freely accessible online) · Not yet known

EDPB method - does one of the EDPB's own published example breaches closely match this one?

Pick the closest, if any. CHOOSE ONE

OPTIONS Ransomware - properly backed up, no evidence of exfiltration (EDPB example, case 1) · Ransomware - no proper backup in place (EDPB example, case 2) · Ransomware - backed up, no evidence of exfiltration, but in a hospital or similarly critical setting (EDPB example, case 3) · Ransomware - no backup, with evidence of exfiltration (EDPB example, case 4) · Exfiltration of job-application data from a website (EDPB example, case 5) · Exfiltration of hashed passwords from a website (EDPB example, case 6) · Credential-stuffing attack on a banking website (EDPB example, case 7) · Exfiltration of business data by a former employee (EDPB example, case 8) · Accidental transmission of data to a trusted third party (EDPB example, case 9) · Stolen device or media storing encrypted personal data (EDPB example, case 10) · Stolen device or media storing unencrypted personal data (EDPB example, case 11) · Stolen paper files containing sensitive data (EDPB example, case 12) · Mail sent to the wrong recipient - no sensitive data involved (EDPB example, case 13) · Sensitive personal data sent by mail to the wrong recipient (EDPB example, case 14) · Personal data sent by mail to the wrong recipient (EDPB example, case 15) · Mail sent to the wrong recipient - a further, separately published example (EDPB example, case 16) · Identity theft via social engineering (EDPB example, case 17) · Email data exfiltrated via social engineering (EDPB example, case 18)

Step 10 of 11 · Communications & mitigation

Have any individuals complained about the incident? YES / NO

FOLLOW-UP Summarize the complaints

Has the incident become public (media, social media)? YES / NO

FOLLOW-UP Where, and what has been said?

What is the likely or potential impact on the individuals? Select all that apply. CHOOSE ANY

OPTIONS No impact · Mere inconvenience · Loss of control over their own data · Feeling of invasion of privacy · Embarrassment or reputational damage · Discrimination · Financial loss · Fraud · Identity theft · Loss of employment or opportunity · Physical harm or a risk to safety

SHOWN WHEN `personalDataAffected === "Yes"`

Has there been any communication with the affected individuals? CHOOSE ONE

OPTIONS Yes · Not yet, but planned · No - not yet decided · No - we will not communicate · Not applicable

FOLLOW-UP What was communicated, and when?

What actions have been taken to contain the breach or reduce the impact on individuals?

LONG TEXT

Lessons learned and follow-up actions LONG TEXT

Step 11 of 11 · Notification

STEP SHOWN WHEN `personalDataAffected === "Yes"`

Record the decision actually taken and when. The clock for notifying the supervisory authority runs from the moment the incident was qualified as a personal data breach, not from when it was discovered.

Will you notify the supervisory authority? CHOOSE ONE

OPTIONS Yes · No · Not yet decided

FOLLOW-UP a follow-up note, worded according to the answer

When was the notification submitted? (leave blank if not yet) DATE

SHOWN WHEN `notifyAuthority === "Yes"`

Was the notification later than 72 hours after the breach was qualified? YES / NO

FOLLOW-UP Give the reasoned justification for the delay - this must accompany the notification

SHOWN WHEN `notifyAuthority === "Yes"`

Was the notification made in phases? YES / NO

FOLLOW-UP Date of the first notification, and the deadline communicated for the final one

SHOWN WHEN `notifyAuthority === "Yes"`

Will you notify the affected individuals? CHOOSE ONE

OPTIONS Yes · No · Not yet decided · Not applicable

FOLLOW-UP a follow-up note, worded according to the answer

Incident & Breach Severity: 11 steps, 56 questions.

Third-Party Security Assessment

A detailed vendor security questionnaire across governance, people, assets, development, access, operations, cryptography, incident response, physical security, continuity and compliance - plus an AI/ML supplement - scored as inherent risk tempered by control maturity, with a full list of gaps to close.

WHAT IT IS FOR A vendor security questionnaire scored as inherent risk tempered by control maturity.

SHAPE 21 steps, 111 questions: two intake steps, then 17 security domains, then two AI/ML domains that apply only when the engagement involves an AI system.

WHAT IT RETURNS An inherent risk tier, a control maturity tier, a residual risk band, per-domain scores, and a gap list ordered by weight and status.

HOW THE SCORING WORKS

- Every control is answered on four points: Fully in place (1), Partially in place (0.5), Not in place (0), Not applicable (removed from scoring).
- Inherent risk is scored from the intake answers alone, out of a theoretical 9: personal data 1, payment or bank data 1.5, HR data 1, other confidential data 0.5, connects to internal systems 1, public-facing 1, AI/ML 1, processor engagement 0.5, plus user count (fewer than 10 scores 0, 10 to 100 scores 0.5, 100 to 1,000 scores 1, more than 1,000 scores 1.5).
- Inherent tiers: below 2 Low, below 4 Medium, below 6 High, 6 and above Critical.
- Control maturity is the weighted average of the domain scores. Tiers: 0.85 and above Strong, 0.65 and above Adequate, 0.4 and above Weak, below that Poor.
- Residual risk comes from a lookup table, rows inherent tier, columns maturity tier:

INHERENT \ MATURITY	POOR	WEAK	ADEQUATE	STRONG
Low	Medium	Low	Low	Low
Medium	High	Medium	Medium	Low
High	Critical	High	Medium	Medium
Critical	Critical	Critical	High	Medium

WHERE PEOPLE GET IT WRONG

- Not applicable is the only answer that can flatter the result, because it leaves the scoring set rather than counting zero. Use it sparingly.
- Nothing at Critical inherent risk falls below Medium residual, however strong the controls. The vendor cannot control its way out of holding your payment data.
- Domain weight decides gap priority: gaps at weight 1.25 and above are surfaced first, split into Not in place and Partially in place.
- Leaving controls unanswered does not lower the score, it withholds the maturity tier entirely and the residual band is reported as provisional.

SOURCES [3] [14] [15]

The question bank, step by step

Step 1 of 21 • Engagement details

Third-party or vendor name SHORT TEXT

What services will this third party provide? LONG TEXT

What kind of engagement is this? CHOOSE ONE

OPTIONS Software / SaaS provider · Data processor or outsourced service · Cloud hosting or infrastructure provider · Operational technology or industrial supplier · Consulting or professional services · Other

FOLLOW-UP Describe the engagement

Which operational or manufacturing processes does this involve? LONG TEXT

SHOWN WHEN engagementType == "Operational technology or industrial supplier"

Does this engagement involve an AI or machine-learning system - a model the third party operates, trains, or exposes to your users? YES / NO

Will there be any connection to your organization's internal systems? YES / NO

FOLLOW-UP Describe the type of connection

If that connection adds a new data flow, describe it LONG TEXT

SHOWN WHEN connectsToInternalSystems == "Yes"

Step 2 of 21 • Data & access

Which categories of data will the third party access, store or process? CHOOSE ANY

OPTIONS Personal data (names, contact details, and similar) · Payment card or bank account data · HR / employee data · Other confidential or proprietary business data · None of the above

FOLLOW-UP Specify the personal data types involved (name, address, email, etc.)

How will data be transferred, and by what technology (API, SFTP, HTTPS, etc.)? SHORT TEXT

Will the service have a public-facing website or application? YES / NO

How many of your people will have access to the service? CHOOSE ONE

OPTIONS Fewer than 10 · 10 to 100 · 100 to 1,000 · More than 1,000

Is this engagement tracked under an internal onboarding, procurement or project reference? (optional) SHORT TEXT

Third-party security or privacy contact (name and/or email, optional) SHORT TEXT

Step 3 of 21 • Governance & risk management

There is a role with information-security oversight that sets direction for the organization's security program. CHOOSE ONE

OPTIONS Fully in place · Partially in place · Not in place · Not applicable

FOLLOW-UP Describe the compensating controls in place, or the plan and timeline to close this gap

There is a formal, documented and implemented information-risk management program. CHOOSE ONE

OPTIONS Fully in place · Partially in place · Not in place · Not applicable

FOLLOW-UP Describe the compensating controls in place, or the plan and timeline to close this gap

The risk management program has a dedicated owner responsible for maintaining and reviewing it. CHOOSE ONE

OPTIONS Fully in place · Partially in place · Not in place · Not applicable

FOLLOW-UP Describe the compensating controls in place, or the plan and timeline to close this gap

There is an information security policy, approved by management and reviewed periodically. CHOOSE ONE

OPTIONS Fully in place · Partially in place · Not in place · Not applicable

FOLLOW-UP Describe the compensating controls in place, or the plan and timeline to close this gap

Information security roles and responsibilities are defined and documented. CHOOSE ONE

OPTIONS Fully in place · Partially in place · Not in place · Not applicable

FOLLOW-UP Describe the compensating controls in place, or the plan and timeline to close this gap

Step 4 of 21 · People & personnel security

Job applicants are screened, including prior-employment and reference checks. CHOOSE ONE

OPTIONS Fully in place · Partially in place · Not in place · Not applicable

FOLLOW-UP Describe the compensating controls in place, or the plan and timeline to close this gap

Staff are required to sign a non-disclosure agreement and an acceptable-use policy. CHOOSE ONE

OPTIONS Fully in place · Partially in place · Not in place · Not applicable

FOLLOW-UP Describe the compensating controls in place, or the plan and timeline to close this gap

Staff receive regular security-awareness training. CHOOSE ONE

OPTIONS Fully in place · Partially in place · Not in place · Not applicable

FOLLOW-UP Describe the compensating controls in place, or the plan and timeline to close this gap

Access rights are automatically removed, or promptly adjusted, when someone's employment or role changes. CHOOSE ONE

OPTIONS Fully in place · Partially in place · Not in place · Not applicable

FOLLOW-UP Describe the compensating controls in place, or the plan and timeline to close this gap

Step 5 of 21 · Information asset management

There is a formal asset-management program with an inventory of critical assets, including any assets accessible to third parties. CHOOSE ONE

OPTIONS Fully in place · Partially in place · Not in place · Not applicable

FOLLOW-UP Describe the compensating controls in place, or the plan and timeline to close this gap

Ownership of information assets is formally assigned. CHOOSE ONE

OPTIONS Fully in place · Partially in place · Not in place · Not applicable

FOLLOW-UP Describe the compensating controls in place, or the plan and timeline to close this gap

There is a formal information-classification policy. CHOOSE ONE

OPTIONS Fully in place · Partially in place · Not in place · Not applicable

FOLLOW-UP Describe the compensating controls in place, or the plan and timeline to close this gap

The asset-management program covers the handling, disposal, destruction and reuse of media. CHOOSE ONE

OPTIONS Fully in place · Partially in place · Not in place · Not applicable

FOLLOW-UP Describe the compensating controls in place, or the plan and timeline to close this gap

Step 6 of 21 · Devices, mobile & remote access

Sensitive data is encrypted when copied to removable media. CHOOSE ONE

OPTIONS Fully in place · Partially in place · Not in place · Not applicable

FOLLOW-UP Describe the compensating controls in place, or the plan and timeline to close this gap

Remote access to systems, applications or network devices requires multi-factor authentication and encryption. CHOOSE ONE

OPTIONS Fully in place · Partially in place · Not in place · Not applicable

FOLLOW-UP Describe the compensating controls in place, or the plan and timeline to close this gap

Physical devices and systems are inventoried. CHOOSE ONE

OPTIONS Fully in place · Partially in place · Not in place · Not applicable

FOLLOW-UP Describe the compensating controls in place, or the plan and timeline to close this gap

There are processes to ensure the secure physical transport of removable media. CHOOSE ONE

OPTIONS Fully in place · Partially in place · Not in place · Not applicable

FOLLOW-UP Describe the compensating controls in place, or the plan and timeline to close this gap

Step 7 of 21 • Secure development lifecycle

There is a maintained, up-to-date development methodology covering techniques, delivery methods, architectures and security standards. CHOOSE ONE

OPTIONS Fully in place · Partially in place · Not in place · Not applicable

FOLLOW-UP Describe the compensating controls in place, or the plan and timeline to close this gap

Quality assurance in the development lifecycle covers: assessing development risks; confirming security requirements are defined; confirming the agreed security controls were built; and verifying they are effectively met. CHOOSE ONE

OPTIONS Fully in place · Partially in place · Not in place · Not applicable

FOLLOW-UP Describe the compensating controls in place, or the plan and timeline to close this gap

There is a clearly defined process for version control over development software. CHOOSE ONE

OPTIONS Fully in place · Partially in place · Not in place · Not applicable

FOLLOW-UP Describe the compensating controls in place, or the plan and timeline to close this gap

There is a secure development environment that accounts for data sensitivity, applicable requirements, existing controls, environment segregation, access control, change monitoring, offsite backups and data movement in and out. CHOOSE ONE

OPTIONS Fully in place · Partially in place · Not in place · Not applicable

FOLLOW-UP Describe the compensating controls in place, or the plan and timeline to close this gap

Software developers receive periodic secure-coding training. CHOOSE ONE

OPTIONS Fully in place · Partially in place · Not in place · Not applicable

FOLLOW-UP Describe the compensating controls in place, or the plan and timeline to close this gap

Step 8 of 21 • Release, testing & code security

Post-implementation reviews, including information security, are conducted for all new systems. CHOOSE ONE

OPTIONS Fully in place · Partially in place · Not in place · Not applicable

FOLLOW-UP Describe the compensating controls in place, or the plan and timeline to close this gap

There is a final security assessment on applications before they go live. CHOOSE ONE

OPTIONS Fully in place · Partially in place · Not in place · Not applicable

FOLLOW-UP Describe the compensating controls in place, or the plan and timeline to close this gap

Customers are provided with the results of that final security assessment on request. CHOOSE ONE

OPTIONS Fully in place · Partially in place · Not in place · Not applicable

FOLLOW-UP Describe the compensating controls in place, or the plan and timeline to close this gap

There are periodic reviews for outdated protocols and libraries. CHOOSE ONE

OPTIONS Fully in place · Partially in place · Not in place · Not applicable

FOLLOW-UP Describe the compensating controls in place, or the plan and timeline to close this gap

Controls are in place to ensure confidential or live data is never used in testing. CHOOSE ONE

OPTIONS Fully in place · Partially in place · Not in place · Not applicable

FOLLOW-UP Describe the compensating controls in place, or the plan and timeline to close this gap

Source code and data in development environments have unnecessary sensitive information removed (credentials, developer comments, organizational detail). CHOOSE ONE

OPTIONS Fully in place · Partially in place · Not in place · Not applicable

FOLLOW-UP Describe the compensating controls in place, or the plan and timeline to close this gap

Step 9 of 21 • Application & environment segregation

Developers do not have access to production systems and data. CHOOSE ONE

OPTIONS Fully in place · Partially in place · Not in place · Not applicable

FOLLOW-UP Describe the compensating controls in place, or the plan and timeline to close this gap

Test, development and production systems are hosted in separate environments. CHOOSE ONE

OPTIONS Fully in place · Partially in place · Not in place · Not applicable

FOLLOW-UP Describe the compensating controls in place, or the plan and timeline to close this gap

Systems used to store or process your data are separated from systems processing other customers' data. CHOOSE ONE

OPTIONS Fully in place · Partially in place · Not in place · Not applicable

FOLLOW-UP Describe the compensating controls in place, or the plan and timeline to close this gap

Web-server communications are encrypted, with non-repudiation ensured via digital certificates. CHOOSE ONE

OPTIONS Fully in place · Partially in place · Not in place · Not applicable

FOLLOW-UP Describe the compensating controls in place, or the plan and timeline to close this gap

Step 10 of 21 • Identity & access management

There is a formal access-control policy: role-based access, a unique ID per individual, no shared or generic IDs, and need-to-know / least-privilege principles. CHOOSE ONE

OPTIONS Fully in place · Partially in place · Not in place · Not applicable

FOLLOW-UP Describe the compensating controls in place, or the plan and timeline to close this gap

There is a formal password policy: no sharing, forced change at first login, periodic changes, complexity, and secure storage. CHOOSE ONE

OPTIONS Fully in place · Partially in place · Not in place · Not applicable

FOLLOW-UP Describe the compensating controls in place, or the plan and timeline to close this gap

Good password practice is enforced in the solution itself (a minimum length, mixed case, digits and special characters). CHOOSE ONE

OPTIONS Fully in place · Partially in place · Not in place · Not applicable

FOLLOW-UP Describe the compensating controls in place, or the plan and timeline to close this gap

Accounts are locked or disabled after a defined number of failed login attempts (a common baseline is 5). CHOOSE ONE

OPTIONS Fully in place · Partially in place · Not in place · Not applicable

FOLLOW-UP Describe the compensating controls in place, or the plan and timeline to close this gap

Passwords expire after a defined period (a common baseline is 90-120 days). CHOOSE ONE

OPTIONS Fully in place · Partially in place · Not in place · Not applicable

FOLLOW-UP Describe the compensating controls in place, or the plan and timeline to close this gap

Single sign-on (SSO) is supported, so access can be centrally managed and revoked. CHOOSE ONE

OPTIONS Fully in place · Partially in place · Not in place · Not applicable

FOLLOW-UP Describe the compensating controls in place, or the plan and timeline to close this gap

Step 11 of 21 • Access review & session controls

Access rights to systems, applications and network devices are reviewed at least annually. CHOOSE ONE

OPTIONS Fully in place · Partially in place · Not in place · Not applicable

FOLLOW-UP Describe the compensating controls in place, or the plan and timeline to close this gap

Firewall rules are reviewed at least annually. CHOOSE ONE

OPTIONS Fully in place · Partially in place · Not in place · Not applicable

FOLLOW-UP Describe the compensating controls in place, or the plan and timeline to close this gap

Workstations lock automatically after a period of inactivity. CHOOSE ONE

OPTIONS Fully in place · Partially in place · Not in place · Not applicable

FOLLOW-UP Describe the compensating controls in place, or the plan and timeline to close this gap

Privileged users and administrative tools are subject to specific controls. CHOOSE ONE

OPTIONS Fully in place · Partially in place · Not in place · Not applicable

FOLLOW-UP Describe the compensating controls in place, or the plan and timeline to close this gap

Any emergency 'break-glass' accounts that exist are tightly controlled and accounted for. CHOOSE ONE

OPTIONS Fully in place · Partially in place · Not in place · Not applicable

FOLLOW-UP Describe the compensating controls in place, or the plan and timeline to close this gap

There is a documented standard for security-event logging: generation, storage, protection, retention, and the attributes captured (date, time, user ID, filename, IP address). CHOOSE ONE

OPTIONS Fully in place · Partially in place · Not in place · Not applicable

FOLLOW-UP Describe the compensating controls in place, or the plan and timeline to close this gap

Security-event logs are retained for a defined minimum period (a common baseline is 90 days). CHOOSE ONE

OPTIONS Fully in place · Partially in place · Not in place · Not applicable

FOLLOW-UP Describe the compensating controls in place, or the plan and timeline to close this gap

Step 12 of 21 · Change, configuration & patch management

There is a formal change-management process that tracks relevant changes. CHOOSE ONE

OPTIONS Fully in place · Partially in place · Not in place · Not applicable

FOLLOW-UP Describe the compensating controls in place, or the plan and timeline to close this gap

Devices are built to a standard configuration and periodically reviewed for deviation. CHOOSE ONE

OPTIONS Fully in place · Partially in place · Not in place · Not applicable

FOLLOW-UP Describe the compensating controls in place, or the plan and timeline to close this gap

Servers and endpoints run security software that users cannot disable. CHOOSE ONE

OPTIONS Fully in place · Partially in place · Not in place · Not applicable

FOLLOW-UP Describe the compensating controls in place, or the plan and timeline to close this gap

An endpoint detection and response (EDR) solution investigates suspicious activity on hosts and endpoints. CHOOSE ONE

OPTIONS Fully in place · Partially in place · Not in place · Not applicable

FOLLOW-UP Describe the compensating controls in place, or the plan and timeline to close this gap

Servers, workstations, applications and network devices are patched on a regular basis. CHOOSE ONE

OPTIONS Fully in place · Partially in place · Not in place · Not applicable

FOLLOW-UP Describe the compensating controls in place, or the plan and timeline to close this gap

There is an emergency-patch process for rapid response to critical vulnerabilities. CHOOSE ONE

OPTIONS Fully in place · Partially in place · Not in place · Not applicable

FOLLOW-UP Describe the compensating controls in place, or the plan and timeline to close this gap

There is a formal vulnerability-assessment policy: regular assessments, severity classification, and required remediation of high-risk findings. CHOOSE ONE

OPTIONS Fully in place · Partially in place · Not in place · Not applicable

FOLLOW-UP Describe the compensating controls in place, or the plan and timeline to close this gap

Step 13 of 21 • Backup & monitoring

Systems holding sensitive data are backed up on a regular basis. CHOOSE ONE

OPTIONS Fully in place · Partially in place · Not in place · Not applicable

FOLLOW-UP Describe the compensating controls in place, or the plan and timeline to close this gap

Restoration of backups is tested regularly. CHOOSE ONE

OPTIONS Fully in place · Partially in place · Not in place · Not applicable

FOLLOW-UP Describe the compensating controls in place, or the plan and timeline to close this gap

External network connections are monitored by an IPS/IDS. CHOOSE ONE

OPTIONS Fully in place · Partially in place · Not in place · Not applicable

FOLLOW-UP Describe the compensating controls in place, or the plan and timeline to close this gap

Physical equipment is subject to a regular maintenance process. CHOOSE ONE

OPTIONS Fully in place · Partially in place · Not in place · Not applicable

FOLLOW-UP Describe the compensating controls in place, or the plan and timeline to close this gap

Step 14 of 21 • Networks & communications

Email systems are protected by technical security controls. CHOOSE ONE

OPTIONS Fully in place · Partially in place · Not in place · Not applicable

FOLLOW-UP Describe the compensating controls in place, or the plan and timeline to close this gap

Insecure protocols (Telnet, FTP, unencrypted instant messaging) are disabled at the network boundary. CHOOSE ONE

OPTIONS Fully in place · Partially in place · Not in place · Not applicable

FOLLOW-UP Describe the compensating controls in place, or the plan and timeline to close this gap

Sensitive data is encrypted, in transit and on physical media, before it leaves the environment. CHOOSE ONE

OPTIONS Fully in place · Partially in place · Not in place · Not applicable

FOLLOW-UP Describe the compensating controls in place, or the plan and timeline to close this gap

Anti-DDoS mechanisms are in place at infrastructure and application level. CHOOSE ONE

OPTIONS Fully in place · Partially in place · Not in place · Not applicable

FOLLOW-UP Describe the compensating controls in place, or the plan and timeline to close this gap

Internet access is monitored, and access to known-harmful sites is blocked. CHOOSE ONE

OPTIONS Fully in place · Partially in place · Not in place · Not applicable

FOLLOW-UP Describe the compensating controls in place, or the plan and timeline to close this gap

Phishing defenses (email filtering, simulation or training, or similar) are in place. CHOOSE ONE

OPTIONS Fully in place · Partially in place · Not in place · Not applicable

FOLLOW-UP Describe the compensating controls in place, or the plan and timeline to close this gap

Step 15 of 21 • Supply chain & sub-processors

Are subcontractors or sub-processors used to perform the service? YES / NO

FOLLOW-UP Name their role (not their identity, if that's easier) and how their access is controlled

Where the solution is hosted by another third party, that hosting contract incorporates information-security requirements. CHOOSE ONE

OPTIONS Fully in place · Partially in place · Not in place · Not applicable

FOLLOW-UP Describe the compensating controls in place, or the plan and timeline to close this gap

There are information-security policies governing supplier relationships and the risk of supplier access to assets. CHOOSE ONE

OPTIONS Fully in place · Partially in place · Not in place · Not applicable

FOLLOW-UP Describe the compensating controls in place, or the plan and timeline to close this gap

The security of the organization's own suppliers is actively monitored. CHOOSE ONE

OPTIONS Fully in place · Partially in place · Not in place · Not applicable

FOLLOW-UP Describe the compensating controls in place, or the plan and timeline to close this gap

Step 16 of 21 · Cryptography & key management

Connections between servers and back-office systems are encrypted (e.g. TLS 1.2 or higher, or IPsec). CHOOSE ONE

OPTIONS Fully in place · Partially in place · Not in place · Not applicable

FOLLOW-UP Describe the compensating controls in place, or the plan and timeline to close this gap

Data is encrypted at rest (e.g. AES-256 or equivalent). CHOOSE ONE

OPTIONS Fully in place · Partially in place · Not in place · Not applicable

FOLLOW-UP Describe the compensating controls in place, or the plan and timeline to close this gap

Passwords are never stored in plaintext - only salted hashes are used to identify users. CHOOSE ONE

OPTIONS Fully in place · Partially in place · Not in place · Not applicable

FOLLOW-UP Describe the compensating controls in place, or the plan and timeline to close this gap

There is a defined policy on the use of cryptographic controls: what must be encrypted, mobile/removable media, the key-management approach, applicable standards, and roles. CHOOSE ONE

OPTIONS Fully in place · Partially in place · Not in place · Not applicable

FOLLOW-UP Describe the compensating controls in place, or the plan and timeline to close this gap

There is a defined key-management procedure covering the full key lifecycle: generation, storage, archival, retrieval, distribution, removal and destruction. CHOOSE ONE

OPTIONS Fully in place · Partially in place · Not in place · Not applicable

FOLLOW-UP Describe the compensating controls in place, or the plan and timeline to close this gap

Unique encryption keys can be issued on a per-customer basis. CHOOSE ONE

OPTIONS Fully in place · Partially in place · Not in place · Not applicable

FOLLOW-UP Describe the compensating controls in place, or the plan and timeline to close this gap

Step 17 of 21 · Threat & incident management

Employees are contractually obliged to report security incidents. CHOOSE ONE

OPTIONS Fully in place · Partially in place · Not in place · Not applicable

FOLLOW-UP Describe the compensating controls in place, or the plan and timeline to close this gap

There is a formal incident-response process: an obligation to report, client notification in the event of a breach, and a response team with defined roles. CHOOSE ONE

OPTIONS Fully in place · Partially in place · Not in place · Not applicable

FOLLOW-UP Describe the compensating controls in place, or the plan and timeline to close this gap

There is an emergency-response process for a fast, effective reaction to serious attacks. CHOOSE ONE

OPTIONS Fully in place · Partially in place · Not in place · Not applicable

FOLLOW-UP Describe the compensating controls in place, or the plan and timeline to close this gap

Relevant authorities are notified where criminal or fraudulent activity is suspected. CHOOSE ONE

OPTIONS Fully in place · Partially in place · Not in place · Not applicable

FOLLOW-UP Describe the compensating controls in place, or the plan and timeline to close this gap

Step 18 of 21 • Physical security & business continuity

Buildings housing critical facilities are protected against unauthorized access. CHOOSE ONE

OPTIONS Fully in place · Partially in place · Not in place · Not applicable

FOLLOW-UP Describe the compensating controls in place, or the plan and timeline to close this gap

Critical facilities are protected against fire, flood and other environmental hazards. CHOOSE ONE

OPTIONS Fully in place · Partially in place · Not in place · Not applicable

FOLLOW-UP Describe the compensating controls in place, or the plan and timeline to close this gap

Critical-facility equipment is protected from power failure and, where needed, climate-controlled. CHOOSE ONE

OPTIONS Fully in place · Partially in place · Not in place · Not applicable

FOLLOW-UP Describe the compensating controls in place, or the plan and timeline to close this gap

The solution, and your data within it, is hosted in a clearly defined, secure location. CHOOSE ONE

OPTIONS Fully in place · Partially in place · Not in place · Not applicable

FOLLOW-UP Describe the compensating controls in place, or the plan and timeline to close this gap

Critical facilities are protected by surveillance, alarm and intrusion-detection systems. CHOOSE ONE

OPTIONS Fully in place · Partially in place · Not in place · Not applicable

FOLLOW-UP Describe the compensating controls in place, or the plan and timeline to close this gap

A continuity plan is in place, based on a risk assessment, for the event of a disaster. CHOOSE ONE

OPTIONS Fully in place · Partially in place · Not in place · Not applicable

FOLLOW-UP Describe the compensating controls in place, or the plan and timeline to close this gap

There is a business-continuity clause or SLA covering the recovery plan, recovery time and recovery point objectives. CHOOSE ONE

OPTIONS Fully in place · Partially in place · Not in place · Not applicable

FOLLOW-UP Describe the compensating controls in place, or the plan and timeline to close this gap

Business-continuity tests are performed annually, with results, lessons learned and action plans reported to customers. CHOOSE ONE

OPTIONS Fully in place · Partially in place · Not in place · Not applicable

FOLLOW-UP Describe the compensating controls in place, or the plan and timeline to close this gap

Step 19 of 21 • Compliance, monitoring & improvement

There is an established program covering legal, regulatory and contractual requirements (e.g. GDPR, PCI DSS) and relevant standards (e.g. ISO/IEC 27001). CHOOSE ONE

OPTIONS Fully in place · Partially in place · Not in place · Not applicable

FOLLOW-UP Describe the compensating controls in place, or the plan and timeline to close this gap

There are documented procedures for monitoring information-security compliance across the organization. CHOOSE ONE

OPTIONS Fully in place · Partially in place · Not in place · Not applicable

FOLLOW-UP Describe the compensating controls in place, or the plan and timeline to close this gap

Breaches of the security policy, or suspected weaknesses, are reported to you as the customer. CHOOSE ONE

OPTIONS Fully in place · Partially in place · Not in place · Not applicable

FOLLOW-UP Describe the compensating controls in place, or the plan and timeline to close this gap

There is a process to transfer part of the risk in the event of an incident (e.g. cyber insurance). CHOOSE ONE

OPTIONS Fully in place · Partially in place · Not in place · Not applicable

FOLLOW-UP Describe the compensating controls in place, or the plan and timeline to close this gap

Networks are supported by documentation, including network configuration diagrams. CHOOSE ONE

OPTIONS Fully in place · Partially in place · Not in place · Not applicable

FOLLOW-UP Describe the compensating controls in place, or the plan and timeline to close this gap

Step 20 of 21 · AI / ML - attack resistance

STEP SHOWN WHEN `involvesAI === "Yes"`

For generative AI/ML applications that interact with users: prompt-injection attacks are mitigated (e.g. input validation and sanitisation before prompts reach the model). CHOOSE ONE

OPTIONS Fully in place · Partially in place · Not in place · Not applicable

FOLLOW-UP Describe the compensating controls in place, or the plan and timeline to close this gap

Model-inversion attacks are mitigated (e.g. privacy-preserving techniques, restricted model access, monitoring). CHOOSE ONE

OPTIONS Fully in place · Partially in place · Not in place · Not applicable

FOLLOW-UP Describe the compensating controls in place, or the plan and timeline to close this gap

Training or model data-poisoning attacks are mitigated (e.g. strict data validation and anomaly detection on training and deployment inputs). CHOOSE ONE

OPTIONS Fully in place · Partially in place · Not in place · Not applicable

FOLLOW-UP Describe the compensating controls in place, or the plan and timeline to close this gap

Model-theft is mitigated (e.g. limiting the specificity of model outputs, or encrypting model files). CHOOSE ONE

OPTIONS Fully in place · Partially in place · Not in place · Not applicable

FOLLOW-UP Describe the compensating controls in place, or the plan and timeline to close this gap

The trained model is isolated from other customers' data and information. CHOOSE ONE

OPTIONS Fully in place · Partially in place · Not in place · Not applicable

FOLLOW-UP Describe the compensating controls in place, or the plan and timeline to close this gap

Step 21 of 21 · AI / ML - data handling & assurance

STEP SHOWN WHEN `involvesAI === "Yes"`

Data ingested by the AI model is hosted in a clearly defined, secure location, in line with GDPR (EU hosting where required). CHOOSE ONE

OPTIONS Fully in place · Partially in place · Not in place · Not applicable

FOLLOW-UP Describe the compensating controls in place, or the plan and timeline to close this gap

The AI system's data handling, model security and deployment environment are audited regularly (e.g. penetration testing). CHOOSE ONE

OPTIONS Fully in place · Partially in place · Not in place · Not applicable

FOLLOW-UP Describe the compensating controls in place, or the plan and timeline to close this gap

The AI solution holds relevant AI-specific certification (e.g. ISO/IEC 42001). CHOOSE ONE

OPTIONS Fully in place · Partially in place · Not in place · Not applicable

FOLLOW-UP Describe the compensating controls in place, or the plan and timeline to close this gap

The AI solution has documented test reports evaluating its accuracy and performance. CHOOSE ONE

OPTIONS Fully in place · Partially in place · Not in place · Not applicable

FOLLOW-UP Describe the compensating controls in place, or the plan and timeline to close this gap

Third-Party Security Assessment: 21 steps, 111 questions.

Part 3 self-test

Cover the answers. Say or write your answer in full before you check it: recall you have to construct is worth several times a line you merely recognise. Answers begin on the next page.

1. A process involves special-category data and the assessor selects no Article 9 condition. What happens to the risk level, and why?
2. How many Article 35(3) triggers make a DPIA mandatory, and what happens at one trigger?
3. Why does the Privacy Assessment risk level never go down?
4. Severity Maximum, likelihood Limited. What is the DPIA risk level, and what would a multiplication have given?
5. Name the three feared events the DPIA rates, and say why those three.
6. What triggers the prior-consultation flag in the DPIA?
7. List the four LIA blockers.
8. In the LIA, which four factors carry the maximum weight of 4 against?
9. Two safeguards are recorded in an LIA. Does that help or hurt?
10. The AI Risk Assessment returns Minimal regulatory risk and High business risk. Is that a contradiction?
11. Write out the ENISA severity formula and say what each term does.
12. Why does pseudonymisation with a secure key move the severity score so much?
13. Give the four ENISA severity bands and the notification outcome of each.
14. When does the 72-hour clock start?
15. A vendor holds payment card data, connects to internal systems, is public-facing and serves more than 1,000 users. What is the inherent score and tier?
16. A Critical inherent risk vendor scores Strong on control maturity. What is the residual band?
17. Why should Not applicable be used sparingly in the vendor assessment?
18. What happens to the residual band if half the controls are left unanswered?

Part 3 self-test: answers

1. A process involves special-category data and the assessor selects no Article 9 condition. What happens to the risk level, and why?
It escalates to High. Special-category data cannot be processed on an Article 6 lawful basis alone, so a missing Article 9 condition is not a documentation gap, it is a lawfulness gap.
2. How many Article 35(3) triggers make a DPIA mandatory, and what happens at one trigger?
Two or more makes it Required. One makes it Required if the risk level is already High, and Recommended otherwise.
3. Why does the Privacy Assessment risk level never go down?
It uses an escalate-only function. Each factor can raise the level but nothing lowers it, so the outcome is set by the single worst finding rather than by an average that good answers could dilute.
4. Severity Maximum, likelihood Limited. What is the DPIA risk level, and what would a multiplication have given?
High. A product would have given $4 \times 2 = 8$, ranking it below significant severity at significant likelihood ($3 \times 3 = 9$), which understates an irreversible impact on individuals. The matrix sets a floor so nothing at Maximum severity falls below High.
5. Name the three feared events the DPIA rates, and say why those three.
Illegitimate access, unwanted modification, and data disappearance. Between them they exhaust what can go wrong with data: someone sees it who should not, it is changed, or it is gone.
6. What triggers the prior-consultation flag in the DPIA?
Residual risk at High or Very High combined with an answer that the residual risk is not acceptable.
7. List the four LIA blockers.
No purpose recorded; the necessity test not met on either limb; a less intrusive alternative exists; special-category or criminal-offence data is involved.
8. In the LIA, which four factors carry the maximum weight of 4 against?
Likely to cause harm or distress; the processing limits or undermines individual rights; no privacy notice covering the purpose; the individual cannot easily object.
9. Two safeguards are recorded in an LIA. Does that help or hurt?
It hurts slightly. Three or more count as a factor in favour; one or two are recorded as a factor against, because safeguards are the main lever available for tipping a balance.
10. The AI Risk Assessment returns Minimal regulatory risk and High business risk. Is that a contradiction?
No. The two levels are independent by design. A system outside Annex III can still have broad autonomous action without logging, or process business-critical data without oversight, which is a real operational risk even where the Act imposes little.
11. Write out the ENISA severity formula and say what each term does.
 $SE = (DPC \times EI) + CB$. DPC is the data processing context, 1 to 4, from the most serious data family involved. EI is ease of identification, a correcting factor from 0.25 to 1. CB is the circumstances of the breach, up to 1.5, from loss of confidentiality, integrity and availability.

12. Why does pseudonymisation with a secure key move the severity score so much?
Because EI multiplies rather than adds. Driving ease of identification down toward 0.25 cuts the DPC term by three quarters before CB is even added.
13. Give the four ENISA severity bands and the notification outcome of each.
Below 2 Low: no notification. Below 3 Medium: notify the authority. Below 4 High: notify the authority and the individuals. 4 and above Very High: the same, with the highest urgency.
14. When does the 72-hour clock start?
From the moment the incident qualified as a personal data breach, not from discovery and not from confirmation of the full facts.
15. A vendor holds payment card data, connects to internal systems, is public-facing and serves more than 1,000 users. What is the inherent score and tier?
 $1.5 + 1 + 1 + 1.5 = 5$, which is High (the High band runs from 4 up to but not including 6). Adding personal data as well would take it to 6 and into Critical.
16. A Critical inherent risk vendor scores Strong on control maturity. What is the residual band?
Medium. Nothing at Critical inherent risk falls below Medium residual, whatever the controls, for the same reason the DPIA matrix sets a floor.
17. Why should Not applicable be used sparingly in the vendor assessment?
It is the only answer removed from scoring rather than counted as zero, so it is the only one that can flatter the maturity average. Not in place is the honest answer when you are unsure.
18. What happens to the residual band if half the controls are left unanswered?
The maturity tier is withheld and the residual band is reported as provisional, falling back to the inherent tier. Unanswered is not the same as good.

PART 4

The GDPR Readiness Model

71 privacy management activities in 13 categories,
mapped to 37 GDPR Articles, with the two evidence ques-
tions that decide each one.

The method

WHAT IT IS FOR Measure demonstrable accountability by recording which privacy management activities you perform, then deriving which GDPR Articles those activities evidence.

SHAPE 13 scope questions, then 71 activities in 13 categories. Each activity carries two evidence questions: a Privacy Office question (does the mechanism exist and is it built correctly) and an Operational Unit question (does it reflect what actually happens).

WHAT IT RETURNS An overall percentage, a score per category, a score per Article, and a gap list ordered worst first. State lives in localStorage only, with Save, Load, Clear, Forget and an Excel export.

HOW THE SCORING WORKS

- The inversion is the method. The unit of assessment is an activity you perform, not a legal requirement you must meet, because activities are finite and observable while legal requirements are open-ended.
- Four statuses: Implemented scores 1, In progress scores 0.5, Not in place scores 0, Not applicable is removed from the scoring set entirely.
- The 13 scope questions come first. Answering no removes the activities gated on that condition from scoring, rather than counting them as failures.
- The overall score is the mean activity score across in-scope, non-excluded activities. A category score is the mean of its activities. An Article score is the mean of the activities that evidence it.
- Bands: 0.85 and above is good, 0.5 and above is fair, above 0 is weak, 0 is bad.
- The gap list sorts by score ascending, then by the number of Articles the activity evidences descending, so the lowest-scoring activity touching the most Articles comes first.

WHERE PEOPLE GET IT WRONG

- Implemented means you could put evidence in front of a regulator today. A policy saying you should do it is not the same as doing it.
- Not in place is also the correct answer when you do not know, because an activity nobody can confirm is not evidence of anything.
- Not applicable is the only status that can flatter the result. Most genuine non-applicability is already handled by the scope questions.
- Coverage is deliberately partial: only Articles a management activity can evidence are scored. Scope, definitions and Member State provisions are out of scope, so a high score is not a claim of blanket compliance.
- One weak activity can drag several Article scores at once, which is exactly what the gap ordering is designed to surface.

SOURCES [4] [5] [17]

The four statuses

STATUS	SCORE	WHAT IT MEANS
Implemented	1	You actually do this, it is operating now, and you could put evidence in front of a regulator today. Having a policy that says you should do it is not the same as doing it.
In progress	0.5	Started but not finished. Approved and underway, partially rolled out, or working in some parts of the business but not others. Counts as half.

STATUS	SCORE	WHAT IT MEANS
Not in place	0	Not happening, or happening informally with nothing to show for it. This is also the right answer when you do not know, because an activity nobody can confirm is not evidence of anything.
Not applicable	excluded	Genuinely cannot apply to your organisation. This one is removed from the score rather than counted against you, so it is the only status that can flatter the result. Use it sparingly, and prefer Not in place if you are unsure. Most cases that truly do not apply are already handled by the scope questions above.

The 13 scope questions

Answering no to one of these removes the activities gated on it from scoring, rather than counting them as failures.

1. Does the organisation process personal data on behalf of another organisation, acting as a processor? PROCESSOR
2. Does the organisation process special categories of personal data, such as health, biometric or trade union data? SPECIAL
3. Does the organisation process personal data relating to criminal convictions or offences? CRIMINAL
4. Is the organisation established outside the EU while offering goods or services to, or monitoring, people in the EU? OUTSIDE EU
5. Has the organisation appointed a Data Protection Officer, or is it required to appoint one? DPO
6. Does the organisation rely on consent as a legal basis for any processing? CONSENT
7. Does the organisation offer online services directly to children? CHILDREN
8. Does the organisation make automated decisions, including profiling, that have legal or similarly significant effects on people? AUTOMATED
9. Does the organisation transfer personal data outside the EEA? TRANSFERS
10. Does the organisation rely on the Article 49 derogations for any occasional transfers? DEROGATIONS
11. Does the organisation act as a joint controller with another organisation? JOINT
12. Does the organisation obtain personal data from sources other than the individual concerned? INDIRECT
13. Does the organisation process personal data for archiving in the public interest, scientific or historical research, or statistical purposes? RESEARCH

The 71 activities

Each activity carries two evidence questions. **PO** is the Privacy Office question: does the mechanism exist and is it built correctly. **OU** is the Operational Unit question: does it reflect what actually happens. The Articles listed are the ones the activity evidences.

1. Governance and accountability 6 activities

G1 Assign overall responsibility for data protection to a named individual

PO Is there a named individual with documented overall responsibility for data protection?

OU Does your area know who to approach for data protection decisions and escalations?

Art. 24

G2 Appoint a Data Protection Officer with an independent reporting line

PO Has a Data Protection Officer been appointed and their contact details published and notified to the supervisory authority?

OU

Art. 37 · scoped on: dpo

G3 Define the DPO's tasks, resources and independence in writing

PO Are the DPO's tasks, resourcing and freedom from instruction documented, with direct access to senior management?

OU Is the DPO involved early in matters in your area that affect personal data?

Art. 38, 39 · scoped on: dpo

G4 Define data protection roles and responsibilities across functions

PO Are data protection responsibilities documented for each function that handles personal data?

OU Does your area have a named person responsible for data protection matters?

Art. 24

G5 Report on data protection performance to senior management

PO Is data protection performance reported to senior management on a defined cycle?

OU Does your area contribute data or metrics to that reporting?

Art. 24

G6 Appoint a representative in the Union

PO Has a representative in the Union been appointed in writing and identified in privacy notices?

OU

Art. 27 · scoped on: outsideEU

2. Personal data inventory and records 6 activities

I1 Maintain a record of processing activities carried out as controller

PO Is a record of processing activities maintained, covering purposes, categories of data and recipients, retention and security measures?

OU Have your area's processing activities been recorded and confirmed as current?

Art. 30

I2 Maintain a record of processing carried out on behalf of others

PO Is a separate record maintained for processing carried out on behalf of other controllers?

OU Does your area carry out processing on behalf of a client, and is it recorded?

Art. 30 · scoped on: processor

I3 Document the legal basis for each processing activity

PO Is the legal basis identified and documented for every processing activity?

OU Do you know the legal basis for the personal data your area processes?

Art. 5, 6

I4 Document the condition relied on for special category data

PO Is the Article 9 condition documented for each activity involving special category data?

OU Does your area process special category data, and is the basis for doing so recorded?

Art. 9 • scoped on: special

I5 Document the authority for processing criminal offence data

PO Is processing of criminal conviction and offence data carried out under official authority or authorised by law, and documented?

OU Does your area process criminal record information, and under what authority?

Art. 10 • scoped on: criminal

I6 Record international transfers and the safeguards applied

PO Does the record of processing identify transfers outside the EEA and the safeguard relied on for each?

OU Does your area send personal data outside the EEA, including to vendors or affiliates?

Art. 30, 44 • scoped on: transfers

3. Policies and internal rules 3 activities**P1 Maintain a data protection policy approved at senior level**

PO Is there an approved data protection policy that applies across the organisation?

OU Is your area aware of the data protection policy and how it applies to its work?

Art. 24

P2 Maintain procedures that give effect to the data protection principles

PO Are there working procedures covering lawfulness, fairness, transparency, minimisation, accuracy, storage limitation and security?

OU Does your area follow documented procedures when handling personal data?

Art. 5

P3 Review and update policies and procedures on a defined cycle

PO Are policies reviewed on a defined cycle and after material change, with the review evidenced?

OU Is your area notified when a policy change affects how it must work?

Art. 24

4. Embedding privacy into operations 11 activities**E1 Apply data protection by design to new systems and processes**

PO Is data protection built into the design stage of new systems, products and processes, with the consideration evidenced?

OU Is data protection considered before your area starts a new system or process, rather than afterwards?

Art. 25

E2 Apply data protection by default to settings and data volumes

PO Are default settings configured so that only the personal data necessary for each purpose is processed?

OU Are the defaults in your area's tools set to collect and expose the minimum necessary?

Art. 25

E3 Maintain procedures for obtaining and recording valid consent

PO Where consent is relied on, is it freely given, specific, informed and unambiguous, and is a record of it kept?

OU Does your area collect consent, and is what the person agreed to recorded?

Art. 7 • scoped on: consent

E4 Provide a withdrawal mechanism as easy to use as giving consent

PO Can individuals withdraw consent as easily as they gave it, with withdrawal applied promptly?

OU Can people your area deals with withdraw consent easily, and is it acted on?

Art. 7 • scoped on: consent

E5 Verify parental authorisation for children's online services

PO Are reasonable efforts made to verify parental authorisation where online services are offered to children below the applicable age?

OU Does your area's service reach children, and is age or parental authorisation checked?

Art. 8 · scoped on: children

E6 Assess compatibility before using data for a new purpose

PO Is a compatibility assessment carried out, or a fresh basis obtained, before personal data is used for a new purpose?

OU Does your area check the original purpose before reusing personal data for something new?

Art. 5, 6

E7 Apply data minimisation controls at the point of collection

PO Are collection points reviewed so that only adequate, relevant and necessary data is gathered?

OU Are your area's forms and systems limited to the fields actually needed?

Art. 5

E8 Maintain controls that keep personal data accurate and current

PO Are there controls to keep personal data accurate and to correct it without delay?

OU Does your area have a way to correct inaccurate personal data it holds?

Art. 5

E9 Maintain retention schedules and routine deletion

PO Is a retention schedule defined for each category of personal data, with deletion carried out when it expires?

OU Does your area know how long it may keep personal data, and is it deleted on time?

Art. 5

E10 Apply safeguards for archiving, research and statistical processing

PO Are safeguards such as minimisation and pseudonymisation applied to archiving, research or statistical processing?

OU Does your area use personal data for research or statistics, and with what safeguards?

Art. 89 · scoped on: research

E11 Control automated decision-making and profiling

PO Are automated decisions with legal or similarly significant effects identified, justified and subject to human intervention?

OU Does your area make decisions about people automatically, and can a person intervene?

Art. 22 · scoped on: automated

5. Training and awareness 3 activities**T1 Deliver data protection training to all staff**

PO Do all staff who handle personal data receive data protection training on joining and periodically thereafter?

OU Has everyone in your area who handles personal data completed the training?

Art. 24, 39

T2 Deliver role-specific training to higher-risk functions

PO Do functions handling higher-risk processing receive training tailored to their activities?

OU Has your area received training specific to the personal data it actually handles?

Art. 39

T3 Maintain records of training completion

PO Are training completion records kept and followed up where training is outstanding?

OU Can your area evidence who has completed training and when?

Art. 24

6. Information security 6 activities**S1** Implement security measures appropriate to the risk

PO Are technical and organisational security measures determined by reference to the risk to individuals, and documented?

OU Are the systems your area uses covered by the organisation's security controls?

Art. 32

S2 Apply pseudonymisation or encryption where appropriate

PO Are pseudonymisation and encryption applied where they are an appropriate measure for the risk?

OU Is personal data in your area encrypted at rest and in transit where required?

Art. 32

S3 Maintain confidentiality, integrity, availability and resilience

PO Are measures in place to maintain confidentiality, integrity, availability and resilience, including restoration after an incident?

OU Can your area restore access to personal data after a system failure?

Art. 32

S4 Test and evaluate the effectiveness of security measures

PO Are security measures tested and evaluated on a regular basis, with findings remediated?

OU Are the systems your area relies on included in security testing?

Art. 32

S5 Ensure staff process personal data only on documented instruction

PO Are staff and contractors bound to process personal data only on documented instruction and under a duty of confidence?

OU Do people in your area understand they may only use personal data as instructed?

Art. 29, 32

S6 Maintain access control and periodic access review

PO Is access to personal data restricted by role and reviewed periodically, with leavers removed promptly?

OU Is access in your area limited to those who need it, and reviewed?

Art. 32

7. Third parties and processors 6 activities**V1** Carry out due diligence on processors before engagement

PO Are processors assessed for sufficient guarantees before they are engaged, with the assessment recorded?

OU Does your area check a supplier's data protection measures before sharing personal data?

Art. 28

V2 Put a written processing agreement in place with each processor

PO Is a written contract covering the Article 28 terms in place with every processor?

OU Do your area's suppliers who handle personal data have a signed agreement in place?

Art. 28

V3 Control the engagement of sub-processors

PO Are sub-processors engaged only with authorisation, and are they bound to equivalent obligations?

OU Do you know whether your area's suppliers subcontract any handling of personal data?

Art. 28

V4 Maintain a lawful mechanism for transfers outside the EEA

PO Is every transfer outside the EEA covered by an adequacy decision or appropriate safeguards, and documented?

OU Are your area's transfers outside the EEA covered by an approved mechanism?

Art. 44, 45, 46 · scoped on: transfers

V5 Document derogations relied on for occasional transfers

PO Where a derogation is relied on, is the transfer occasional, necessary and documented?

OU Does your area rely on one-off exceptions to transfer data abroad?

Art. 49 · scoped on: derogations

V6 Define and publish joint controller arrangements

PO Is there an arrangement setting out respective responsibilities with each joint controller, the essence of which is available to individuals?

OU Does your area decide purposes jointly with another organisation?

Art. 26 · scoped on: joint

8. Transparency and notices 4 activities**N1 Provide privacy information at the point of collection**

PO Is privacy information provided at the time personal data is collected from the individual?

OU Does every point where your area collects personal data show a privacy notice?

Art. 13

N2 Provide privacy information where data is obtained indirectly

PO Where data is obtained from another source, is the individual informed within the required period, including the source?

OU Does your area obtain personal data from third parties, and are those people informed?

Art. 14 · scoped on: indirect

N3 Maintain notices in clear, plain and accessible language

PO Are privacy notices concise, transparent, intelligible and easily accessible, in plain language?

OU Are the notices your area uses understandable to the people who receive them?

Art. 12

N4 Keep notices aligned with actual processing

PO Are notices reviewed and updated when processing changes, so they describe what actually happens?

OU Does your area's notice still match what it actually does with personal data?

Art. 12, 13, 14

9. Handling individual rights 10 activities**R1 Maintain a procedure to receive and log rights requests**

PO Is there a defined route for receiving rights requests through any channel, with central logging?

OU Does your area know how to recognise a rights request and where to send it?

Art. 12

R2 Verify the identity of the requester before disclosure

PO Is identity verified proportionately before personal data is disclosed in response to a request?

OU Does your area avoid releasing data before identity has been confirmed centrally?

Art. 12

R3 Track and meet the statutory response deadline

PO Are requests tracked against the one-month deadline, with extensions notified within the first month?

OU Does your area supply information for requests within the internal deadline it is given?

Art. 12

R4 Handle access requests and provide a copy of the data

PO Can the organisation locate and provide a copy of an individual's personal data along with the required supplementary information?

OU Can your area locate all personal data it holds about a named individual?

Art. 15

R5 Handle rectification requests

PO Are inaccurate data corrected without undue delay, including incomplete data?

OU Can your area correct personal data in its systems when asked?

Art. 16

R6 Handle erasure requests and notify recipients

PO Are erasure requests assessed against the grounds and exemptions, with recipients notified where required?

OU Can your area delete an individual's data across its systems when instructed?

Art. 17, 19

R7 Handle restriction requests and notify recipients

PO Can processing be restricted rather than deleted where the grounds apply, with recipients notified?

OU Can your area suspend use of a record without deleting it?

Art. 18, 19

R8 Handle portability requests in a machine-readable format

PO Can data provided by the individual and processed by consent or contract be exported in a structured, commonly used, machine-readable format?

OU Can your area export an individual's data in a reusable format?

Art. 20

R9 Handle objections, including to direct marketing

PO Are objections acted on, with direct marketing stopped immediately and suppression applied?

OU Are objections and marketing opt-outs applied in your area's systems without delay?

Art. 21

R10 Handle requests concerning automated decisions

PO Can individuals obtain human intervention, express their point of view and contest an automated decision?

OU Is there a route for someone to challenge an automated decision made in your area?

Art. 22 · scoped on: automated

10. Assessing new and changed processing 5 activities**A1 Screen new processing for whether a DPIA is required**

PO Is new processing screened against DPIA criteria, with the screening decision recorded either way?

OU Does your area flag new processing for assessment before it starts?

Art. 35

A2 Conduct DPIAs where processing is likely to be high risk

PO Are DPIAs carried out where processing is likely to result in a high risk, covering necessity, proportionality and mitigation?

OU Has your area completed an assessment for its higher-risk processing?

Art. 35

A3 Seek the DPO's advice when carrying out a DPIA

PO Is the DPO's advice sought and recorded when a DPIA is carried out?

OU

Art. 35 · scoped on: dpo

A4 Consult the supervisory authority where high residual risk remains

PO Is the supervisory authority consulted before processing where a DPIA shows high risk that cannot be mitigated?

OU

Art. 36

A5 Reassess when processing changes materially

PO Is an existing assessment revisited when the scope, data or technology of the processing changes?

OU Does your area revisit its assessment when a project's scope changes?

Art. 35

11. Breach management 5 activities**B1 Maintain a breach detection, reporting and escalation procedure**

PO Is there a documented procedure for detecting, reporting and escalating personal data breaches?

OU Does your area know how to report a suspected breach and to whom, without delay?

Art. 33

B2 Assess breach severity against the notification threshold

PO Is each breach assessed for risk to individuals to determine whether notification is required?

OU Does your area provide the facts needed to assess a breach quickly?

Art. 33

B3 Notify the supervisory authority within 72 hours where required

PO Can a notifiable breach be reported to the supervisory authority within 72 hours of awareness?

OU

Art. 33

B4 Communicate to affected individuals where the risk is high

PO Are individuals informed without undue delay where a breach is likely to result in a high risk to them?

OU Can your area help identify and reach the individuals affected by a breach?

Art. 34

B5 Maintain an internal record of all breaches

PO Are all breaches recorded, including those not notified, with the facts, effects and remedial action?

OU Are incidents in your area recorded even when they are not reportable?

Art. 33

12. Monitoring and assurance 4 activities**M1 Monitor operational compliance with policies and procedures**

PO Is compliance with data protection policies monitored in practice rather than assumed?

OU Is your area's handling of personal data checked periodically?

Art. 24

M2 Audit processing activities periodically

PO Are processing activities audited on a risk-based cycle, with findings tracked to closure?

OU Has your area's processing been audited, and were findings addressed?

Art. 24

M3 Monitor processor compliance during the engagement

PO Are processors monitored during the engagement, not only assessed at onboarding?

OU Does your area review supplier performance against data protection obligations?

Art. 28

M4 Maintain documentation sufficient to demonstrate compliance

PO Is documentation maintained such that compliance could be demonstrated to a supervisory authority on request?

OU Could your area evidence how it handles personal data if asked?

Art. 5, 24

13. Tracking external requirements 2 activities**X1** Track changes in data protection law and guidance

PO Is there a defined way of tracking legal change and translating it into required action?

OU Is your area told when a legal change affects how it must operate?

Art. 24

X2 Track supervisory authority guidance and enforcement

PO Is regulator guidance and enforcement activity monitored and reflected in internal practice?

OU Does your area receive relevant regulator guidance affecting its work?

Art. 24

Article index

The reverse view: which activities evidence each Article. An Article scores the mean of the activities listed against it, so an Article with one activity behind it is fragile and an Article with six is not.

ART.	TITLE	EVIDENCED BY
5	Principles relating to processing of personal data	I3, P2, E6, E7, E8, E9, M4
6	Lawfulness of processing	I3, E6
7	Conditions for consent	E3, E4
8	Conditions applicable to child's consent for information society services	E5
9	Processing of special categories of personal data	I4
10	Processing relating to criminal convictions and offences	I5
12	Transparent information, communication and modalities	N3, N4, R1, R2, R3
13	Information to be provided where data are collected from the data subject	N1, N4
14	Information to be provided where data have not been obtained from the data subject	N2, N4
15	Right of access by the data subject	R4
16	Right to rectification	R5
17	Right to erasure (right to be forgotten)	R6
18	Right to restriction of processing	R7
19	Notification obligation regarding rectification, erasure or restriction	R6, R7
20	Right to data portability	R8
21	Right to object	R9
22	Automated individual decision-making, including profiling	E11, R10
24	Responsibility of the controller	G1, G4, G5, P1, P3, T1, T3, M1, M2, M4, X1, X2
25	Data protection by design and by default	E1, E2
26	Joint controllers	V6
27	Representatives of controllers or processors not established in the Union	G6
28	Processor	V1, V2, V3, M3
29	Processing under the authority of the controller or processor	S5
30	Records of processing activities	I1, I2, I6
32	Security of processing	S1, S2, S3, S4, S5, S6

ART.	TITLE	EVIDENCED BY
33	Notification of a personal data breach to the supervisory authority	B1, B2, B3, B5
34	Communication of a personal data breach to the data subject	B4
35	Data protection impact assessment	A1, A2, A3, A5
36	Prior consultation	A4
37	Designation of the data protection officer	G2
38	Position of the data protection officer	G3
39	Tasks of the data protection officer	G3, T1, T2
44	General principle for transfers	I6, V4
45	Transfers on the basis of an adequacy decision	V4
46	Transfers subject to appropriate safeguards	V4
49	Derogations for specific situations	V5
89	Safeguards for archiving, research and statistical purposes	E10

Part 4 self-test

Cover the answers. Say or write your answer in full before you check it: recall you have to construct is worth several times a line you merely recognise. Answers begin on the next page.

1. What is inverted in this model, and why does the inversion matter?
2. Give the four statuses and their scores.
3. Why are there 13 scope questions before the activities?
4. You have a written policy requiring annual privacy training but no training has run this year. What status?
5. Someone answers Not applicable to an activity they are unsure about. What is wrong with that?
6. How is an Article's score calculated?
7. What are the two evidence questions on each activity for, and why two?
8. What does a score of 90% not tell you?
9. How is the gap list ordered, and why that order?

Part 4 self-test: answers

1. What is inverted in this model, and why does the inversion matter?
The unit of assessment. Instead of asking whether you meet each legal requirement, it asks which management activities you perform and derives the Articles those evidence. Activities are finite and observable, which makes the assessment repeatable; legal requirements are open-ended, which makes checklists against them drift.
2. Give the four statuses and their scores.
Implemented 1, In progress 0.5, Not in place 0, Not applicable removed from the scoring set.
3. Why are there 13 scope questions before the activities?
So that activities which genuinely cannot apply are removed from scoring rather than counted as failures. Answering no to a scope question drops the activities gated on it.
4. You have a written policy requiring annual privacy training but no training has run this year. What status?
Not in place, or In progress at best. Implemented means the activity is operating now and you could evidence it today; a policy saying you should do it is not evidence that you do.
5. Someone answers Not applicable to an activity they are unsure about. What is wrong with that?
Not applicable is the only status removed from the scoring set, so it is the only one that can inflate the result. The correct answer when unsure is Not in place, since an activity nobody can confirm evidences nothing.
6. How is an Article's score calculated?
As the mean of the scores of the in-scope activities that evidence that Article. One weak activity therefore drags every Article it maps to.
7. What are the two evidence questions on each activity for, and why two?
The Privacy Office question asks whether the mechanism exists and is built correctly. The Operational Unit question asks whether it reflects what actually happens on the ground. Two questions because a mechanism that exists centrally and is ignored locally scores well on the first and badly on the second, and that gap is the finding.
8. What does a score of 90% not tell you?
That you are compliant. The model measures demonstrable accountability across the Articles a management activity can evidence. Scope, definitions and Member State provisions are outside it entirely.
9. How is the gap list ordered, and why that order?
By activity score ascending, then by the number of Articles the activity evidences descending. It puts the lowest-scoring activity with the widest Article footprint first, so the first fix buys the most evidential coverage.

APPENDIX

Reference lists

Appendix A. Long option lists

Countries and regions 209 entries

Global / worldwide (all countries) · Whole EU/EEA (all member states) · Whole European Union (EU) only · Whole EFTA (Iceland, Liechtenstein, Norway, Switzerland) · Whole United Kingdom · Whole North America (US & Canada) · Whole Latin America & the Caribbean · Whole Asia-Pacific (APAC) · Whole Middle East · Whole Africa · Afghanistan · Albania · Algeria · Andorra · Angola · Antigua and Barbuda · Argentina · Armenia · Australia · Austria · Azerbaijan · Bahamas · Bahrain · Bangladesh · Barbados · Belarus · Belgium · Belize · Benin · Bhutan · Bolivia · Bosnia and Herzegovina · Botswana · Brazil · Brunei · Bulgaria · Burkina Faso · Burundi · Cabo Verde · Cambodia · Cameroon · Canada · Central African Republic · Chad · Chile · China · Colombia · Comoros · Congo (Republic of the) · Congo (Democratic Republic of the) · Costa Rica · Croatia · Cuba · Cyprus · Czechia · Denmark · Djibouti · Dominica · Dominican Republic · Ecuador · Egypt · El Salvador · Equatorial Guinea · Eritrea · Estonia · Eswatini · Ethiopia · Fiji · Finland · France · Gabon · Gambia · Georgia · Germany · Ghana · Greece · Grenada · Guatemala · Guinea · Guinea-Bissau · Guyana · Haiti · Honduras · Hong Kong SAR · Hungary · Iceland · India · Indonesia · Iran · Iraq · Ireland · Israel · Italy · Jamaica · Japan · Jordan · Kazakhstan · Kenya · Kiribati · Kosovo · Kuwait · Kyrgyzstan · Laos · Latvia · Lebanon · Lesotho · Liberia · Libya · Liechtenstein · Lithuania · Luxembourg · Macau SAR · Madagascar · Malawi · Malaysia · Maldives · Mali · Malta · Marshall Islands · Mauritania · Mauritius · Mexico · Micronesia · Moldova · Monaco · Mongolia · Montenegro · Morocco · Mozambique · Myanmar · Namibia · Nauru · Nepal · Netherlands · New Zealand · Nicaragua · Niger · Nigeria · North Korea · North Macedonia · Norway · Oman · Pakistan · Palau · Palestine · Panama · Papua New Guinea · Paraguay · Peru · Philippines · Poland · Portugal · Qatar · Romania · Russia · Rwanda · Saint Kitts and Nevis · Saint Lucia · Saint Vincent and the Grenadines · Samoa · San Marino · Sao Tome and Principe · Saudi Arabia · Senegal · Serbia · Seychelles · Sierra Leone · Singapore · Slovakia · Slovenia · Solomon Islands · Somalia · South Africa · South Korea · South Sudan · Spain · Sri Lanka · Sudan · Suriname · Sweden · Switzerland · Syria · Taiwan · Tajikistan · Tanzania · Thailand · Timor-Leste · Togo · Tonga · Trinidad and Tobago · Tunisia · Turkey · Turkmenistan · Tuvalu · Uganda · Ukraine · United Arab Emirates · United Kingdom · United States · Uruguay · Uzbekistan · Vanuatu · Vatican City · Venezuela · Vietnam · Yemen · Zambia · Zimbabwe · Other

Appendix B. Fifteen-minute review card

The whole pack compressed to what is worth knowing cold. Time yourself: fifteen minutes is the target once the material is in place.

Privacy, the rules that decide most cases

- **Consent is only valid where refusal is free of consequence.** Informed, voluntary, specific and current, given by someone with capacity. A notice is not consent.
- **Special categories:** racial or ethnic origin, political opinions, religious or philosophical beliefs, trade union membership, genetic data, biometric data used to uniquely identify a person, health, sex life or sexual orientation. Needs an Article 9 condition on top of the Article 6 basis.
- **A rights request needs no legal wording.** Escalate immediately; do not verify identity or respond yourself. One month under GDPR-style regimes, extendable by two with notice inside the first month.
- **Report incidents on suspicion, not on certainty.** Notification clocks run from organisational awareness, in hours.
- **Never release data to an external requester directly.** Gather requester, legal basis and precise scope, then escalate.
- **Secondary use:** confirm the original purpose first; a new purpose may need a new notice, consent, basis, assessment or safeguards.
- **Marketing is defined by primary purpose.** Consent is channel-specific. A promotional link converts an operational message into marketing.
- **Four classification labels:** public, internal, confidential, highly confidential. When in doubt, more restrictive.

AI Act, the numbers and lists

- **Four roles:** provider, deployer, importer, distributor. Modifying or rebranding turns a deployer into a provider.
- **Three territorial triggers:** placing on the EU market from anywhere; EU-established deployer; output used in the EU from anywhere.
- **Ten prohibited practices:** subliminal or deceptive manipulation; exploiting vulnerability; social scoring; predictive policing by profiling alone; emotion inference at work or in education; untargeted facial scraping; biometric categorisation inferring protected traits; real-time remote biometric identification in public by law enforcement; and from 2 December 2026, generating non-consensual intimate imagery and generating child sexual abuse material.
- **Two routes to high-risk:** the Annex III use-case list, and regulated products or safety components. Run both.
- **Eight Annex III categories:** biometrics; critical infrastructure; education; employment; essential services and benefits; law enforcement; migration and borders; justice and democratic processes.
- **Twelve provider obligations:** risk management, data governance, technical documentation, logging, instructions for use, human oversight, accuracy and robustness and cybersecurity, quality management, accessibility, conformity assessment, registration, cooperation.
- **FRIA applies to three groups only:** public-law bodies, public-service providers, and credit scoring or life and health insurance pricing. Applies from 2 December 2027.
- **GPAI:** four baseline duties, open-source carve-out cancelled by systemic risk, 10^{25} FLOPS as the systemic-risk proxy, five extra duties above it.

- **Dates:** in force 1 Aug 2024; prohibitions 2 Feb 2025; GPAI 2 Aug 2025; transparency and penalties 2 Aug 2026; Annex III high-risk 2 Dec 2027; Annex I 2 Aug 2028 (Regulation (EU) 2026/1744).
- **Penalties:** 7% or EUR 35m; 3% or EUR 15m; 1% or EUR 7.5m. Whichever is higher.

The six tools, one line each

- **Privacy Assessment.** Escalate-only level. Two Article 35(3) triggers make a DPIA mandatory; one makes it mandatory at High.
- **Full DPIA.** Severity x likelihood through a 4 x 4 lookup, not a product. Nothing at Maximum severity falls below High. Three feared events: access, modification, disappearance.
- **Legitimate Interest Test.** Four blockers override the balance. Against-weights 1 to 4, for-factors 2 each. 12 or more against is unlikely to be available; 6 or more is finely balanced.
- **AI Risk Assessment.** Two independent levels: regulatory from prohibited-use and Annex III answers, business from autonomy, data access, logging and guardrails.
- **Incident & Breach Severity.** $SE = (DPC \times EI) + CB$. DPC 1 to 4, EI 0.25 to 1, CB up to 1.5. Bands at 2, 3 and 4. Medium notifies the authority; High notifies individuals too.
- **Third-Party Security.** Inherent risk out of 9 from intake alone, maturity from the control answers, residual from a lookup. Critical inherent never falls below Medium residual.

The readiness model

- **The inversion:** record activities you perform, derive the Articles they evidence. 71 activities, 13 categories, 13 scope questions, 37 Articles.
- **Statuses:** Implemented 1, In progress 0.5, Not in place 0, Not applicable excluded. Not in place is the right answer when you do not know.
- **Two evidence questions per activity:** does the mechanism exist and is it correct (Privacy Office), and does it reflect what actually happens (Operational Unit). The gap between them is the finding.
- **Gap order:** lowest score first, then widest Article footprint. The first fix buys the most coverage.
- **What a high score does not mean:** compliance. It measures demonstrable accountability across the Articles an activity can evidence.

SOURCES [5] [6] [9] [19]

Appendix C. Sources

Every [n] in this pack points here. The first four are the site itself, as extracted on the date shown; the rest are the primary texts and published methods the pages and tools rest on. For what has changed since the pages were written, see the companion verification report [19].

1. Practical Privacy, site page (practical-privacy.html), as extracted on 19 September 2026.
2. Practical AI Act Advice, site page (practical-ai-act-advice.html), as extracted on 19 September 2026.
3. Privacy & AI Assessment tools, source file pages/privacy-ai-assessment/assessment.js (six tools, 68 steps, 337 questions), as extracted on 19 September 2026.
4. GDPR Readiness model, source files pages/gdpr-readiness/readiness-data.js and readiness.js (71 activities, 13 categories, 13 scope questions, 37 Articles), as extracted on 19 September 2026.
5. Regulation (EU) 2016/679 (GDPR), Articles 5, 6, 9, 12, 14, 22, 28, 30, 33 to 36, 44 to 49: <https://eur-lex.europa.eu/eli/reg/2016/679/oj>
6. Regulation (EU) 2024/1689 (AI Act) as amended by Regulation (EU) 2026/1744 (Digital Omnibus on AI, in force 27 July 2026): <https://eur-lex.europa.eu/eli/reg/2024/1689/oj> and <https://eur-lex.europa.eu/eli/reg/2026/1744/oj>
7. Article 29 Working Party, Guidelines on Data Protection Impact Assessment, WP248 rev.01 (endorsed by the EDPB): the nine criteria and the two-criteria rule used by the Privacy Assessment: <https://ec.europa.eu/newsroom/article29/items/611236>
8. EDPB Guidelines 1/2024 on processing of personal data based on Article 6(1)(f) GDPR (version for consultation, 8 October 2024): the three-step test used by the Legitimate Interest Test: https://www.edpb.europa.eu/our-work-tools/documents/public-consultations/2024/guidelines-12024-processing-personal-data-based_en
9. ENISA, Recommendations for a methodology of the assessment of severity of personal data breaches (December 2013): $SE = (DPC \times EI) + CB$, scales and bands used by the Incident tool: <https://www.enisa.europa.eu/publications/dbn-severity>
10. EDPB Guidelines 01/2021 on examples regarding personal data breach notification (v2.0, December 2021): the EDPB cross-check in the Incident tool: https://www.edpb.europa.eu/our-work-tools/our-documents/guidelines/guidelines-012021-examples-regarding-personal-data-breach_en
11. EDPB Guidelines 9/2022 on personal data breach notification under GDPR (v2.0, March 2023): awareness and the 72-hour clock: https://www.edpb.europa.eu/our-work-tools/our-documents/guidelines/guidelines-92022-personal-data-breach-notification-under_en
12. CNIL, Privacy Impact Assessment methodology and knowledge bases (EBIOS-based): the four-point severity and likelihood scales and the three feared events used by the Full DPIA: <https://www.cnil.fr/en/privacy-impact-assessment-pia>
13. EDPB Recommendations 01/2020 on measures that supplement transfer tools (v2.0, June 2021): the transfer impact assessment factor in the Privacy Assessment: https://www.edpb.europa.eu/our-work-tools/our-documents/recommendations/recommendations-012020-measures-supplement-transfer_en
14. ISO/IEC 27001:2022 and the Standardized Information Gathering (SIG) questionnaire: the domain structure the Third-Party Security Assessment follows: <https://www.iso.org/standard/27001>
15. OWASP Top 10 for Large Language Model Applications (2025): the attack-resistance controls in the AI/ML supplement of the Third-Party Security Assessment: <https://owasp.org/www-project-top-10-for-large-language-model-applications/>
16. EDPB Guidelines 05/2020 on consent under Regulation 2016/679 (May 2020): topic 10: https://www.edpb.europa.eu/our-work-tools/our-documents/guidelines/guidelines-052020-consent-under-regulation-2016679_en
17. Article 29 Working Party, Guidelines on transparency, WP260 rev.01 (endorsed by the EDPB): topic 15 and the readiness transparency activities: <https://ec.europa.eu/newsroom/article29/items/622227>
18. EDPB Guidelines 3/2019 on processing of personal data through video devices (v2.0, January 2020): topic 1: https://www.edpb.europa.eu/our-work-tools/our-documents/guidelines/guidelines-32019-processing-personal-data-through-video_en

19. Companion verification report, The site against the law, as of 19 September 2026 (site-verification-report-2026-09-19.pdf): what has changed since the pages were written, rated High to Low, with 90 sources.